Arquitectura de Solución — Banca por Internet BP

Challenge Devsu — Líder Técnico de Proyectos / Arquitecto de Soluciones

Hernán Mateo Jurado

2026-11-04

Table of Contents

Portada ejecutiva 5
0.1 Resumen del documento 5
0.2 Objetivo del documento 5
0.3 Alcance del documento 5
0.4 Fuera del alcance del documento 6
0.5 Metodologías y estándares aplicados en este documento 6
1 Resumen ejecutivo 8
1.1 El problema 8
1.2 El marco normativo 9
1.3 La decisión arquitectónica 9
1.4 La solución en síntesis 9
1.5 Presupuesto 10
1.6 Tiempo de entrega (PERT con 3 escenarios) 10
1.7 Principales riesgos 11
1.8 Validación mediante crítica adversarial 11
1.9 Conclusión 12
2 Problema y supuestos 12
2.1 Propósito de este capítulo 12
2.2 Contexto del negocio 12
2.3 Objetivo del sistema 13
2.4 Requisitos funcionales principales (RF) 14
2.5 Actores principales del sistema 15
2.6 Requisitos no funcionales / atributos de calidad (RNF) 16

2.7 Supuestos de operación 17
2.8 Restricciones 21
2.9 Alcance del entregable y fuera del alcance 21
2.10 Síntesis 22
3 Marco normativo 23
3.1 Por qué el marco normativo precede al diseño técnico 23
3.2 Regulación nacional de Ecuador 23
3.3 Estándares internacionales obligatorios o de referencia 26
3.4 Marcos sectoriales de la industria bancaria y financiera 27
3.5 Buenas prácticas de seguridad 28
3.6 Marco normativo Ecuador — resumen aplicable 29
3.7 Mapeo de controles normativos a componentes arquitectónicos 29
3.8 Síntesis 31
4 Comparativa de alternativas con ISO/IEC 25010 31
4.1 Propósito y método de este capítulo 31
4.2 Criterios de evaluación 32
4.3 Alternativa A — Cloud-native pura (AWS managed) 33
4.4 Alternativa B — Híbrida cloud-portable (Kubernetes + Spring Cloud) 36
4.5 Alternativa C — Serverless-first (AWS nativo) 39
4.6 Matriz comparativa consolidada 42
4.7 Decisión: alternativa seleccionada 43
5 Decisiones arquitectónicas clave 44
5.1 Propósito y método del capítulo 44
5.2 ADR-01 — Arquitectura de microservicios: Spring Boot 3 + Java 21 con DDD y Hexagonal Architecture 45
5.3 ADR-02 — API Gateway + Service Discovery: AWS API Gateway (perimetral) + Spring Cloud Gateway (interno) + Kubernetes-native discovery 49
5.4 ADR-03 — Framework SPA web: Angular 17+ con monorepo Nx 51
5.5 ADR-04 — Framework móvil multiplataforma: Flutter 52
5.6 ADR-05 — Proveedor OAuth 2.0: Microsoft Entra External ID y Keycloak como alternativas tercerizables intercambiables 54
5.7 ADR-06 — Flujo OAuth 2.0: Authorization Code + PKCE (S256) 58
5.8 ADR-07 — Autenticación escalonada y step-up: AAL2 base y AAL3 para operaciones de alto impacto 59

5.9 ADR-08 — Onboarding con reconocimiento facial: AWS Rekognition + Liveness con Veridas como fallback certificado 60
5.10 ADR-09 — Persistencia de clientes frecuentes: Cache-Aside sobre Redis con TTL diferencial 61
5.11 ADR-10 — Patrón de mensajería: RabbitMQ para comando asíncrono + Kafka para eventos de dominio 63
5.12 ADR-11 — Patrón de auditoría inmutable: Event Sourcing + Outbox + Aurora append-only con hash-chain + TSA + Anchor S3 Object Lock 64
5.13 ADR-12 — Object storage y gestión de secretos: MinIO + Amazon S3 y HashiCorp Vault + AWS Secrets Manager 67
5.14 Síntesis del capítulo 69
6 Diagramas C4 (de la alternativa seleccionada) 70
6.1 C4 Nivel 1 — Contexto (síntesis del ganador) 70
6.2 C4 Nivel 2 — Contenedores (vista técnica) 70
6.3 C4 Nivel 3 — Componentes (detalle del microservicio canónico) 72
7 Diagramas complementarios 74
7.1 Flujo de autenticación OAuth 2.0 + onboarding con reconocimiento facial 74
7.2 Flujo de auditoría inmutable (Event Sourcing + Outbox + Kafka + Aurora append-only + TSA + OpenSearch) 75
7.3 Flujo de cache (Cache-Aside sobre Redis con invalidación por eventos) 77
7.4 Infraestructura AWS — VPC, subredes y topología de red 78
7.5 Deployment multi-AZ + DR Pilot Light multi-región 80
8 HA, DR, Observabilidad y Auto-healing 82
8.1 Alta disponibilidad (HA) 82
8.2 Disaster Recovery (DR) 82
8.3 Observabilidad — cuatro pilares 83
8.4 Auto-healing 83
8.5 Observabilidad de seguridad 84
8.6 Excelencia operativa 84
9 CI/CD, GitOps y respaldos en cluster 84
9.1 Estrategia general 84
9.2 Fases del pipeline Jenkins 86
9.3 Estrategias de despliegue por criticidad 86
9.4 Respaldos en cluster 86

9.5 Métricas DORA 87
10 Planificación y simulación de tiempos 87
10.1 Marco metodológico 87
10.2 Organización del equipo 87
10.3 Roadmap de alto nivel — 4 incrementos de 3 meses 89
10.4 Plan de sprints — primeros 6 sprints detallados (Incremento 1 + Sprint 7 de Incr. 2) 90
10.5 Simulación de tiempos de entrega — PERT con 3 escenarios 93
10.6 Rituales 95
10.7 Supuestos del modelo 96
10.8 Nota sobre la validez de las estimaciones 96
11 Costos — mensual, trimestral, anual y TCO 96
11.1 Metodología 97
11.2 1. Infraestructura AWS (mensual) — escenario objetivo 500k–1M MAU 97
11.3 2. Licencias y servicios de terceros (mensual) 98
11.4 3. Personal mensual 99
11.5 4. Gran total mensual (dos escenarios de IdP) 100
11.6 5. Costos por escenario de carga (orden de magnitud) 101
11.7 6. Costos por horizonte temporal — escenario objetivo 101
11.8 7. Costos únicos de construcción — año 1 101
11.9 8. Proyección a 3 años — ambas opciones 102
11.10 9. Comparativa con las alternativas descartadas en Cap 3 103
11.11 10. Composición del gasto (escenario objetivo) 103
11.12 11. Palancas de optimización (reducción potencial de 20-35%) 103
11.13 12. Nota sobre validez de las estimaciones 104
12 Riesgos y mitigaciones 104
12.1 Metodología 105
12.2 Matriz de riesgos — 28 riesgos identificados 105
12.3 Riesgos TOP 6 por prioridad (R ≥ 12) 110
12.4 Matriz visual de riesgo (heatmap) 112
12.5 Gestión continua de riesgos 112
12.6 Observación final 112
13 Anexos 113

13.1 Anexo A — Glosario de términos 113
13.2 Anexo B — Lista de siglas 118
13.3 Anexo C — Referencias bibliográficas y normativas 120
13.4 Anexo D — Fichas técnicas de componentes clave 122
13.5 Anexo E — Decisiones futuras (ADRs pendientes) 124

Portada ejecutiva

Autor: Hernán Mateo Jurado **Rol en el ejercicio**: Arquitecto de Soluciones / Líder Técnico de Proyectos **Fecha de entrega**: 2026-11-04

0.1 Resumen del documento

Este documento presenta el diseño de arquitectura de solución para un sistema de **banca por internet** para la entidad financiera BP. Se desarrolla la propuesta técnica desde el entendimiento del problema hasta la planificación de ejecución, pasando por la evaluación de alternativas, el diseño con modelo C4, las decisiones arquitectónicas con sus justificaciones teóricas, el marco normativo aplicable, los costos estimados en distintos niveles de carga y los horizontes mensual, trimestral y anual, y la planificación de equipo con simulación de tiempos de entrega bajo tres escenarios.

0.2 Objetivo del documento

Proveer a BP una **propuesta arquitectónica completa, justificada y evaluable** para su sistema de banca por internet, que cumpla con los requisitos funcionales (consulta de movimientos, transferencias propias e interbancarias, onboarding digital con reconocimiento facial, notificaciones multi-canal) y con los atributos de calidad exigidos para una institución financiera: alta disponibilidad, tolerancia a fallos, recuperación ante desastres, seguridad, auditoría inmutable, auto-healing y cumplimiento normativo.

0.3 Alcance del documento

- Análisis del problema, actores, supuestos y restricciones de operación.
- Comparativa de dos alternativas arquitectónicas evaluadas con **ISO/IEC 25010**.
- Decisiones arquitectónicas detalladas con justificación teórica (mínimo dos por decisión) y alternativas evaluadas por cada una.
- Diseño de la solución con el **modelo C4** (contexto, contenedores y componentes) + diagramas complementarios (flujos de auth, auditoría, cache, infraestructura, HA/DR).
- Diseño de los flujos de autenticación (OAuth 2.0), onboarding con reconocimiento facial, auditoría inmutable y persistencia de datos frecuentes.

- Estrategia de alta disponibilidad, recuperación ante desastres, observabilidad, auto-healing y seguridad.
- Planificación: organización de equipo, sprints, estimación PERT con escenarios optimista / normal / pesimista.
- Marco de costos: **escenarios por carga de usuarios activos** y horizontes mensual, trimestral, anual y TCO a tres años.
- Marco normativo aplicable: LOPDP Ecuador, Superintendencia de Bancos, **ISO/IEC 27001**, PCI-DSS, SOC 2.
- Riesgos del proyecto y mitigaciones propuestas.

0.4 Fuera del alcance del documento

- **Diseño o modificación del core bancario**: el core es un sistema preexistente de BP (motor contable, cálculo de intereses, saldos, cumplimiento contable, conciliación con Banco Central). Este documento diseña el **canal digital que lo consume**, no el core en sí. El core se integra vía APIs expuestas por BP.
- Implementación de código fuente (el documento define arquitectura, no implementa).
- Diseño de productos financieros nuevos (el catálogo de productos lo define BP).
- Operación 24/7 del centro de operaciones de red (NOC/SOC) de BP.
- Integración con red SWIFT u otras redes interbancarias en detalle (se asume provista por el core).

0.5 Metodologías y estándares aplicados en este documento

0.5.1 Arquitectura empresarial y diseño

- **Modelo C4** (Simon Brown) — diagramación arquitectónica en 3 niveles: contexto, contenedores, componentes.
- **ISO/IEC 25010** — evaluación comparativa de alternativas por las 8 características de calidad de producto de software.
- **ISO/IEC 42010** — descripción arquitectónica formal (viewpoints, stakeholders, concerns).
- **Domain-Driven Design (DDD)** — bounded contexts, lenguaje ubicuo, agregados para justificar el diseño de microservicios.
- **Clean Architecture / Hexagonal Architecture** — separación dominio/infraestructura dentro de cada microservicio.
- **The Twelve-Factor App** — principios para aplicaciones nativas cloud (config, logs, procesos stateless, build/release/run).

0.5.2 Patrones de diseño

- **AWS Well-Architected Framework** — 6 pilares (Operational Excellence, Security, Reliability, Performance Efficiency, Cost Optimization, Sustainability).

- **Cloud Design Patterns** (Microsoft) — Cache-Aside, Circuit Breaker, Bulkhead, Retry con backoff, Throttling, etc.
- **Enterprise Integration Patterns** (Hohpe & Woolf) — patrones de mensajería e integración.
- **Microservices Patterns** (Chris Richardson) — Saga, Outbox, CQRS, Event Sourcing, API Composition.

0.5.3 Seguridad de la información

- **ISO/IEC 27001:2022** — marco de referencia SGSI.
- **OWASP Top 10 (2021)** — vulnerabilidades web más comunes.
- **OWASP ASVS L2/L3** — Application Security Verification Standard.
- **OWASP SAMM** — modelo de madurez del programa de seguridad.
- **NIST CSF 2.0** — framework Govern, Identify, Protect, Detect, Respond, Recover.
- **NIST SP 800-63B** — niveles de aseguramiento de identidad digital (AAL1/2/3).
- **NIST SP 800-53** — catálogo de controles de seguridad.
- **MITRE ATT&CK** — tácticas y técnicas de adversarios.
- **CIS Controls v8** — 18 controles de seguridad priorizados.
- **CIS Benchmarks** — hardening específico (Kubernetes, Linux, Docker).

0.5.4 Operación y servicios

- **ISO 22301** — continuidad del negocio (BCP) y recuperación ante desastres.
- **DORA Metrics** — Deployment Frequency, Lead Time for Changes, Change Failure Rate, MTTR.
- **SRE — Site Reliability Engineering** (Google) — SLI/SLO/Error Budget, blameless postmortems.

0.5.5 Gestión del programa y del equipo

- **Scrum** — marco ágil para la ejecución por sprints.
- **Kanban** — flujo continuo para equipos de soporte y mantenimiento.
- **SAFe 6.0** — escalado ágil para múltiples squads coordinados.
- **PMBOK 7** — capa de gobernanza del programa (steering committee, risk register, procurement, communication plan, stakeholder management) como complemento al marco ágil de ejecución.

0.5.6 Estimación

- **PERT** (Program Evaluation and Review Technique) — estimación de tiempos con tres escenarios (optimista, normal, pesimista).

0.5.7 Específicos de la industria bancaria y financiera

- **BIAN** (Banking Industry Architecture Network) — arquitectura de referencia para mapear microservicios a service domains estándar de la industria.

- **PCI-DSS v4.0** — Payment Card Industry Data Security Standard.
- **SOC 2 Type II** — controles operativos auditados.
- **Basilea III** (riesgo operacional digital) — mencionado como referencia normativa internacional.
- **PSD2 / Open Banking** — mencionado como tendencia regulatoria regional (no obligatorio en Ecuador aún).

0.5.8 Marco normativo Ecuador

- **LOPDP** — Ley Orgánica de Protección de Datos Personales (2021).
- **Superintendencia de Bancos del Ecuador** — resoluciones vigentes sobre seguridad de la información y servicios financieros digitales.

0.5.9 UI / UX / Accesibilidad

- **Material Design 3** (Google) — sistema de diseño para Android y web.
- **Apple Human Interface Guidelines (HIG)** — obligatorio para iOS en App Store.
- **Atomic Design** (Brad Frost) — metodología de design systems.
- **Design Tokens** (W3C Design Tokens Community Group) — variables de diseño cross-plataforma.
- **WCAG 2.2 Nivel AA** — accesibilidad web.
- **ISO 9241-11** — definición formal de usabilidad.
- **ISO 9241-210** — diseño centrado en el usuario.

---

1 Resumen ejecutivo

1.1 El problema

La entidad financiera **BP** requiere diseñar un **canal digital bancario** (SPA web + aplicación móvil + backend) que permita a sus clientes: completar el **onboarding digital con reconocimiento facial**, **autenticarse** con OAuth 2.0 + MFA + biometría local, **consultar productos y movimientos**, **realizar transferencias propias e interbancarias** con **autorización step-up por token OTP** para operaciones de alto impacto, **recibir notificaciones multi-canal** (email, push, SMS, WhatsApp) y **ejercer sus derechos LOPDP**. El sistema se integra con sistemas preexistentes de BP (core bancario, CRM/ODS, proveedor de identidad externo) sin modificarlos.

Base de usuarios estimada: 500.000 a 1.000.000 usuarios activos mensuales en régimen inicial, con capacidad diseñada para crecer hasta 3.000.000 (media del mercado ecuatoriano — Banco Pichincha, Guayaquil, Pacífico, Produbanco, Bolivariano). SLA objetivo **99.95%** mensual (≈22 minutos de downtime permitido), RTO ≤ 30 minutos, RPO ≤ 5 minutos.

1.2 El marco normativo

El sistema cumple obligatoriamente con la **Ley Orgánica de Protección de Datos Personales de Ecuador (LOPDP)**, las resoluciones vigentes de la **Superintendencia de Bancos** (incluida JB-2020-2398 sobre servicios tecnológicos en la nube), el **Código Orgánico Monetario y Financiero**, **ISO/IEC 27001:2022**, **ISO 22301** (continuidad del negocio), **PCI-DSS v4.0** (scope reducido por diseño) y **SOC 2 Type II**. Incorpora como buenas prácticas **OWASP ASVS L2/L3**, **NIST CSF 2.0** y **NIST SP 800-63B** para niveles de aseguramiento de autenticación.

1.3 La decisión arquitectónica

Se evaluaron **tres alternativas arquitectónicas** con el estándar **ISO/IEC 25010**: (A) Cloud-native pura sobre AWS managed services, (B) Híbrida cloud-portable sobre Kubernetes + Spring Cloud, y (C) Serverless-first sobre AWS. Los puntajes totales (sobre 40) fueron 33, 36 y 29 respectivamente.

Se seleccionó la Alternativa B — Híbrida cloud-portable con incorporación estratégica de componentes AWS reemplazables (Aurora, MSK, WAF, SES, SNS, Rekognition). Los cuatro motivos principales:

1. **Portabilidad arquitectónica como activo estratégico** en banca regulada — única alternativa con score máximo en portabilidad (5 vs 1 en las otras).
2. **Compatibilidad con core bancario legacy** — stack Spring Cloud + REST + Kafka + OIDC es el estándar bancario LATAM.
3. **Talento Java/Spring disponible** en el mercado LATAM — menor time-to-hire, menor rotación, menor costo unitario.
4. **Robustez transaccional y control fino** del rendimiento — crítico en operaciones ACID de banca.

1.4 La solución en síntesis

El sistema se compone de **8 microservicios Spring Boot 3 sobre Java 21** (onboarding, customer-basic, customer-detail, movements, transfer, notification, audit, authz), desplegados en **Amazon EKS multi-AZ**, con los siguientes diseños clave:

- **Frontend**: SPA en **Angular 17+ con Nx monorepo** y aplicación móvil en **Flutter**.
- **Autenticación**: OAuth 2.0 + OIDC con **Authorization Code + PKCE (S256)**; dos alternativas tercerizables intercambiables como IdP externo: **Microsoft Entra External ID (CIAM)** o **Keycloak** self-hosted; step-up a **AAL3** con token OTP por canal independiente para operaciones de alto impacto.
- **Onboarding facial**: AWS Rekognition + Face Liveness como principal, **Veridas como fallback certificado** para casos de alto riesgo.
- **Enrutamiento**: AWS API Gateway + WAF + Shield en el edge; Spring Cloud Gateway en el cluster con **Kubernetes-native service discovery** (CoreDNS + Services).

- **Datos**: Aurora PostgreSQL Multi-AZ (transaccional), DocumentDB (detalle cliente), Redis con **patrón Cache-Aside** con TTL diferencial e invalidación por eventos.
- **Mensajería**: **RabbitMQ** para comandos asíncronos, **Kafka (MSK)** para eventos de dominio y streaming de auditoría.
- **Auditoría inmutable**: Event Sourcing con patrón **Outbox** → Kafka → **Aurora PostgreSQL append-only con hash-chain HMAC** + **TSA RFC 3161** + **anchor diario a S3 Object Lock modo Compliance** + espejo a OpenSearch para consulta. Resuelve la contradicción LOPDP (derecho de supresión) vs ledger inmutable mediante **crypto-shredding** y base legal del Art. 12 numeral 2.
- **Observabilidad**: Prometheus + Grafana + ELK + Jaeger; cuatro pilares (métricas, logs, trazas, logs de auditoría separados).
- **CI/CD**: Jenkins + ArgoCD (GitOps) con progressive delivery (Canary + Blue/Green).
- **HA + DR**: multi-AZ dentro de la región primaria (us-east-1); DR Pilot Light en región secundaria (us-west-2) con Aurora Global Database + MirrorMaker 2 + S3 CRR.

El Capítulo 4 documenta las **12 ADRs** con sus alternativas evaluadas y justificaciones teóricas. Los Capítulos 5 y 6 presentan el diseño con el **modelo C4** hasta el nivel de componentes, más diagramas complementarios de flujos (OAuth + onboarding, auditoría, cache, infraestructura AWS, deployment HA/DR, pipeline CI/CD).

1.5 Presupuesto

Costo mensual del sistema en el **escenario objetivo (500k–1M MAU)**:

Opción de IdP CIAM	Costo mensual (USD)	Costo anual (USD)	TCO 3 años (USD)
Opción A — Microsoft Entra External ID	124.800 – 137.400	1.727.000 – 1.879.000 (año 1 con setup)	5.050.000 – 5.530.000
Opción B — Keycloak self-hosted	106.500	1.498.000 (año 1 con setup)	~4.350.000

Composición: **personal 60-65%**, licencias y terceros 5-18%, infraestructura cloud 9-10%. El personal (equipo de 22.5 FTE incluyendo workstream regulatorio) es el componente dominante. El detalle completo con escenarios por carga (desde piloto 1k hasta escala masiva 5M+ MAU) y palancas de optimización se desarrolla en el Capítulo 10.

1.6 Tiempo de entrega (PERT con 3 escenarios)

Milestone	Optimista	**Normal (PERT)**	Pesimista
M1 Fundación (landing zone + CI/CD + SSO)	6 sem	**10 sem**	16 sem
M2 Core funcional	11 sem	**22 sem**	34 sem
M3 Transferencias + onboarding + auditoría	18 sem	**34 sem**	50 sem

Milestone	Optimista	**Normal (PERT)**	Pesimista
M4 Go-live piloto (1.000 usuarios)	24 sem (~6m)	**44 sem (~11 meses)**	64 sem (~16m)
M5 General Availability	28 sem (~7m)	**52 sem (12 meses)**	76 sem (~19m)

El plan contempla **4 incrementos de 3 meses**, 6 squads cross-funcionales + plataforma + **workstream regulatorio activo desde el Sprint 1** (crítico por los tiempos de aprobación JB-2020-2398 de la Superintendencia de Bancos).

1.7 Principales riesgos

El Capítulo 11 identifica **28 riesgos** con matriz P × I. Los 3 de mayor prioridad son:

- **R01 — Core bancario inestable** (R=20): mitigado con spike técnico Sprint 1, contratos OpenAPI, mocks WireMock, SLA interno BP ≤48h y modo degradado con Cache-Aside.
- **R03 — Rotación de ingenieros clave** (R=16): mitigado con ADR culture obligatoria, pair programming, bus factor ≥2 por área, salarios competitivos.
- **R24 — Lentitud regulatoria SB** (R=16): mitigado con workstream regulatorio arrancado el Sprint 1 (no al final del Incremento 4) y plan B de iniciar con Keycloak mientras se tramita Entra External ID.

1.8 Validación mediante crítica adversarial

Durante la elaboración del documento, las tres decisiones arquitectónicas más críticas (ADR-01 Microservicios, ADR-05 Proveedor OAuth, ADR-11 Auditoría) fueron sometidas a un **proceso de crítica adversarial** por un arquitecto en rol de abogado del diablo. Este ejercicio identificó hallazgos materiales que fueron **incorporados al diseño final** antes de la entrega:

- La decisión original de usar **Amazon QLDB** para el ledger de auditoría fue reemplazada por **Aurora append-only + hash-chain HMAC + TSA RFC 3161 + anchor S3 Object Lock**, dado que QLDB fue deprecado por AWS en julio 2024 con EOL julio 2025.
- El **pricing de Microsoft Entra ID** fue corregido para reflejar el modelo CIAM (MAU-based, ~USD 18.000–30.000/mes a 1M MAU) en lugar del modelo workforce (per-user) inicialmente contemplado.
- Se eliminó **Netflix Eureka** como service discovery (en mantenimiento desde 2018) a favor de **Kubernetes-native service discovery** con CoreDNS + Services + Spring Cloud LoadBalancer.
- Se agregó cobertura explícita de **token revocation** (introspection + blocklist Redis + TTL corto), **back-channel logout** RFC 8414, y conciliación de la **contradicción LOPDP vs ledger inmutable** mediante crypto-shredding.

- Se incorporó al plan del Capítulo 9 un **workstream regulatorio activo** para gestionar la formalización ante la Superintendencia de Bancos (JB-2020-2398).

El proceso adversarial es evidencia de la madurez metodológica de la propuesta: detectar debilidades antes del go-live, en lugar de descubrirlas tras un incidente.

1.9 Conclusión

La arquitectura propuesta provee a BP un **canal digital bancario robusto, escalable, portable y regulatoriamente defendible** para operar en el mercado ecuatoriano. El diseño prioriza la portabilidad entre proveedores cloud como activo estratégico en banca regulada, usa el estándar bancario Spring + Kubernetes para asegurar talento y compatibilidad con el core legacy, y cumple con el marco normativo ecuatoriano e internacional aplicable.

El entregable de este documento es el **diseño arquitectónico y la planificación de ejecución**; la implementación, despliegue y operación continua están fuera del alcance de este ejercicio pero quedan definidos en los Capítulos 9 (planificación), 10 (costos) y 11 (riesgos) como insumos listos para ejecutar.

---

2 Problema y supuestos

2.1 Propósito de este capítulo

Este capítulo establece el marco del problema que la arquitectura debe resolver, antes de entrar a discutir alternativas de solución. Define el contexto de negocio, los objetivos del sistema, los requisitos funcionales y no funcionales, los actores involucrados, los supuestos de operación y las restricciones. Toda decisión arquitectónica posterior se evalúa contra lo aquí descrito: si una alternativa no satisface los requisitos no funcionales o viola una restricción, queda descartada automáticamente, por elegante que sea técnicamente.

2.2 Contexto del negocio

La entidad financiera **BP** opera en el mercado bancario ecuatoriano y requiere incorporar un canal digital moderno para su base de clientes. El canal digital bancario ha dejado de ser un complemento del canal físico para convertirse en el canal principal de interacción con el cliente.

Las cifras públicas del sector respaldan esta afirmación:

- Los canales digitales **concentraron el 67.7% del número de transacciones** y el 67% del monto movido en el sistema financiero ecuatoriano durante 2024-2025, según datos publicados por Asobanca.[1]

- El **canal móvil registró más de 970 millones de operaciones en 2024**, equivalentes al **54.2% del total transaccional** del sistema.[2]
- **Banred procesó 268 millones de transferencias interbancarias inmediatas en 2025**, un 58% más que en 2024.[3]
- Los **retiros de efectivo cayeron 22%** entre 2024 y 2025, mientras crecen las transferencias, tarjetas y billeteras digitales.[4]
- El **65% de los adultos en Ecuador** tiene al menos una cuenta en una institución financiera formal, según el *Global Findex 2024* del Banco Mundial.[5]
- En el banco líder del mercado, **8 de cada 10 clientes operan por canales digitales** y el **83% de las transacciones monetarias se realiza por medios digitales**.[6]

Un canal digital bancario moderno debe satisfacer simultáneamente tres exigencias que históricamente estuvieron en tensión:

- **Experiencia de usuario** comparable a la de los neobancos (onboarding en minutos, operación en segundos, sin fricción innecesaria).
- **Seguridad bancaria** con autenticación fuerte, auditoría inmutable, prevención de fraude y cumplimiento regulatorio no negociable.
- **Resiliencia y disponibilidad** al nivel que exige una institución financiera (SLA formal, RTO/RPO acotados, continuidad del negocio garantizada).

El sistema diseñado en este documento responde a estas tres exigencias dentro del marco normativo ecuatoriano desarrollado en el capítulo siguiente.

> **Notas y fuentes del contexto de mercado:** [1] Asobanca, *La era de la banca digital en Ecuador — reporte de transacciones*, y actualización 2025. Disponible en asobanca.org.ec. [2] Reportes Asobanca y publicaciones de medios económicos ecuatorianos (Forbes Ecuador, Primicias, El Comercio) con base en datos Asobanca y Superintendencia de Bancos. [3] Banred, cifras de transferencias interbancarias inmediatas 2024-2025. [4] Asobanca y Superintendencia de Bancos, Reportes 2025. [5] World Bank, *Global Findex Database 2024*. [6] Banco Pichincha, declaraciones públicas sobre canales digitales (Primicias / Ecuador221, 2025-2026).

2.3 Objetivo del sistema

Proveer a los clientes de BP un canal digital seguro, confiable, escalable y de bajo tiempo de respuesta, disponible desde la web (SPA) y desde dispositivos móviles (aplicación multiplataforma), que permita:

1. Completar el **onboarding** (alta digital) mediante reconocimiento facial y verificación de identidad.
2. **Autenticarse** mediante mecanismos robustos acordes al riesgo de cada operación.
3. **Autorizar operaciones de alto impacto** mediante tokens de un solo uso entregados por un canal independiente (SMS, email o push de la aplicación).

4. **Consultar la información** de los productos financieros contratados y el histórico de movimientos.
5. **Realizar transferencias** y pagos entre cuentas propias y hacia otras entidades (interbancarias).
6. **Recibir notificaciones** transaccionales y comerciales por múltiples canales.
7. **Ejercer los derechos** reconocidos por la LOPDP (acceso, rectificación, cancelación, oposición, portabilidad).

2.4 Requisitos funcionales principales (RF)

Los requisitos funcionales describen **qué debe hacer el sistema desde la perspectiva del usuario y del negocio**. No prescriben tecnologías ni patrones de implementación: esas decisiones se desarrollan en los capítulos de alternativas y de decisiones arquitectónicas.

ID	Requisito	Descripción
RF-01	Onboarding digital con reconocimiento facial	Alta de nuevos clientes con captura de documento de identidad, verificación facial (liveness + match contra cédula), aceptación de términos y consentimiento LOPDP.
RF-02	Autenticación robusta	Login mediante el servicio corporativo de autenticación de BP (OAuth 2.0 + OIDC). El sistema no implementa el Authorization Server, lo consume.
RF-03	Multifactor y biometría local	Soporte para segundo factor: OTP (TOTP), huella digital o Face ID (biometría local del dispositivo), push approval.
RF-04	Autorización de operaciones de alto impacto con token (step-up)	Para transferencias interbancarias, transferencias sobre un umbral configurable, cambios de datos sensibles y alta de beneficiarios, el sistema exige un **token de un solo uso (OTP)** de vigencia corta (60-120 segundos), entregado por un canal independiente al del login (SMS, email o push de la aplicación). Implementa el concepto de *transaction signing* y el nivel de aseguramiento AAL3 (NIST SP 800-63B).
RF-05	Consulta de productos del cliente	Visualización del listado de productos financieros contratados (cuentas, tarjetas, créditos), con datos básicos obtenidos del core bancario y datos de detalle obtenidos del sistema complementario de información del cliente.
RF-06	Consulta de histórico de movimientos	Visualización paginada del histórico de movimientos de cada producto, con filtros por fecha, tipo y monto.
RF-07	Transferencia entre	Débito y crédito entre cuentas del mismo cliente, con validación de saldo disponible y reglas de negocio.

ID	Requisito	Descripción
	cuentas propias	
RF-08	Transferencia interbancaria	Transferencia hacia cuentas en otras entidades financieras a través del core bancario (que se integra con la cámara de compensación nacional); validación de cutoffs horarios.
RF-09	Notificaciones multi-canal	Envío de notificaciones transaccionales (obligatorias por norma) y comerciales (con consentimiento) por al menos dos canales simultáneos entre: email, push, SMS y WhatsApp.
RF-10	Auditoría inmutable	Toda acción del cliente, operadores internos y accesos administrativos debe registrarse en un ledger inmutable, no repudiable y criptográficamente verificable, consultable por el oficial de cumplimiento.
RF-11	Autogestión del cliente	Portal de autoservicio: actualización de datos permitidos, cambio de contraseña, gestión de dispositivos registrados, ejercicio de derechos ARCO+.
RF-12	Portal del oficial de cumplimiento	Consulta de auditoría, generación de reportes regulatorios, alertas de PLAFT.

2.5 Actores principales del sistema

- **Cliente retail**: usuario final del canal digital. Accede desde la SPA web o desde la aplicación móvil.
- **Cliente nuevo (onboarding)**: aún no tiene credenciales. Solicita alta digital y pasa por el flujo de reconocimiento facial.
- **Operaciones / Back office de BP**: monitorea el sistema, resuelve incidencias, consulta auditoría ante reclamos.
- **Oficial de cumplimiento**: audita operaciones, genera reportes regulatorios, investiga alertas PLAFT.
- **Delegado de Protección de Datos (DPO)**: supervisa cumplimiento LOPDP, gestiona ejercicios ARCO+, coordina notificaciones de brecha.
- **Superintendencia de Bancos del Ecuador**: ente regulador; puede requerir evidencia de controles.
- **Superintendencia de Datos Personales**: ente regulador; receptora de notificaciones de brecha.
- **Core bancario** (externo preexistente): fuente de información básica del cliente, productos y movimientos; ejecutor de transferencias.

- **Sistema de información detallada del cliente — CRM / ODS** (externo preexistente): complementa la información del cliente (perfil comercial, segmentación).
- **Servicio corporativo de autenticación OAuth 2.0** (externo preexistente, configurable): descrito en la sección de supuestos.
- **Proveedor de reconocimiento facial** (externo): servicio especializado de liveness y face-match.
- **Servicios de notificación** (externos, mínimo 2): email, SMS, push, WhatsApp.
- **Red interbancaria nacional**: destino final de transferencias interbancarias, integrada por el core.

2.6 Requisitos no funcionales / atributos de calidad (RNF)

Expresados en términos operativos y medibles. Son los criterios contra los que se evaluarán las alternativas arquitectónicas.

ID	Atributo de calidad	Nivel exigido
RNF-01	Disponibilidad (SLA)	99.95% mensual (≈ 22 minutos de downtime permitido al mes).
RNF-02	Latencia percibida por el cliente (p95)	< 2 segundos en consultas; < 3 segundos en operaciones transaccionales.
RNF-03	Recovery Time Objective (RTO)	≤ 30 minutos.
RNF-04	Recovery Point Objective (RPO)	≤ 5 minutos.
RNF-05	Aseguramiento de autenticación	AAL2 mínimo (NIST SP 800-63B); AAL3 para operaciones de alto riesgo (RF-04).
RNF-06	Auditoría	Inmutable, no repudiable, criptográficamente verificable; retención ≥ 7 años.
RNF-07	Cumplimiento normativo	LOPDP, resoluciones Superintendencia de Bancos, COMF, ISO/IEC 27001, SOC 2, PCI-DSS v4.0 (scope reducido).
RNF-08	Capacidad / escalabilidad	500.000 a 1.000.000 usuarios activos mensuales en régimen inicial; capacidad diseñada para crecer a 2-3 millones sin rediseño estructural.
RNF-09	Observabilidad	Logs estructurados, métricas, trazas distribuidas, logs de auditoría separados. Retención diferenciada.
RNF-10	Mantenibilidad	Componentes desacoplados; contratos versionados; CI/CD con despliegue automatizado; DORA metrics medidas.
RNF-11	Portabilidad	Capacidad de migrar componentes entre regiones del mismo proveedor o entre proveedores cloud con esfuerzo acotado, sin reescribir lógica de negocio.

ID	Atributo de calidad	Nivel exigido
RNF-12	Seguridad	Cifrado en reposo (AES-256) y en tránsito (TLS 1.3); mTLS entre servicios internos; secretos gestionados en servicio especializado.
RNF-13	Accesibilidad	WCAG 2.2 Nivel AA en SPA y aplicación móvil.
RNF-14	Experiencia de usuario	Tasa de completación de onboarding ≥ 85%; NPS objetivo ≥ 50 tras el primer año de operación.

2.7 Supuestos de operación

Los siguientes supuestos definen el marco técnico y de negocio que sustenta el diseño. Deberán validarse con BP antes del arranque real del proyecto; su alteración puede obligar a revisar decisiones arquitectónicas.

2.7.1 Base de usuarios — supuesto basado en la media del mercado ecuatoriano

Dado que no se cuenta con cifras oficiales de BP sobre su base de usuarios digitales esperada para este sistema, los valores asumidos se derivan de la **media observada en los cinco bancos privados más grandes del Ecuador** (ordenados por activos a fecha de corte 2024-2025):

#	Banco	Clientes totales (orden de magnitud)	Usuarios digitales activos (estimados)
1	Banco Pichincha	~6.5 millones	~5.5 millones
2	Banco Guayaquil	~3.8 millones	~3.0 millones
3	Banco del Pacífico	~2.5–3 millones	~2.0–2.5 millones
4	Produbanco	~2–2.5 millones	~1.8 millones
5	Banco Bolivariano	~1.5 millones	~1.2 millones
Media del top 5		**~3.3 millones**	**~2.7 millones**

Fuentes: Forbes Ecuador — *Ranking de bancos por activos y patrimonio 2024 / 2025*; Asobanca — *reportes de digitalización 2025*; declaraciones públicas de las entidades. Los valores están redondeados al orden de magnitud por la variabilidad entre fuentes y cortes de fecha.

Supuesto adoptado para BP en este diseño:

- **Base inicial objetivo**: 500.000 a 1.000.000 usuarios activos mensuales (prudencia por tratarse de un sistema nuevo que arranca, no el canal consolidado de un banco líder).
- **Capacidad diseñada**: hasta 2.000.000–3.000.000 usuarios activos mensuales sin rediseño estructural, alineada con la media de los top 5 del país.
- **Pico transaccional esperado**: ~500 a 2.000 TPS en horarios de nómina; carga promedio 100-300 TPS.

Este supuesto permite dimensionar la infraestructura, estimar costos y planificar escalabilidad sin comprometer la propuesta a cifras no verificadas de BP. Si BP provee valores reales durante la etapa de kickoff, el dimensionamiento se ajusta en consecuencia.

2.7.2 Presupuesto inicial proyectado

Esta sección provee la **vista agregada del presupuesto** como parte del entendimiento inicial del problema. El desglose detallado por rubro (infraestructura, licencias, personal, servicios profesionales) y las palancas de optimización se desarrollan en el capítulo de costos.

El presupuesto se presenta en dos vistas complementarias:

(a) Por escenario de carga — porque el costo del sistema no es constante: escala con el volumen de usuarios activos, el nivel de TPS y el SLA comprometido.

Escenario	Usuarios activos mensuales	TPS pico esperado	SLA razonable	Costo mensual estimado (USD)
Piloto / MVP	1.000	10	99.0%	25.000 – 35.000
Pequeña escala	10.000	50	99.5%	40.000 – 55.000
Mediana escala	100.000	500	99.9%	60.000 – 75.000
Escenario objetivo inicial	**500.000 – 1.000.000**	**500 – 2.000**	**99.95%**	**~85.000 – 110.000**
Escala media del mercado EC	2.000.000 – 3.000.000	5.000	99.95%	140.000 – 180.000
Escala masiva	5.000.000+	15.000+	99.99%	250.000 – 320.000

(b) Por horizonte temporal, para el escenario objetivo inicial (500k–1M usuarios):

Horizonte	Monto estimado (USD)
Mensual (operación)	85.000 – 110.000
Trimestral	255.000 –

Horizonte	Monto estimado (USD)
	330.000
Anual (operación)	1.020.000 – 1.320.000
Costos únicos año 1 (setup landing zone, certificaciones PCI-DSS / SOC 2, pentests, capacitación, diseño UX inicial, consultoría de seguridad)	~180.000
Total año 1	**~1.200.000 – 1.500.000**
TCO estimado a 3 años	**~3.400.000 – 4.100.000**

Composición típica del gasto en banca digital (referencia de industria): - **Personal del equipo**: 70-80% del total (piso mínimo irreducible: equipo bancario multidisciplinario ~12-18 personas). - **Infraestructura cloud y servicios gestionados**: 10-15% del total (escala elásticamente con la carga). - **Licencias de terceros y servicios profesionales**: 5-10% del total (auditorías, pentests, soporte vendors, herramientas enterprise).

Observación sobre el escalamiento del presupuesto y la disponibilidad: el SLA comprometido impacta directamente el costo. Un sistema para 10.000 usuarios puede operar con 99.5% mono-región con infraestructura sencilla; un sistema con la carga objetivo de 500k–1M usuarios y 99.95% exige multi-AZ obligatorio, DR activo en región secundaria y automatización de failover, lo que incrementa el costo de infraestructura y la complejidad operativa. Comprometer un SLA superior al que la arquitectura puede sostener es un riesgo contractual y reputacional; comprometer un SLA inferior al que el negocio requiere es un riesgo competitivo.

Las estimaciones anteriores son **órdenes de magnitud** basados en pricing público de hyperscalers (AWS/Azure a fecha 2025) y rangos salariales de LATAM. El dimensionamiento final requiere el ejercicio de AWS Pricing Calculator (o equivalente Azure) con la configuración específica del diseño y la validación de salarios con BP.

2.7.3 Equipo de trabajo

Se asume un equipo multidisciplinario alineado con las prácticas estándar de la industria para proyectos de banca digital en LATAM. Composición típica:

- Arquitecto de Solución / Líder Técnico.
- Tech Leads (backend, frontend, mobile).
- Ingenieros backend senior y semi-senior.
- Ingenieros frontend (SPA) senior y semi-senior.
- Ingenieros mobile (framework multiplataforma) senior y semi-senior.
- DevOps / SRE senior.

- QA Automation y QA Manual.
- Especialista en seguridad de aplicaciones.
- UX / UI Designer.
- Product Owner / Scrum Master.

Metodología: SAFe-lite / Scrum of Scrums para la ejecución; PMBOK 7 como capa de gobernanza del programa. El detalle de headcount y plan de sprints se desarrolla en el capítulo de planificación.

2.7.4 Distribución geográfica

Usuarios concentrados en Ecuador. Latencia optimizada para la región. No se requiere multi-región activo-activo desde el día uno; se contempla multi-región Pilot Light / Warm Standby para cumplir RTO.

2.7.5 Core bancario

Expone APIs documentadas para consulta de cliente, productos, movimientos y ejecución de transferencias. Su SLA interno es conocido y acotado. No se modifica como parte de este proyecto.

2.7.6 Autenticación corporativa

BP cuenta con un producto corporativo configurable para OAuth 2.0 / OIDC. Este documento **evalúa dos alternativas como servicios externos tercerizables** (detalle en el capítulo de decisiones arquitectónicas), de manera que BP pueda optar entre ellas en función de su contexto, licenciamiento vigente y estrategia:

- **Microsoft Entra ID** (Identity as a Service, SaaS).
- **Keycloak** (open-source, self-hosted o con soporte comercial de Red Hat).

La arquitectura las trata como **proveedores de identidad intercambiables** mediante estándares abiertos (OIDC + OAuth 2.0 + JWT + JWKS), lo que permite a BP cambiar de proveedor o combinar ambos sin impacto estructural en los demás componentes del sistema.

2.7.7 Red interbancaria

La integración con la cámara de compensación nacional es responsabilidad del core bancario y se asume operativa.

2.8 Restricciones

2.8.1 Restricciones regulatorias

Cumplimiento obligatorio con la normativa desarrollada en el Capítulo “Marco normativo”: LOPDP, resoluciones de la Superintendencia de Bancos, COMF, Ley de Telecomunicaciones + ARCOTEL.

2.8.2 Restricciones de integración

El core bancario y el sistema de detalle del cliente son preexistentes y no se modifican como parte de este proyecto; se consumen vía sus interfaces expuestas.

2.8.3 Restricciones de autenticación

El servicio OAuth 2.0 / OIDC es un proveedor externo tercerizable; se configura y se consume, no se implementa.

2.8.4 Restricciones de latencia

La latencia percibida por el cliente final debe mantenerse por debajo de los 2 segundos en el 95% de las operaciones de consulta y por debajo de los 3 segundos en operaciones transaccionales.

2.8.5 Restricciones de auditoría

Toda acción del cliente y todo acceso administrativo debe registrarse de forma inmutable, no repudiable y criptográficamente verificable, con retención mínima de 7 años para registros con impacto financiero o regulatorio.

2.8.6 Restricciones de disaster recovery

El sistema debe operar en al menos dos zonas de disponibilidad (multi-AZ obligatorio). Se contempla multi-región bajo esquema Pilot Light o Warm Standby para cumplir el RTO de 30 minutos.

2.9 Alcance del entregable y fuera del alcance

> **Importante**: el presente ejercicio tiene por objeto la **entrega de un diseño de arquitectura de solución** y su documentación. No se incluye la construcción, el despliegue ni la operación del software. Esta sección aclara qué está dentro y qué queda fuera del entregable.

2.9.1 Dentro del alcance del documento (entregable)

- Entendimiento del problema, requisitos funcionales y no funcionales, actores, supuestos y restricciones (este capítulo).
- Identificación del marco normativo aplicable.

- Evaluación comparativa de alternativas arquitectónicas con ISO/IEC 25010.
- Decisiones arquitectónicas clave con justificación teórica (mínimo dos por decisión) y alternativas evaluadas por cada una.
- Diseño de la solución con el modelo C4 hasta el nivel de componentes y diagramas complementarios.
- Estrategia de alta disponibilidad, disaster recovery, observabilidad, auto-healing y seguridad.
- Diseño del pipeline de CI/CD y de los respaldos en cluster.
- Plan de implementación: organización del equipo, sprints y simulación de tiempos.
- Estimación de costos por carga y por horizonte temporal.
- Registro de riesgos del proyecto y mitigaciones propuestas.
- Anexos (glosario, siglas, referencias).

2.9.2 Fuera del alcance del documento (no forma parte del entregable)

- **Implementación del código fuente** de los componentes de la arquitectura.
- **Despliegue efectivo** de la infraestructura en una cuenta cloud real.
- **Operación continua** del sistema tras el despliegue (NOC/SOC, soporte 24/7, gestión de incidentes).
- **Diseño o modificación de sistemas preexistentes de BP**: core bancario, sistema de detalle de cliente (CRM/ODS), Authorization Server corporativo de OAuth 2.0.
- **Diseño de productos financieros nuevos** (el catálogo lo define el área de negocio de BP).
- **Integración detallada con red SWIFT o redes internacionales** (se asume provista por el core).
- **Pruebas de penetración reales, auditorías SOC 2 formales, certificaciones PCI-DSS**: se recomiendan en el plan pero no se ejecutan como parte de este entregable.

2.10 Síntesis

El sistema a diseñar es el **canal digital bancario** (SPA web + aplicación móvil + backend) para la entidad financiera BP. Permite onboarding digital con reconocimiento facial, autenticación robusta con OAuth 2.0 (dos alternativas de proveedor tercerizable: Microsoft Entra ID y Keycloak), consulta de información y movimientos, transferencias entre cuentas propias e interbancarias con autorización por token de un solo uso para operaciones de alto impacto, notificaciones multi-canal y ejercicio de derechos ARCO+. Se integra con sistemas preexistentes de BP (core bancario, sistema de detalle de cliente, servicio de autenticación) sin modificarlos. Debe cumplir simultáneamente con requisitos de experiencia de usuario, seguridad bancaria y resiliencia operativa, dentro del marco normativo del capítulo siguiente.

Los supuestos de carga se basan en la media de los cinco bancos privados más grandes del Ecuador, ajustados por tratarse de un sistema nuevo. El entregable es el diseño de la arquitectura y su documentación; no la implementación ni la operación.

---

3 Marco normativo

3.1 Por qué el marco normativo precede al diseño técnico

En una entidad financiera, la normativa no es una capa que se suma al final del diseño: es una restricción de entrada que condiciona la arquitectura desde su origen. Un diseño técnicamente elegante pero regulatoriamente inviable es un diseño descartado. Por eso este capítulo precede al desarrollo de las alternativas y de las decisiones arquitectónicas: establece el conjunto de obligaciones que la solución debe satisfacer por diseño, no por configuración posterior.

El marco normativo aplicable al sistema de banca por internet de BP se organiza en cinco bloques:

1. **Regulación nacional de Ecuador** (obligatoria).
2. **Estándares internacionales obligatorios o de referencia** (ISO 27001, ISO 22301, PCI-DSS, SOC 2).
3. **Marcos sectoriales de la industria bancaria y financiera** (Basilea III, BIAN, PSD2 como tendencia).
4. **Buenas prácticas de seguridad** (OWASP, NIST, CIS, MITRE).
5. **Mapeo de controles normativos a componentes arquitectónicos** (traducción concreta de la obligación a la implementación).

3.2 Regulación nacional de Ecuador

3.2.1 Ley Orgánica de Protección de Datos Personales (LOPDP) — Registro Oficial, mayo 2021

La LOPDP es la norma de aplicación transversal para todo tratamiento de datos personales de residentes en Ecuador. En el contexto de banca digital, la LOPDP impacta prácticamente todos los flujos: onboarding, autenticación, consulta de productos, transferencias, notificaciones y auditoría.

Obligaciones principales que condicionan la arquitectura:

- **Consentimiento expreso, informado, libre y específico** (Art. 7). El sistema debe capturar y persistir evidencia del consentimiento por cada finalidad de tratamiento.

- **Principio de minimización** (Art. 10.3). El sistema debe recolectar únicamente los datos necesarios para la finalidad declarada. No se pueden guardar datos "por si acaso".
- **Derechos ARCO+** (Arts. 12 a 18): Acceso, Rectificación, Cancelación, Oposición, Portabilidad, y oposición a Decisiones Automatizadas. La arquitectura debe exponer endpoints o procesos para el ejercicio de cada derecho.
- **Delegado de Protección de Datos (DPO)** (Art. 47). Figura obligatoria en entidades que tratan datos de alto riesgo (incluye biometría de onboarding facial). La arquitectura debe proveer al DPO consolas o reportes operativos.
- **Notificación de brechas de seguridad en 72 horas** (Art. 46). Obligatoria a la Superintendencia de Datos Personales y a los afectados cuando hay riesgo alto. La arquitectura debe soportar detección temprana, forensia y canales de notificación.
- **Evaluación de Impacto a la Protección de Datos (EIPD)** (Art. 44). Obligatoria para tratamientos de alto riesgo. El reconocimiento facial del onboarding entra en esta categoría y requiere EIPD documentada.
- **Sanciones**. Las sanciones establecidas llegan hasta el 1% del volumen de negocio en infracciones leves y pueden ser mayores en infracciones graves y muy graves.

Impacto arquitectónico concreto:

- Cifrado en reposo obligatorio (AWS KMS / HashiCorp Vault) en toda base de datos, cache y objeto almacenado.
- Cifrado en tránsito obligatorio (TLS 1.3 entre todos los componentes, mTLS entre microservicios).
- Logs de auditoría con retención controlada y procedimiento documentado de purga selectiva.
- Endpoints dedicados para ejercer derechos ARCO integrados al portal del cliente.
- Pseudonimización de datos personales en analytics, logs operativos y entornos no productivos.
- Segregación lógica de datos personales (microservicio `customer-data-service`) respecto de datos operativos (movimientos, transferencias).
- Playbook de respuesta a incidentes con tiempos medibles (detección, contención, notificación) alineado al límite de 72 horas.

3.2.2 Superintendencia de Bancos del Ecuador

La Superintendencia de Bancos emite resoluciones de cumplimiento obligatorio para las entidades financieras controladas. Para el diseño de banca por internet, resultan relevantes las resoluciones vigentes sobre:

- Seguridad de la información en entidades controladas (gestión del SGSI, controles mínimos, auditoría interna y externa).

- Servicios financieros digitales (canales electrónicos, autenticación fuerte, registro de operaciones, atención al cliente digital).
- Prevención de lavado de activos y financiamiento del terrorismo (PLAFT): monitoreo transaccional, umbrales de alerta, reportes automáticos.
- Continuidad del negocio: plan de continuidad (BCP) y plan de recuperación ante desastres (DR) documentados, probados y auditados anualmente.

Impacto arquitectónico concreto:

- Auditoría inmutable y no-repudiable de toda acción del cliente y de todo acceso administrativo (patrón de Event Sourcing + ledger inmutable (Aurora append-only con hash-chain HMAC + TSA + anchor S3 Object Lock)).
- Monitoreo transaccional con motor de reglas para detección de fraude y PLAFT en tiempo cercano al real.
- Reportes regulatorios automatizados generables bajo demanda.
- Plan BCP/DR documentado, versionado y probado mediante simulacros periódicos (DR Drill / Game Day).
- Segregación obligatoria de ambientes de desarrollo, pruebas, pre-producción y producción, con controles diferenciados.

3.2.3 Código Orgánico Monetario y Financiero (COMF)

El COMF regula el funcionamiento del sistema financiero, monetario, de valores y de seguros del Ecuador. Para el canal digital impacta en:

- Operaciones de transferencias interbancarias: cumplimiento con las reglas de compensación, cutoffs horarios y uso de la cámara de compensación nacional.
- Secreto bancario (Art. 353): obligación de confidencialidad sobre operaciones y saldos; restringe quién, cuándo y cómo puede acceder a información del cliente.
- Protección al usuario del sistema financiero: transparencia de información, cobros, canales de reclamo.

3.2.4 Ley Orgánica de Telecomunicaciones y marco ARCOTEL

Aplica al uso de canales SMS y push notification para notificaciones transaccionales y comerciales al cliente. Obliga a:

- Capturar consentimiento comercial diferenciado del consentimiento transaccional.
- Respetar listas de no-contacto.
- Ofrecer mecanismos de opt-out en cada mensaje comercial.

3.3 Estándares internacionales obligatorios o de referencia

3.3.1 ISO/IEC 27001:2022 — Sistema de Gestión de Seguridad de la Información (SGSI)

Estándar internacional de referencia para la gestión de la seguridad de la información. Aunque la certificación formal no es obligatoria en Ecuador, sus controles son auditados por la Superintendencia como parte de la verificación del SGSI exigida a las entidades controladas. Se aplica como marco de controles del Anexo A.

Controles del Anexo A particularmente relevantes para el sistema:

- A.5 — Controles organizativos (políticas, roles, segregación de funciones).
- A.6 — Controles de personas (screening, concientización, acuerdos de confidencialidad).
- A.7 — Controles físicos (datacenter, HSM, control de acceso físico).
- A.8 — Controles tecnológicos (criptografía, control de acceso, backup, logging, protección contra malware, gestión de vulnerabilidades, hardening, segmentación de red).

3.3.2 ISO 22301 — Gestión de la Continuidad del Negocio (BCM)

Estándar internacional para la continuidad del negocio. Define el ciclo de vida de análisis de impacto al negocio (BIA), diseño del plan de continuidad, pruebas, revisión y mejora continua.

Aplicación concreta al sistema:

- Análisis de impacto al negocio (BIA) identifica los procesos críticos y define los RTO/RPO por proceso. En banca digital los procesos críticos son autenticación, consulta de saldos y transferencias.
- Estrategia de continuidad: multi-AZ obligatorio, DR Pilot Light en región secundaria, failover automatizado donde sea posible y controlado donde la decisión humana sea requerida.
- Pruebas de DR trimestrales (Game Day) con observadores externos y reportes auditables.

3.3.3 PCI-DSS v4.0 — Payment Card Industry Data Security Standard

Obligatorio si el sistema procesa, almacena o transmite datos de tarjetas (PAN, CVV, track data). En el diseño propuesto, el core bancario maneja las tarjetas y el canal digital nunca ve datos sensibles de tarjetas, por lo que el **scope PCI-DSS se mantiene reducido** mediante segmentación de red estricta y tokenización en la frontera.

Requisitos de PCI-DSS v4.0 aplicables al canal digital:

- Segmentación de red: el entorno del dato del titular de tarjeta (CDE) debe estar aislado del resto por controles de red verificables.
- Cifrado fuerte en reposo y en tránsito; prohibido almacenar CVV; PAN pseudonimizado o tokenizado si se requiere referencia.
- Logs de auditoría con retención mínima de un año (tres meses accesibles en línea).
- Pentesting anual y Approved Scanning Vendor (ASV) scans trimestrales.
- MFA obligatorio para accesos administrativos al CDE.
- Programa de gestión de vulnerabilidades con SAST, SCA y DAST integrados al pipeline de CI/CD.

3.3.4 SOC 2 Type II

Report de auditoría de controles operativos sostenidos en el tiempo (típicamente 6 a 12 meses de ventana auditada). Es un diferenciador de confianza frente a clientes institucionales, partners y socios comerciales.

Criterios de los Trust Services Criteria (TSC) aplicables:

- **Security** (obligatorio en todo SOC 2).
- **Availability** (relevante por el compromiso de SLA 99.95%).
- **Confidentiality** (relevante por el carácter sensible de la información financiera).
- **Processing Integrity** (relevante por la naturaleza transaccional del sistema).
- **Privacy** (relevante por alineación con LOPDP).

3.3.5 ISO/IEC 27701 — Sistema de Gestión de Información de Privacidad (PIMS)

Extensión de ISO 27001 orientada a la gestión de información personal. Alineada con los principios de LOPDP y GDPR. Se cita como referencia para el diseño de los controles de privacidad.

3.4 Marcos sectoriales de la industria bancaria y financiera

3.4.1 BIAN — Banking Industry Architecture Network

BIAN es la arquitectura de referencia estándar de la industria bancaria. Provee un lenguaje común para describir los dominios de servicio de un banco (Customer Management, Party Life Cycle Management, Payment Order, Transaction Engine, Credit Facility, Position Keeping, Audit Trail, etc.). La ventaja de aplicar BIAN es doble:

- Permite **mapear los microservicios de la solución a dominios de servicio estándar**, facilitando la conversación técnica con arquitectos bancarios senior tanto del cliente como de terceros.
- Facilita el reemplazo o integración futura de componentes manteniendo contratos conocidos.

En este diseño se mapean los microservicios propuestos a dominios BIAN. Por ejemplo: el microservicio de consulta de datos básicos del cliente se alinea con el dominio BIAN *Party Reference Data Directory*; el de consulta de movimientos, con *Current Account*; el de transferencias, con *Payment Order*; la auditoría inmutable, con *Audit Trail*.

3.4.2 Basilea III — Marco internacional de riesgo bancario

Basilea III define requerimientos de capital, liquidez y gestión de riesgos para entidades bancarias. Aunque se refiere primariamente a riesgo financiero, el **Pilar 2 (Riesgo Operacional)** y las guías de **ciber-riesgo operacional** del Comité de Basilea impactan al diseño de sistemas críticos digitales. Se cita como referencia que sustenta las exigencias de disponibilidad, resiliencia y continuidad declaradas en los niveles de servicio.

3.4.3 PSD2 / Open Banking — Mención como tendencia regulatoria

PSD2 (Payment Services Directive 2) es la directiva europea que obliga a los bancos a exponer APIs reguladas para operaciones de pago y acceso de información de cuenta a terceros autorizados (Third Party Providers). No es obligatoria en Ecuador en el presente, pero varios reguladores de la región (Brasil, México, Chile) han adoptado marcos equivalentes de Open Banking. La arquitectura propuesta considera esta tendencia al exponer los dominios de servicio mediante APIs REST versionadas con contratos OpenAPI documentados, lo que facilita una eventual futura publicación de APIs reguladas sin rediseño estructural.

3.5 Buenas prácticas de seguridad

3.5.1 Familia OWASP

- **OWASP Top 10 (2021)**: catálogo de las diez categorías de vulnerabilidades web más frecuentes. Es la línea base de amenazas que la aplicación SPA y las APIs deben mitigar explícitamente. La lista incluye Broken Access Control, Cryptographic Failures, Injection, Insecure Design, Security Misconfiguration, Vulnerable and Outdated Components, Identification and Authentication Failures, Software and Data Integrity Failures, Security Logging and Monitoring Failures, y Server-Side Request Forgery.
- **OWASP ASVS (Application Security Verification Standard) v4.0**: checklist formal de verificación de seguridad de aplicaciones. Se exige **Nivel L2 como línea base** para toda la aplicación y **Nivel L3 para componentes críticos** (auth, transferencias, auditoría).
- **OWASP SAMM (Software Assurance Maturity Model)**: modelo de madurez del programa de seguridad del desarrollo de software. Permite evaluar el estado actual y planificar la mejora en cinco funciones de negocio (Governance, Design, Implementation, Verification, Operations).

3.5.2 Familia NIST

- **NIST Cybersecurity Framework (CSF) 2.0**: marco de referencia para programas de ciberseguridad, estructurado en seis funciones (Govern, Identify, Protect, Detect, Respond, Recover). Se aplica como mapa mental para no dejar dimensiones sin cubrir.
- **NIST SP 800-63B — Digital Identity Guidelines**: define los niveles de aseguramiento de autenticación (Authentication Assurance Levels, AAL1/2/3). Banca requiere **AAL2 como mínimo**; para operaciones de alto riesgo (transferencias sobre umbral, cambios de contraseña, actualización de datos) se exige **AAL3** mediante step-up authentication.
- **NIST SP 800-53 Rev. 5 — Security and Privacy Controls**: catálogo exhaustivo de controles de seguridad. Se usa como referencia en el diseño de controles específicos (gestión de identidades, control de acceso, auditoría, respuesta a incidentes).
- **MITRE ATT&CK**: matriz de tácticas y técnicas de adversarios. Se utiliza para dimensionar la postura defensiva y las capacidades de detección del SOC.

3.5.3 Familia CIS

- **CIS Controls v8**: dieciocho controles de seguridad priorizados por efectividad costo-beneficio. Se aplican como línea base operativa.
- **CIS Benchmarks**: guías de configuración segura (hardening) para tecnologías específicas. En este sistema se aplican los benchmarks de **Kubernetes, Linux (Amazon Linux 2023), y Docker/containerd**.

3.6 Marco normativo Ecuador — resumen aplicable

Norma	Ámbito	Obligación de aplicación
LOPDP (2021)	Datos personales	Obligatoria
Resoluciones Superintendencia de Bancos	Seguridad, servicios digitales, PLAFT, BCP	Obligatoria
Código Orgánico Monetario y Financiero	Operaciones, secreto bancario	Obligatoria
Ley Orgánica de Telecomunicaciones + ARCOTEL	Notificaciones digitales	Obligatoria

3.7 Mapeo de controles normativos a componentes arquitectónicos

La siguiente tabla traduce las obligaciones normativas en los componentes y mecanismos concretos de la arquitectura que las satisfacen. Esta tabla es el puente entre el capítulo normativo y los capítulos técnicos siguientes.

Obligación / control	Componente o mecanismo arquitectónico que lo cubre

Obligación / control	Componente o mecanismo arquitectónico que lo cubre
LOPDP — captura y evidencia de consentimiento	Flujo de onboarding con registro firmado en el log de auditoría (Kafka → Aurora append-only ledger con HMAC + TSA)
LOPDP — cifrado en reposo	AWS KMS + encriptación de EBS, RDS Aurora, DocumentDB, MinIO, Vault
LOPDP — cifrado en tránsito	TLS 1.3 en todos los endpoints públicos; mTLS entre microservicios dentro del cluster (Istio o linkerd opcional)
LOPDP — ejercicio de derechos ARCO	API expuesta por `customer-rights-service`; portal web en el canal de autoservicio
LOPDP — notificación de brecha en 72h	Playbook versionado en Confluence; alertas automáticas de GuardDuty + Security Hub; canal de notificación al DPO en PagerDuty
LOPDP — EIPD para tratamiento biométrico (onboarding facial)	Documento EIPD anexo + logs específicos de procesamiento facial + alternativa de verificación manual en sucursal para opt-out
Superintendencia de Bancos — auditoría inmutable	Event Sourcing con Kafka (patrón Outbox) + consumer a Aurora append-only con hash-chain HMAC + TSA RFC 3161 + anchor S3 Object Lock + mirror a OpenSearch para consulta
Superintendencia de Bancos — PLAFT	Reglas antifraude en el motor transaccional + scoring de machine learning + reportes regulatorios automatizados
Superintendencia de Bancos — BCP / DR	Arquitectura multi-AZ + DR Pilot Light en región us-west-2 + DR drills trimestrales
COMF — secreto bancario	Control de acceso basado en atributos (ABAC) + logging de accesos administrativos + segregación de funciones
PCI-DSS — segmentación CDE	Subnets dedicadas + Network Policies en Kubernetes + WAF rules diferenciadas
PCI-DSS — pentests anuales + ASV trimestrales	Programa anual contratado + bug bounty opcional
ISO 27001 — logging y monitoreo	Agregación centralizada en ELK/OpenSearch + alertas SIEM + retención diferenciada
ISO 27001 — control de acceso	Keycloak o Microsoft Entra ID + RBAC en Kubernetes + IAM AWS + principio de mínimo privilegio
ISO 22301 — continuidad del negocio	Plan BCP documentado, aprobado, probado y auditado anualmente
SOC 2 — disponibilidad	SLA 99.95% + monitoreo + chaos engineering mensual
OWASP ASVS L2/L3	SAST (SonarQube) + SCA (Snyk) + DAST (OWASP ZAP) integrados al pipeline Jenkins

Obligación / control	Componente o mecanismo arquitectónico que lo cubre
NIST SP 800-63B — AAL2/AAL3	Autenticación multifactor obligatoria + step-up para operaciones críticas
CIS Benchmark K8s	Hardening del cluster EKS auditado automáticamente con kube-bench + AWS Config rules

3.8 Síntesis

El marco normativo aplicable al sistema de banca por internet de BP combina obligaciones nacionales (LOPDP, Superintendencia de Bancos, COMF, ARCOTEL), estándares internacionales (ISO 27001, ISO 22301, PCI-DSS v4.0, SOC 2 Type II), marcos sectoriales bancarios (BIAN, Basilea III, PSD2 como tendencia) y buenas prácticas de seguridad (OWASP, NIST, CIS, MITRE). Cada obligación se traduce en componentes y mecanismos arquitectónicos concretos (sección 2.7), que se desarrollan en los capítulos siguientes del documento. Esta trazabilidad bidireccional —de obligación a componente y viceversa— es la que permite responder, frente a un auditor, con qué control específico se cubre cada requerimiento regulatorio.

---

4 Comparativa de alternativas con ISO/IEC 25010

4.1 Propósito y método de este capítulo

Este capítulo compara tres alternativas arquitectónicas capaces de resolver el problema planteado en el Capítulo 1 dentro del marco normativo del Capítulo 2. Cada alternativa se describe con sus componentes concretos, se evalúa con las ocho características del estándar **ISO/IEC 25010:2011** de calidad de producto de software, y se contrasta por costo y tiempo de puesta en producción. El capítulo cierra con una **recomendación condicional** —no una única "mejor" opción— porque la decisión definitiva depende de criterios que BP debe ponderar (tolerancia al vendor lock-in, talento disponible, apetito de operación interna, etc.). La decisión formal se toma en el Capítulo 4.

4.1.1 Alternativas evaluadas en profundidad

- **Alternativa A** — *Cloud-native pura sobre AWS managed services*. Maximiza el uso de servicios administrados por el hyperscaler; minimiza la operación propia; acepta lock-in.
- **Alternativa B** — *Híbrida cloud-portable sobre Kubernetes + Spring Cloud*. Usa Kubernetes administrado como denominador común portable; componentes open-source estándar en el ecosistema Java; AWS como proveedor base pero reemplazable.

- **Alternativa C** — *Serverless-first sobre AWS nativo*. 100% event-driven, Lambda + Step Functions + DynamoDB Global Tables; costo variable puro; cero operación de infraestructura.

4.1.2 Alternativas consideradas y descartadas tempranamente

- **Monolito modular desplegado en PaaS** (Elastic Beanstalk / Heroku-style): descartada porque no cumple el requisito RNF-08 de escalabilidad a 2-3 millones de usuarios sin rediseño estructural ni el requisito de segregación de responsabilidades exigido en entornos regulados bancarios.
- **Microservicios sobre Node.js o Python (Flask/FastAPI)**: descartadas para el núcleo transaccional. Son opciones válidas para componentes de borde (notificaciones, APIs públicas), pero la banca core/transaccional en LATAM se apoya mayoritariamente en Java/.NET por tradición regulatoria y madurez de bibliotecas transaccionales. Se contempla su uso puntual en componentes no críticos.
- **Arquitectura on-premises pura**: descartada por costo de infraestructura inicial, SLAs inferiores a los cloud y falta de alineamiento con la tendencia regulatoria regional.

4.2 Criterios de evaluación

4.2.1 Las ocho características de ISO/IEC 25010

Cada alternativa se evalúa con score **1-5** (1 = muy débil, 5 = excelente) en cada característica:

1. **Idoneidad funcional** — ¿cubre todos los requisitos funcionales del Capítulo 1?
2. **Eficiencia de desempeño** — comportamiento temporal, utilización de recursos, capacidad.
3. **Compatibilidad** — coexistencia e interoperabilidad con sistemas externos (core bancario, servicios de notificación, autenticación corporativa).
4. **Usabilidad** — aquí se evalúa la **usabilidad operativa** (facilidad de operar el sistema) y la **usabilidad para developers** (DX).
5. **Fiabilidad** — madurez, disponibilidad, tolerancia a fallos, recuperabilidad.
6. **Seguridad** — confidencialidad, integridad, no repudio, autenticidad, responsabilidad.
7. **Mantenibilidad** — modularidad, reusabilidad, analizabilidad, modificabilidad, testabilidad.
8. **Portabilidad** — adaptabilidad, instalabilidad, reemplazabilidad.

4.2.2 Criterios complementarios considerados

- **Costo mensual** para el escenario objetivo (500k–1M MAU, 99.95% SLA).
- **Tiempo estimado hasta producción** (MVP go-live piloto).

- **Complejidad operativa**.
- **Disponibilidad de talento** en el mercado LATAM.

4.3 Alternativa A — Cloud-native pura (AWS managed)

4.3.1 Descripción

Arquitectura 100% apoyada en servicios administrados por AWS. El equipo construye código de negocio (Lambda functions, aplicaciones Fargate) y la lógica de orquestación; la infraestructura subyacente, los brokers, las bases de datos y los servicios cognitivos son operados por AWS. Lock-in alto; operación propia mínima.

4.3.2 Diagrama C4 — Nivel 1: Contexto (Alternativa A)

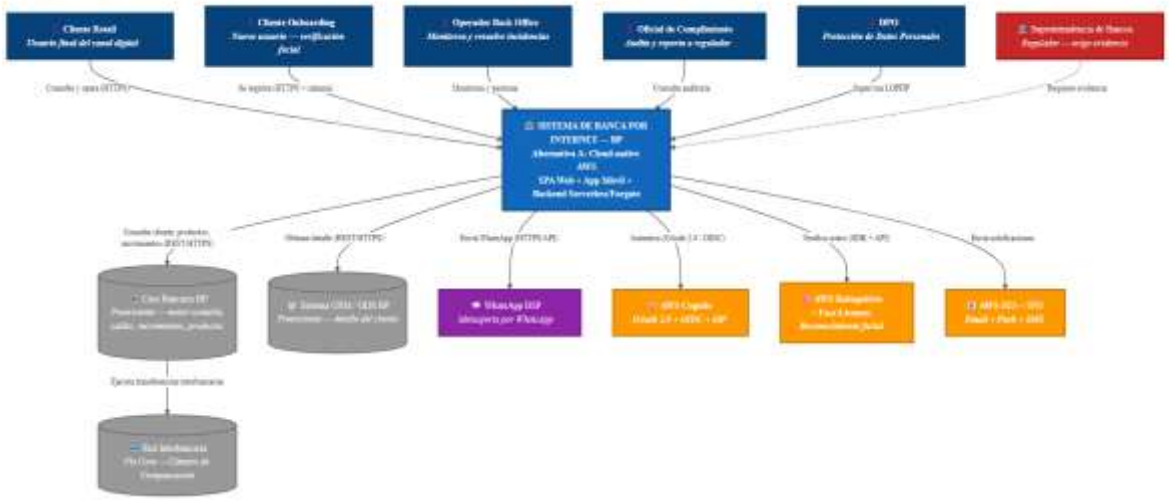


Diagrama C4 Nivel 1 — Contexto — Alternativa A (Cloud-native AWS)

Nota sobre el diagrama: a nivel de Contexto (C4 Nivel 1), las tres alternativas comparten los mismos actores y sistemas externos preexistentes de BP (core bancario, CRM/ODS, red interbancaria). La diferencia visible en este nivel es **qué servicios propietarios del proveedor cloud forman parte del contorno del sistema**: en la Alternativa A, prácticamente toda la funcionalidad de identidad, reconocimiento facial y notificaciones recae en servicios AWS managed (color naranja), lo que hace explícito el acoplamiento al proveedor desde el nivel más alto de la arquitectura.

4.3.3 Componentes principales

Función	Servicio AWS
Edge / CDN / WAF	CloudFront + AWS WAF + AWS Shield
API Gateway	Amazon API Gateway (REST + WebSocket)
Identidad / OAuth 2.0	Amazon Cognito (IdP)

Función	Servicio AWS
Compute aplicaciones	AWS Lambda + AWS Fargate (según tipo de carga)
Reconocimiento facial	Amazon Rekognition + Face Liveness
Base de datos transaccional	Amazon Aurora PostgreSQL Multi-AZ
Base de datos de detalle cliente	Amazon DynamoDB
Auditoría inmutable	Amazon QLDB (ledger criptográficamente verificable)
Cache	Amazon ElastiCache for Redis
Mensajería (eventos)	Amazon MSK (Kafka managed)
Mensajería (colas)	Amazon SQS
Notificaciones	Amazon SNS (push + SMS) + Amazon SES (email) + proveedor WhatsApp BSP
Object storage	Amazon S3
Secretos	AWS Secrets Manager + AWS KMS
Observabilidad	Amazon CloudWatch + AWS X-Ray
CI/CD	AWS CodePipeline + CodeBuild + CodeDeploy

4.3.4 Pros

- **Time-to-market acelerado**: pocos componentes requieren decisiones de infraestructura; AWS los opera.
- **SLAs publicados y robustos** por servicio (Aurora 99.99%, DynamoDB 99.999%, Lambda 99.95%).
- **Zero-ops** para la mayoría de componentes: sin patching de BD, sin tuning de brokers, sin administración de clusters.
- **Seguridad integrada**: IAM granular, KMS, Secrets Manager, WAF, GuardDuty, Macie, CloudTrail integrados nativamente.
- **Soporte de nivel enterprise** disponible 24/7 con AWS Business/Enterprise Support.

4.3.5 Contras

- **Vendor lock-in alto**: Lambda, DynamoDB, QLDB, Cognito, Rekognition son servicios propietarios. Migrar a otro proveedor requiere reescritura significativa.
- **Costos no predecibles a escala**: egress fees, CloudWatch Logs ingestion y DynamoDB on-demand pueden explotar el presupuesto.
- **Menor control sobre rendimiento fino**: Lambda tiene cold starts; Fargate tiene latencia de arranque; no se puede tunear JVM internamente de un servicio Lambda.
- **Mercado de talento especializado más pequeño** en LATAM que el de Java/Spring.
- **Riesgo regulatorio futuro**: si la Superintendencia de Bancos exige multi-cloud o on-prem en el futuro, el costo de migración es muy alto.

4.3.6 Costo mensual estimado (escenario 500k–1M MAU, 99.95%)

Rubro	USD/mes
Infraestructura AWS (compute, storage, red, servicios managed)	14.000 – 18.000
Licencias de terceros (Veridas opcional, WhatsApp BSP, SAST/SCA, PagerDuty)	2.500 – 3.500
Personal (equipo típico ~14 personas)	55.000 – 65.000
Imprevistos (10%)	7.200 – 8.600
Total	**~78.700 – 95.100**

4.3.7 Tiempo estimado hasta producción piloto (MVP)

- **Optimista**: ~5 meses
- **Normal (PERT)**: ~10 meses
- **Pesimista**: ~15 meses

4.3.8 Complejidad operativa

Baja a media. AWS opera los componentes; el equipo opera principalmente aplicación, IaC (Terraform/CDK) y pipelines.

4.3.9 Scoring ISO/IEC 25010 — Alternativa A

Característica	Score	Justificación
Idoneidad funcional	5	Todos los building blocks existen como servicio managed; cero gap funcional.
Eficiencia de desempeño	4	Lambda tiene cold starts; Fargate tarda en escalar; managed services son eficientes pero poco tuneables.
Compatibilidad	4	Fuerte dentro de AWS; integración con core bancario on-prem requiere Direct Connect / VPN.
Usabilidad operativa	5	Dashboards AWS listos, logs en CloudWatch, consola unificada.
Fiabilidad	5	SLAs AWS publicados y probados; Multi-AZ automático en la mayoría de servicios.
Seguridad	5	IAM, KMS, WAF, GuardDuty, Macie, CloudTrail integrados; Cognito maduro.
Mantenibilidad	4	Microservicios Lambda desacoplados; pero cambios de infra implican IaC extenso.
Portabilidad	1	Lock-in muy alto; migrar fuera de AWS requiere reescritura.
Total (sobre 40)	**33**	

4.4 Alternativa B — Híbrida cloud-portable (Kubernetes + Spring Cloud)

4.4.1 Descripción

Arquitectura apoyada en Kubernetes administrado (Amazon EKS) como denominador común portable. Microservicios en **Spring Boot 3 sobre Java 21**. Componentes de infraestructura (service discovery, mensajería, object storage, autenticación) son open-source desplegados en el cluster o servicios externos tercerizables. AWS se usa como proveedor cloud base, pero los componentes son portables a Azure (AKS), GCP (GKE) u on-prem (K8s puro) sin reescribir código de negocio.

4.4.2 Diagrama C4 — Nivel 1: Contexto (Alternativa B)

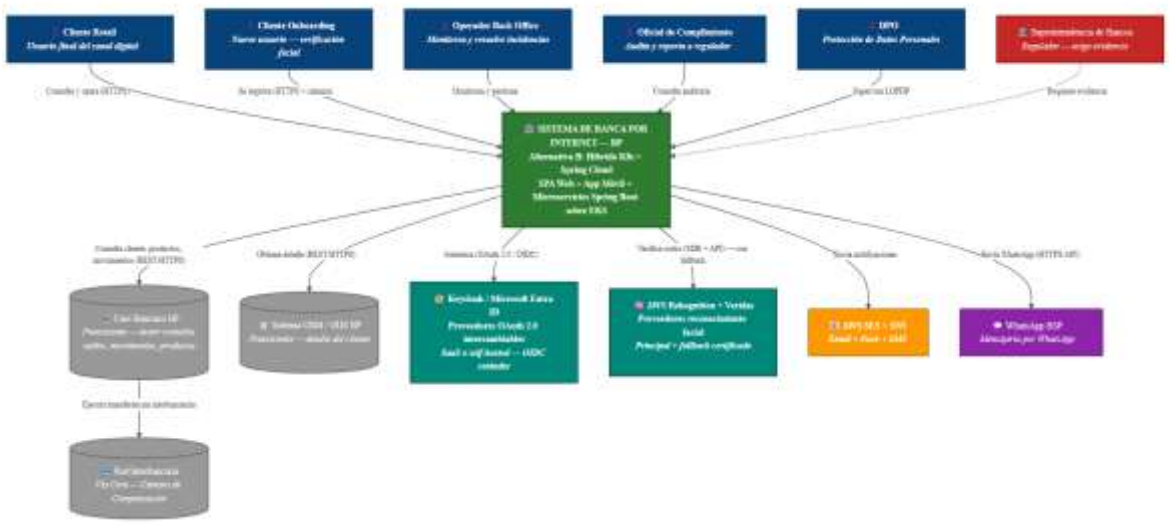


Diagrama C4 Nivel 1 — Contexto — Alternativa B (Híbrida K8s + Spring Cloud)

Nota sobre el diagrama: a diferencia de la Alternativa A, los proveedores de identidad y de reconocimiento facial se representan como **sistemas externos tercerizables e intercambiables** (color teal). Keycloak o Microsoft Entra ID se consumen vía OIDC estándar; AWS Rekognition o Veridas se consumen vía abstracción Strategy. Esta representación en el Contexto hace visible desde el nivel más alto de la arquitectura el principio de desacoplamiento del proveedor, que es uno de los motivos principales de selección de esta alternativa.

4.4.3 Componentes principales

Función	Componente
Edge / CDN / WAF	CloudFront + AWS WAF + AWS Shield (capa perimetral AWS)
API Gateway perimetral	AWS API Gateway (externo)
API Gateway interno	Spring Cloud Gateway (intra-cluster)

Función	Componente
Service discovery	Kubernetes-native (CoreDNS + Services + Spring Cloud LoadBalancer)
Identidad / OAuth 2.0	**Keycloak** (self-hosted en K8s) o **Microsoft Entra ID** (SaaS) — intercambiables vía OIDC
Compute aplicaciones	Amazon EKS (Kubernetes administrado) + Spring Boot 3 / Java 21
Reconocimiento facial	AWS Rekognition + Face Liveness (con Veridas como fallback certificado para banca)
Base de datos transaccional	PostgreSQL (Amazon RDS Aurora Multi-AZ, accedida como RDS estándar → portable)
Base de datos de detalle cliente	MongoDB (Amazon DocumentDB o MongoDB Atlas)
Auditoría inmutable	Event Sourcing con Kafka + Aurora append-only con hash-chain HMAC + TSA + anchor S3 Object Lock + espejo a OpenSearch
Cache	Redis en K8s (operador Bitnami) o Amazon ElastiCache
Mensajería transaccional	RabbitMQ (self-hosted en K8s)
Event streaming	Kafka (Amazon MSK o self-hosted)
Notificaciones	Amazon SES + Amazon SNS + WhatsApp BSP; abstraídos tras un servicio propio portable
Object storage	MinIO en K8s (S3-compatible) + Amazon S3 para archive
Admin de BD	Adminer (acceso interno vía bastion)
Secretos	HashiCorp Vault + AWS Secrets Manager (jerárquico)
Observabilidad	Prometheus + Grafana + ELK (Elasticsearch, Logstash, Kibana) + Jaeger
CI/CD	Jenkins (declarative pipelines) + ArgoCD (GitOps)

4.4.4 Pros

- **Portabilidad real**: todo el código de negocio corre en Kubernetes estándar; migrable a Azure AKS, GCP GKE u on-prem.
- **Control fino de rendimiento**: tuning JVM, pod resources, HPA con custom metrics, Kafka con configuración específica banca.
- **Ecosistema Java/Spring**: librerías maduras para banca (Spring Security, Spring Data JDBC con reactive, soporte transaccional robusto).
- **Talento LATAM abundante**: Java/Spring es ampliamente conocido en Ecuador, Colombia, Perú, México.
- **Flexibilidad de identidad**: Keycloak o Entra ID como proveedores intercambiables.

- **Alineamiento con tendencia bancaria regional**: muchos bancos LATAM operan K8s + Spring.

4.4.5 Contras

- **Mayor complejidad operativa**: el equipo debe operar EKS, Kafka, RabbitMQ, Keycloak, Vault, MinIO. Requiere expertise SRE.
- **Piso de equipo más alto**: 2 DevOps/SRE mínimos para operación 24/7.
- **Responsabilidad sobre parches y vulnerabilidades**: el equipo debe seguir CVEs, aplicar upgrades, hacer DR drills.
- **Mayor curva de aprendizaje inicial**: Kubernetes, GitOps, observabilidad.

4.4.6 Costo mensual estimado (escenario 500k–1M MAU, 99.95%)

Rubro	USD/mes
Infraestructura AWS (EKS, EC2 nodos, RDS, MSK opcional, S3, red)	8.000 – 11.000
Licencias de terceros (Veridas opcional, WhatsApp BSP, SonarQube, Snyk, PagerDuty)	2.500 – 3.500
Personal (equipo típico ~16 personas, incluye 2 DevOps/SRE)	65.000 – 75.000
Imprevistos (10%)	7.550 – 8.950
Total	**~83.050 – 98.450**

4.4.7 Tiempo estimado hasta producción piloto (MVP)

- **Optimista**: ~6 meses
- **Normal (PERT)**: ~11 meses
- **Pesimista**: ~16 meses

4.4.8 Complejidad operativa

Media a alta. Requiere equipo con expertise K8s + Java. Mayor flexibilidad, mayor responsabilidad.

4.4.9 Scoring ISO/IEC 25010 — Alternativa B

Característica	Score	Justificación
Idoneidad funcional	5	Cubre todos los requisitos con componentes open-source maduros.
Eficiencia de desempeño	5	Tuning fino de JVM, pods, HPA custom; Kafka y RabbitMQ ajustables a la carga banca.
Compatibilidad	5	Stack estándar (REST, gRPC, Kafka, OIDC) — interopera con cualquier core bancario legacy.
Usabilidad operativa	3	Mayor complejidad operativa; curva K8s; requiere expertise.

Característica	Score	Justificación
Fiabilidad	4	Depende de que el equipo opere bien HA de Kafka, RabbitMQ, Keycloak. Posible pero exige disciplina.
Seguridad	4	Vault + Keycloak + mTLS son robustos pero self-hosted = responsabilidad del equipo.
Mantenibilidad	5	Microservicios Spring Boot con contratos claros; GitOps; talento disponible.
Portabilidad	5	Todo corre en K8s estándar; migrable a cualquier proveedor.
Total (sobre 40)	**36**	

4.5 Alternativa C — Serverless-first (AWS nativo)

4.5.1 Descripción

Arquitectura 100% event-driven apoyada en AWS Lambda + Step Functions para orquestación + DynamoDB Global Tables para persistencia + EventBridge para eventos. Sin servidores que administrar; costo variable puro (pay-per-use); escalabilidad automática infinita. Vendor lock-in extremo.

4.5.2 Diagrama C4 — Nivel 1: Contexto (Alternativa C)

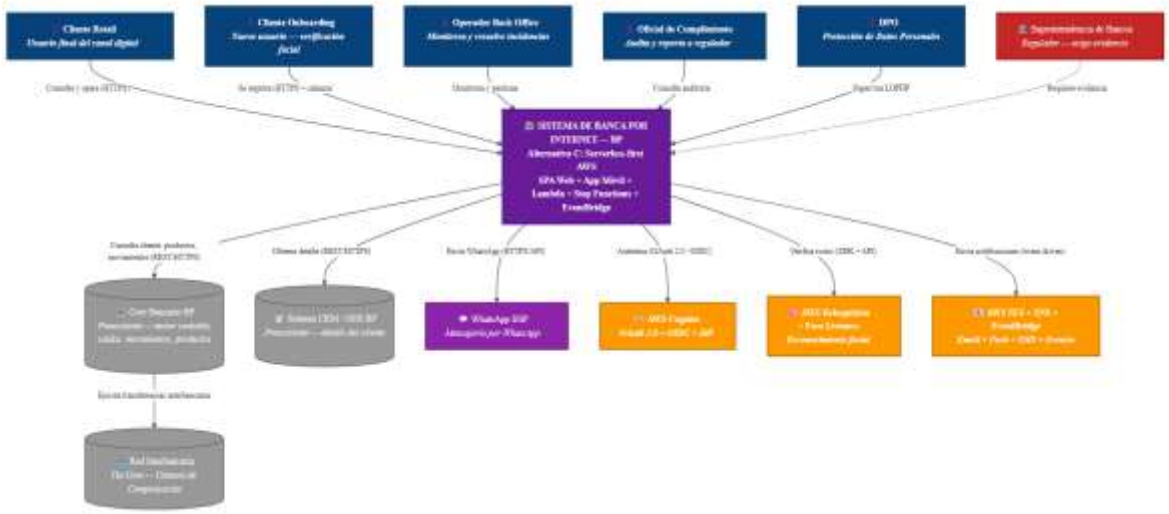


Diagrama C4 Nivel 1 — Contexto — Alternativa C (Serverless-first AWS)

Nota sobre el diagrama: estructuralmente a nivel de Contexto, la Alternativa C es similar a la Alternativa A (mismos sistemas externos preexistentes de BP, mismos servicios cognitivos AWS). La diferencia significativa se manifiesta en el Nivel 2 (Contenedores), donde el "Sistema" interno pasa de contener aplicaciones Fargate + Lambda a estar compuesto únicamente por Lambda functions orquestadas por Step Functions sobre bases de datos serverless (DynamoDB Global Tables, Aurora Serverless v2).

4.5.3 Componentes principales

Función	Servicio AWS
Edge / CDN / WAF	CloudFront + AWS WAF
API Gateway	Amazon API Gateway REST
Identidad / OAuth 2.0	Amazon Cognito
Compute	AWS Lambda (todas las funciones) + AWS Step Functions (orquestación de flujos complejos)
Reconocimiento facial	Amazon Rekognition + Face Liveness
Base de datos transaccional	Amazon DynamoDB Global Tables (multi-región activa-activa)
Base de datos relacional (solo donde sea indispensable)	Amazon Aurora Serverless v2
Auditoría inmutable	Amazon QLDB
Cache	Amazon DynamoDB Accelerator (DAX)
Eventos	Amazon EventBridge + SNS + SQS
Notificaciones	Amazon SNS + Amazon SES + WhatsApp BSP
Object storage	Amazon S3
Observabilidad	CloudWatch + X-Ray
CI/CD	AWS SAM / Serverless Framework + CodePipeline

4.5.4 Pros

- **Costo variable puro**: no se paga infraestructura ociosa. Ideal en escenarios con tráfico muy irregular.
- **Escalabilidad automática infinita**: Lambda escala a miles de invocaciones concurrentes sin intervención.
- **Zero-ops absoluto**: nada que parchear, nada que escalar manualmente.
- **Despliegues muy rápidos**: push de código → función en producción en segundos.
- **Alineamiento con tendencias**: cloud-native puro.

4.5.5 Contras

- **Cold starts**: la primera invocación de una Lambda inactiva puede añadir 300ms-2s de latencia — crítico para RNF-02 (latencia < 2s en operaciones de consulta).
- **Max duration de Lambda 15 minutos**: imposibilita procesos largos sin orquestación adicional (Step Functions).
- **Complejidad de debugging distribuido**: cada request puede atravesar 10+ funciones; tracing es imprescindible.
- **Transacciones ACID complejas**: DynamoDB soporta transacciones pero con límites; patrones Saga obligatorios para operaciones multi-tabla.

- **Vendor lock-in extremo**: cada función es código AWS-específico; migrar fuera de AWS implica reescribir todo.
- **Costos impredecibles a escala**: en escenarios de alto tráfico constante (como el pico de nómina), serverless puede ser más caro que compute reservado.
- **Observabilidad desafiante**: CloudWatch Logs de miles de funciones requiere strategy de agregación.

4.5.6 Costo mensual estimado (escenario 500k–1M MAU, 99.95%)

Rubro	USD/mes
Infraestructura AWS (Lambda invocations, DynamoDB RCU/WCU, Step Functions, EventBridge, API GW requests)	10.000 – 16.000 (variable)
Licencias de terceros	2.500 – 3.500
Personal (equipo típico ~12 personas, menos DevOps dedicado)	50.000 – 58.000
Imprevistos (10%)	6.250 – 7.750
Total	**~68.750 – 85.250**

4.5.7 Tiempo estimado hasta producción piloto (MVP)

- **Optimista**: ~4 meses
- **Normal (PERT)**: ~9 meses
- **Pesimista**: ~14 meses

4.5.8 Complejidad operativa

Baja en operación / **alta** en diseño. Operar no cuesta; diseñar event-driven consistente sí.

4.5.9 Scoring ISO/IEC 25010 — Alternativa C

Característica	Score	Justificación
Idoneidad funcional	4	Cubre la mayoría; pero algunas transacciones banca complejas requieren patrones Saga elaborados que suman riesgo.
Eficiencia de desempeño	3	Cold starts afectan latencia p95; max 15 min por Lambda limita batch.
Compatibilidad	4	Buena con AWS; requiere Direct Connect para core bancario on-prem.
Usabilidad operativa	5	Zero-ops: dashboards automáticos, nada que mantener.
Fiabilidad	4	SLAs AWS robustos; pero complejidad distribuida sube el blast radius de errores de diseño.
Seguridad	5	Superficie reducida; todo AWS managed con IAM granular.
Mantenibilidad	3	Debugging distribuido complejo; muchas funciones pequeñas = sprawl si no hay disciplina.

Característica	Score	Justificación
Portabilidad	1	Lock-in extremo; cada función es AWS-específica.
Total (sobre 40)	**29**	

4.6 Matriz comparativa consolidada

4.6.1 Scoring ISO/IEC 25010 (lado a lado)

Característica	Alt. A (Cloud-native)	Alt. B (Híbrida K8s)	Alt. C (Serverless)
Idoneidad funcional	5	5	4
Eficiencia de desempeño	4	5	3
Compatibilidad	4	5	4
Usabilidad operativa	5	3	5
Fiabilidad	5	4	4
Seguridad	5	4	5
Mantenibilidad	4	5	3
Portabilidad	1	5	1
Total (sobre 40)	**33**	**36**	**29**

4.6.2 Comparativa de costos y tiempos

Criterio	Alt. A	Alt. B	Alt. C
Costo mensual estimado	~78.7k – 95.1k USD	~83k – 98.4k USD	~68.7k – 85.2k USD
Costo infraestructura cloud (% del total)	~18%	~11%	~16%
Costo personal (% del total)	~69%	~77%	~73%
Tiempo a MVP (normal PERT)	10 meses	11 meses	9 meses
Vendor lock-in	Alto	Bajo	Extremo
Complejidad operativa	Baja-Media	Media-Alta	Baja
Talento disponible LATAM	Medio	Alto	Bajo-Medio

4.6.3 Comparativa cualitativa

Criterio	Alt. A	Alt. B	Alt. C
Control sobre rendimiento	Medio	Alto	Bajo
Response a nuevas normativas (ej: multi-cloud	Difícil	Fácil	Imposible sin reescribir

Criterio	Alt. A	Alt. B	Alt. C
obligatorio)			
Costos a escala alta (3M+ MAU)	Riesgo alto (egress + CloudWatch)	Controlado	Riesgo medio (DynamoDB + Lambda invocations)
Observabilidad profunda	Media (CloudWatch + X-Ray)	Alta (Prometheus + Grafana + Jaeger)	Media-Baja (desafío distribuido)
Adecuación a transacciones bancarias ACID complejas	Alta	Muy alta	Media (requiere Saga)

4.7 Decisión: alternativa seleccionada

Aplicando los criterios ISO/IEC 25010 definidos en 3.1, los supuestos del Capítulo 1 (carga 500k–1M MAU, SLA 99.95%, talento Java abundante en LATAM, exigencias regulatorias ecuatorianas) y los resultados cuantitativos (Alt. B: 36/40 — Alt. A: 33/40 — Alt. C: 29/40), **la alternativa seleccionada para esta solución es:**

> **Alternativa B — Híbrida cloud-portable (Kubernetes + Spring Cloud)**, con incorporación estratégica de componentes propietarios de AWS en los puntos donde aportan valor sin comprometer la portabilidad del núcleo (reconocimiento facial con Rekognition + Liveness, auditoría inmutable con Aurora append-only + hash-chain HMAC + TSA, capa perimetral con WAF y Shield, notificaciones con SES y SNS).

4.7.1 Motivos principales de la selección

1. Portabilidad arquitectónica como activo estratégico en banca regulada. La portabilidad obtiene el score máximo (5) en la Alternativa B y el mínimo (1) en las otras dos. En banca regulada la posibilidad de migrar entre proveedores sin reescribir código no es una comodidad técnica: es una respuesta frente a cambios normativos de la Superintendencia de Bancos, cambios en las condiciones comerciales del proveedor cloud, o incidentes regionales prolongados. Kubernetes como denominador común estándar permite esta portabilidad; Lambda o DynamoDB no.

2. Compatibilidad con core bancario legacy y protocolos estándar. La Alternativa B obtiene score 5 en compatibilidad frente a 4 en las otras. El stack Spring Cloud + REST + Kafka + OIDC es el **estándar de la industria bancaria LATAM** para integrar con cores bancarios tradicionales (Finacle, Cobis, Temenos, FIS). Los cores bancarios ecuatorianos privilegian este stack por madurez de bibliotecas transaccionales ACID y adopción regulatoria.

3. Disponibilidad de talento Java/Spring en el mercado LATAM. La Alternativa B obtiene score 5 en mantenibilidad —el más alto de las tres—, soportado por la abundancia de

ingenieros Java/Spring en Ecuador y la región. Esto se traduce en menor tiempo de hiring, menor rotación, menor costo salarial unitario y menor riesgo de bus-factor. Las Alternativas A y C requieren talento especializado en servicios AWS propietarios, significativamente más escaso.

4. Robustez transaccional y control fino sobre el rendimiento. En operaciones bancarias críticas (transferencias, actualización de saldos, auditoría encadenada), el control explícito sobre transacciones ACID, el tuning de la JVM, de los pools de conexión y de la configuración de Kafka/RabbitMQ es un diferencial. La Alternativa B obtiene score 5 en eficiencia de desempeño gracias a este control; las otras ceden ese control al proveedor.

4.7.2 Reconocimiento de los trade-offs asumidos

La decisión no es gratuita. Las Alternativas A y C ganan en **usabilidad operativa** (5 vs 3) porque delegan la operación al proveedor. La Alternativa B exige un equipo SRE con expertise en Kubernetes como parte del plan de personal (2 DevOps/SRE senior mínimos) y disciplina operativa sostenida (GitOps con ArgoCD, observabilidad fuerte, DR drills trimestrales, runbooks versionados). Estas mitigaciones se incorporan explícitamente al plan de ejecución del Capítulo 9.

Las decisiones arquitectónicas específicas derivadas de esta selección (framework móvil, framework SPA, flujo OAuth, patrón de cache, patrón de auditoría, etc.) se desarrollan en el Capítulo 4 con sus respectivas alternativas evaluadas y justificaciones teóricas.

---

5 Decisiones arquitectónicas clave

5.1 Propósito y método del capítulo

En este capítulo se desarrollan las decisiones arquitectónicas específicas derivadas de la alternativa seleccionada en el capítulo anterior (Híbrida cloud-portable: Kubernetes + Spring Cloud). Cada decisión se documenta como un **Architecture Decision Record (ADR)**, con la siguiente estructura:

- **Contexto**: qué problema específico se resuelve y por qué importa.
- **Opciones evaluadas**: alternativas realistas con sus trade-offs explícitos (mínimo dos por decisión).
- **Decisión**: la opción seleccionada.
- **Justificaciones teóricas**: fundamento conceptual, con referencia a estándares, patrones o literatura (mínimo dos por decisión).
- **Consecuencias y mitigaciones**: trade-offs aceptados y cómo se mitigan sus desventajas.

5.1.1 Mapa de ADRs del capítulo

Las decisiones se agrupan en cuatro familias temáticas para facilitar la lectura:

Familia	ADRs incluidas
Backend, comunicación y mensajería	ADR-01 Microservicios, ADR-02 API Gateway + Service Discovery, ADR-10 Mensajería
Frontend	ADR-03 SPA web, ADR-04 Móvil multiplataforma
Identidad, autenticación y onboarding	ADR-05 Proveedor OAuth, ADR-06 Flujo OAuth, ADR-07 Autenticación escalonada, ADR-08 Reconocimiento facial
Datos, auditoría y almacenamiento	ADR-09 Cache, ADR-11 Auditoría inmutable, ADR-12 Object storage y secretos

---

5.2 ADR-01 — Arquitectura de microservicios: Spring Boot 3 + Java 21 con DDD y Hexagonal Architecture

Contexto: el sistema debe implementarse como un conjunto de componentes desacoplados, con fronteras claras entre dominios de negocio, capacidad de evolucionar de forma independiente y soporte de transacciones ACID robusto propio del dominio bancario. El backend debe correr sobre Kubernetes (Alternativa B) y comunicarse con sistemas preexistentes (core bancario, CRM/ODS, proveedor de identidad externo).

5.2.1 ¿Por qué microservicios y no un monolito modular?

Una crítica legítima a priori es: “para 500k–1M MAU (~500 TPS pico) un monolito modular bien diseñado alcanza; introducir microservicios es *microservice premium*”. Esta observación se evalúa explícitamente.

Argumentos a favor del monolito modular en este escenario:

- Volumen transaccional compatible con un monolito Spring Boot bien dimensionado.
- Menor complejidad operativa (un solo deploy, una sola BD, menos piezas que observar).
- Menos latencia (sin network hops internos).
- Equipo más pequeño puede operarlo con menor costo de SRE.

Argumentos a favor de microservicios (que pesan más en este caso):

- **Múltiples squads trabajando en paralelo**: el plan del Cap 9 contempla 6 squads cross-funcionales. Un monolito con 6 equipos pisándose en el mismo repo genera cuellos de botella en merges, releases coordinados y responsabilidades difusas.

- **Autonomía de despliegue por dominio**: el equipo de notificaciones debe poder lanzar sin coordinarse con el equipo de transferencias. En banca, el riesgo de un deploy monolítico para cambiar un template de email es desproporcionado.
- **Aislamiento de fallas**: un bug en el motor de notificaciones no puede tirar el servicio de transferencias. Blast radius acotado.
- **Escalado granular**: el `transfer-service` necesita escalar en el pico de fin de mes; el `onboarding-service` tiene un perfil de uso totalmente distinto. Monolito escala todo junto.
- **Cumplimiento y segregación de responsabilidades (PCI-DSS, LOPDP)**: el microservicio que toca PAN se mantiene en su propio scope, limitando el perímetro PCI. En monolito, todo el código cae en scope.
- **Alineación con el patrón de servicios BIAN** (ver Cap 2 sec. 2.4.1): facilita el mapeo a dominios de servicio estándar de la industria bancaria y la eventual exposición de APIs reguladas (Open Banking).

Trade-off asumido: se acepta la mayor complejidad operativa a cambio de autonomía de equipos, aislamiento de fallas y alineación con la industria bancaria. Las mitigaciones de esa complejidad están al final de esta ADR y en el Cap 7 (HA/DR/Observabilidad).

Evento storming recomendado en Sprint 1: antes de congelar el diseño de los 8 bounded contexts propuestos, el Cap 9 contempla una sesión de event storming con stakeholders de BP para validar o refinar las fronteras. Es la única forma honesta de descartar el riesgo de "partición técnica disfrazada de DDD".

Opciones evaluadas (lenguaje/framework del microservicio):

Opción	Pros	Contras
Microservicios en Spring Boot 3 + Java 21	Ecosistema maduro para banca; Spring Data con soporte transaccional; Spring Security robusto; talento LATAM abundante; soporte enterprise disponible (Broadcom/VMware)	Footprint JVM; tiempo de arranque mayor que lenguajes compilados nativos
Microservicios en Node.js (NestJS)	Rápido para APIs ligeras; mismo lenguaje que SPA	Transacciones ACID complejas exigen más código; menos tradición bancaria LATAM
Microservicios en Go	Compilación a binario; bajo footprint; concurrencia elegante	Librerías específicas banca más limitadas; talento más escaso LATAM
Microservicios en	Arranque <100ms; memoria 10x menor que Spring Boot JVM	Ecosistema más pequeño; menor

Opción	Pros	Contras
Quarkus (Java native AOT)		adopción enterprise bancaria
Microservicios en .NET 8	Rendimiento alto; buen tooling	Mejor en Windows/Azure; en EKS es viable pero menos natural

Decisión: **Microservicios en Spring Boot 3 sobre Java 21 (LTS)**, con los siguientes principios de diseño internos y mitigaciones operativas obligatorias:

Principios de diseño:

- **Domain-Driven Design (DDD)** — bounded contexts por microservicio; lenguaje ubicuo documentado en cada repo; event storming validado con negocio.
- **Hexagonal Architecture (Ports & Adapters, Alistair Cockburn)** — separación estricta dominio ↔ infraestructura.
- **Clean Architecture (Robert C. Martin)** — regla de dependencia: capas externas dependen de las internas.
- **The Twelve-Factor App** — configuración por entorno, logs estructurados a stdout, procesos stateless, build/release/run separados.

Mitigaciones operativas obligatorias (hallazgos del debate adversarial):

1. **Transactional Outbox obligatorio** en todos los microservicios que publican eventos de dominio (patrón de ADR-11). No se permite "dual write" directo a Kafka desde código de aplicación.
2. **Resilience4j obligatorio** en todos los clientes inter-servicio: Circuit Breaker + Bulkhead (pool de threads aislado por integración) + Timeout + Retry con backoff exponencial y jitter.
3. **mTLS intra-cluster** vía cert-manager + Spring Cloud o service mesh ligero (linkerd). No se permite tráfico plano entre pods.
4. **Consumer-driven contracts (Pact o Spring Cloud Contract)** declarados en el pipeline CI — PRs que rompen contratos aguas abajo son rechazados automáticamente.
5. **Compatibilidad N-1 de contratos** obligatoria: todo cambio de contrato debe mantener compatibilidad con la versión anterior durante al menos un sprint para habilitar deploys independientes.
6. **BD por bounded context (schema o cluster)** — no se permite acceso cross-service a la misma tabla; las FK cross-service están prohibidas. Comunicación solo por contrato API o evento.

7. **Budget de latencia explícito por servicio** contra el RNF-02 (p95 < 2 s): cada microservicio declara su p95 máximo permitido; el presupuesto total se enforce en SLOs.
8. **Distributed tracing con OpenTelemetry + correlation-id propagado**: obligatorio para demostrar trazabilidad end-to-end al auditor de la Superintendencia de Bancos.
9. **GraalVM native image**: se contempla para los microservicios de borde (notification, authz) a partir del Incremento 3 del Cap 9 para reducir cold starts en autoescalado; para los servicios transaccionales se mantiene JVM tradicional por madurez del tooling.

Justificaciones teóricas:

1. **Madurez del ecosistema para dominio bancario**. Spring Framework es la base tecnológica de la banca digital a escala en LATAM durante más de una década. Spring Data, Spring Security, Spring Transaction y los binders para Kafka/RabbitMQ cubren patrones bancarios (ACID, idempotencia, retries, timeouts, circuit breakers) sin reinventar código.
2. **Tipado estricto y verificación en tiempo de compilación**. Java permite capturar al compilar clases enteras de errores (null pointers, type mismatches, casts incorrectos) que en lenguajes dinámicos emergen en runtime — costo inaceptable en banca (Hoare, "Null references, the billion dollar mistake", 2009).
3. **DDD como lenguaje común con el negocio**. En banca los términos tienen significados precisos; modelar según bounded contexts con lenguaje ubicuo reduce la brecha negocio-ingeniería (Evans, *Domain-Driven Design*, 2003).
4. **Hexagonal + Clean como seguro ante cambios de infraestructura**. Si se cambia el broker de mensajería, el proveedor de identidad o la base de datos, el cambio se contiene en los adaptadores; el dominio permanece intacto.

Consecuencias y mitigaciones:

- *Footprint JVM mayor* → tuning ZGC/G1 + containers con requests/limits bien definidos + GraalVM native para servicios de borde desde Incremento 3.
- *Tiempos de arranque mayores que Node/Go* → readiness probes adecuados + pool de pods warm + imágenes nativas en servicios donde importa.
- *Complejidad operativa de 8 servicios* → mitigada con GitOps (ArgoCD), observabilidad fuerte (ver Cap 7), runbooks versionados y equipo SRE dedicado (2 FTE en el Cap 9).
- *Latencia acumulativa entre hops* → mitigada con budget por servicio + topology-aware routing (misma AZ priorizada) + cache en el BFF cuando aplica.

5.3 ADR-02 — API Gateway + Service Discovery: AWS API Gateway (perimetral) + Spring Cloud Gateway (interno) + Kubernetes-native discovery

Contexto: el sistema debe exponer sus APIs al exterior con controles de seguridad perimetral (WAF, rate limiting, DDoS mitigation) y simultáneamente permitir el enrutamiento interno entre microservicios con descubrimiento dinámico (los pods aparecen y desaparecen con autoescalado).

Decisión sobre API Gateway — dos capas:

Opciones evaluadas:

Opción	Pros	Contras
AWS API Gateway (único)	Managed; WAF integrado	Lock-in alto; menos flexible en enrutamiento interno
Spring Cloud Gateway (único)	Nativo en el ecosistema; filtros potentes; reactive	Sin WAF perimetral integrado
Kong Gateway (único)	Enterprise-grade; plugins maduros	Costo de licencia Enterprise
Istio Service Mesh (como gateway)	mTLS, observabilidad, policies	Complejidad operativa alta; sidecar overhead
AWS API Gateway (perimetral) + Spring Cloud Gateway (interno)	Defense in depth; separation of concerns; WAF edge + lógica banca interna	Dos capas a operar

Decisión: **AWS API Gateway + WAF + Shield como capa perimetral (edge) + Spring Cloud Gateway como gateway interno** dentro del cluster EKS.

Decisión sobre Service Discovery — reemplazo de Eureka:

> **Nota sobre Eureka**: en la primera iteración se contempló Netflix Eureka. **Eureka está en modo de mantenimiento desde 2018**; Netflix lo reemplazó internamente y la comunidad tiende a usar alternativas nativas de Kubernetes. Elegir Eureka en 2026 introduce un componente legacy que duplica funcionalidad ya provista por Kubernetes. Por estas razones se descartó.

Opciones evaluadas para service discovery:

Opción	Pros	Contras
~~Netflix Eureka~~	Integración con Spring Cloud LoadBalancer	**En mantenimiento desde 2018; duplica funcionalidad K8s**
Kubernetes-	Built-in, sin componente	Load balancing round-robin básico (se

Opción	Pros	Contras
native (CoreDNS + Services)	adicional; probado a escala masiva; DNS estándar	compensa con Spring Cloud LoadBalancer sobre resolución DNS)
Consul (HashiCorp)	Multi-DC, health checks avanzados	Componente adicional a operar; complejidad extra
Istio service mesh	Discovery + mTLS + observabilidad + traffic management	Overhead operativo y de performance alto para el beneficio

Decisión: **Kubernetes-native service discovery** mediante **CoreDNS + Services (ClusterIP y Headless)**, complementado con **Spring Cloud LoadBalancer** sobre resolución DNS para client-side load balancing inteligente (weighted routing, canary routing, zone-aware routing).

Justificaciones teóricas:

1. **Defense in Depth (NIST SP 800-53 — SC-7)**. Separar seguridad perimetral de lógica de enrutamiento interno reduce el blast radius: WAF filtra en el edge; un atacante que lo supere encuentra una segunda barrera de validación de tokens y políticas en el gateway interno.
2. **Separación de concerns**. La capa perimetral se enfoca en amenazas externas (OWASP Top 10, bots, DDoS); la capa interna en concerns funcionales (routing, rate limiting por cliente, header enrichment, correlation-id injection).
3. **Reactive stack**. Spring Cloud Gateway es reactive (Project Reactor): maneja miles de conexiones concurrentes con pocos threads, adecuado para picos de carga transaccional en banca.
4. **Service discovery nativo de la plataforma**. Usar CoreDNS + Services elimina un SPOF adicional (Eureka cluster) y aprovecha la infraestructura que ya existe por defecto en EKS. Reduce piezas a operar y actualizar.
5. **Spring Cloud LoadBalancer**. Mantiene la capacidad de client-side load balancing que Eureka proveía, pero resolviendo via DNS estándar — sin componente adicional. Soporta zone-aware routing (prioriza instancias en la misma AZ) para reducir latencia y egress cross-AZ.

Consecuencias y mitigaciones:

- *Dos capas de gateway a operar* → responsabilidades claras documentadas (RACI operativa); configuraciones como código (Terraform para AWS API GW, Helm charts para Spring Cloud Gateway).
- *DNS caching puede introducir pequeña demora en descubrir nuevos pods* → mitigado con TTL bajo en CoreDNS + refresh agresivo en Spring Cloud LoadBalancer.
- *Health checks pasivos vs Eureka activos* → mitigado con Readiness Probes + liveness probes en K8s, más robustos que los de Eureka.

5.4 ADR-03 — Framework SPA web: Angular 17+ con monorepo Nx

Contexto: la aplicación web debe interactuar con el mismo backend que la aplicación móvil, proveer dashboards, transferencias y consulta de movimientos para clientes retail, oficiales de cumplimiento y back office. Debe cumplir WCAG 2.2 AA (RNF-13), soportar tipado estricto end-to-end y escalar con múltiples squads frontend trabajando en paralelo.

Opciones evaluadas:

Framework	Pros	Contras
Angular 17+	Framework completo (routing, forms, DI, HTTP, i18n, test); TypeScript-first; opinionado = consistencia a escala; RxJS integrado para streams; estándar en banca internacional	Curva de aprendizaje mayor; más verboso; bundle size inicial mayor
React 18+	Flexibilidad y ecosistema; menor bundle base; server components	Requiere armar el stack (routing, state, forms) con decisiones del equipo; opiniones divergentes en proyectos grandes generan fragmentación
Vue 3	Buen balance simplicidad/potencia; curva de aprendizaje suave	Menor adopción en banca LATAM; ecosistema enterprise más pequeño

Decisión: **Angular 17+ con monorepo Nx** para orquestar la SPA web y librerías compartidas (design system, cliente OpenAPI generado, utilidades de auth, i18n).

Justificaciones teóricas:

1. **Convention over Configuration (Rails Doctrine, Hansson)**. En un proyecto bancario con múltiples squads frontend, un framework opinionado reduce el espacio de divergencias arquitectónicas y acelera el onboarding de nuevos ingenieros. React permite soluciones muy variadas al mismo problema; en un equipo de 4+ personas esto genera fragmentación y deuda técnica.
2. **Tipado fuerte end-to-end**. Angular es TypeScript-first. Los contratos con el backend Spring Boot pueden generarse desde OpenAPI y consumirse con tipos estrictos, eliminando clases enteras de bugs antes de ejecutar (Hoare, “Null references, the billion dollar mistake”, 2009).
3. **Reactividad como ciudadano de primera clase (ReactiveX, Erik Meijer)**. RxJS está integrado al framework; para una aplicación que muestra movimientos en tiempo real, notificaciones push y streams de eventos del backend, el modelo reactivo escala mejor que la composición manual de hooks + librerías de estado.

4. **Adopción en banca internacional**. Angular es el estándar de facto de banca digital (Santander, BBVA, ING, entre otros). Reduce riesgo de hiring, facilita la transferencia de conocimiento y permite reutilizar patrones probados.

Consecuencias y mitigaciones:

- *Bundle inicial mayor* → mitigado con lazy loading por módulo, preloading estratégico (quicklink), Angular SSR donde aporte y optimización con Angular esbuild.
- *Curva de aprendizaje* → mitigado con pair programming entre senior y mid, formación interna y adopción incremental de features avanzadas (signals, standalone components, control flow nuevo).

5.5 ADR-04 — Framework móvil multiplataforma: Flutter

Contexto: la aplicación móvil debe correr en iOS y Android con experiencia equivalente, soportar captura de video para onboarding con reconocimiento facial, acceder a biometría local (huella/FaceID), gestionar notificaciones push y mantener paridad funcional con la SPA web.

Opciones evaluadas:

Framework	Pros	Contras
Flutter	Compilación AOT a código nativo ARM; UI consistente pixel-perfect vía Skia/Impeller; soporte oficial de Google; ecosistema sólido (camera, local_auth, biometría, flutter_appauth)	Dart es menos popular que JS; integración con SDKs nativos específicos requiere platform channels
React Native	Reuso de conocimiento JS/TypeScript; gran ecosistema npm; soporte de Meta	Bridge JS ↔ Native puede ser cuello de botella en captura de video; UI inconsistente entre plataformas sin trabajo adicional; Fabric/TurboModules aún en adopción
Kotlin Multiplatform Mobile (KMM)	Lógica compartida con nativo real en UI; madurez de Kotlin	UI nativa separada por plataforma (más esfuerzo); ecosistema emergente

Framework	Pros	Contras
Nativo puro (Swift + Kotlin)	Máximo rendimiento y acceso a APIs	Duplica esfuerzo y equipo; costo mayor

Decisión: **Flutter** como framework multiplataforma, con integración nativa puntual para componentes de alta sensibilidad (biometría local, secure storage).

Justificaciones teóricas:

1. **Rendimiento predecible por compilación AOT**. Flutter compila a código ARM nativo evitando el overhead del bridge JS ↔ Native. En aplicaciones con captura de video continua (liveness check en onboarding) y transiciones animadas, reduce la varianza de frame-rate y mejora la percepción de calidad (Human Interface Guidelines de Apple y Material Design de Google exigen 60 fps estables).
2. **Consistencia UI cross-platform (principio de consistencia, Nielsen 10 heurísticas)**. Flutter renderiza su propio árbol de widgets con su engine gráfico; un componente luce idéntico en iOS y Android. En banca, donde la confianza visual importa y los errores de usuario por ambigüedad son costosos, esta consistencia es un activo.
3. **Madurez del ecosistema de seguridad y biometría**. Paquetes oficiales (local_auth, flutter_secure_storage, flutter_appauth) cubren los requisitos bancarios sin reescribir código; la integración con AWS Rekognition se resuelve con platform channels bien soportados.
4. **Trayectoria del mercado laboral**. El talento Flutter en LATAM creció significativamente desde 2021; salarios competitivos con React Native; comunidad activa en Ecuador, Colombia, Perú, México.

Consecuencias y mitigaciones:

- *No se reutiliza código con la SPA Angular* → trade-off aceptado: mobile y web tienen flujos y UX distintos; forzar reuso induciría compromisos UX.
- *Platform channels para SDKs nativos específicos* → mitigado documentando los puentes y manteniendo una capa de abstracción (patrón Facade).

5.6 ADR-05 — Proveedor OAuth 2.0: Microsoft Entra External ID y Keycloak como alternativas tercerizables intercambiables

Contexto: BP requiere un proveedor de identidad externo que exponga OAuth 2.0 + OIDC para autenticar tanto a los **clientes retail** (SPA + móvil, ~500k-1M MAU) como a los **operadores internos** (back office, cumplimiento, DPO — decenas a bajas centenas de usuarios). El enunciado indica que BP cuenta con un producto corporativo configurable; este documento no implementa el Authorization Server. Se recomiendan dos alternativas que BP pueda elegir según su contexto.

Importante — separación de planos de identidad:

- **Customer Identity (CIAM)** para los clientes retail: alta volumetría (MAU), requisitos de UX de autoservicio, biométrica, marca propia.
- **Workforce Identity (B2B)** para operadores internos: baja volumetría (usuarios corporativos), SSO con M365/AD, roles y permisos administrativos.

Son dos planos distintos. Mezclarlos en el mismo tenant **no es best practice** y distorsiona el pricing.

Opciones evaluadas:

Opción	Plano	Modelo	Costo típico a 1M MAU retail	Pros	Contras
Microsoft Entra External ID (CIAM — ex Azure AD B2C)	Retail (CIAM)	SaaS MAU-based: 50k MAU gratis / siguientes escalonados ~$0.00325-$0.019/MAU	**~USD 18.000–30.000/mes** (Premium, con MFA y risk-based)	Zero-ops; certificaciones ISO 27001/SOC 2/PCI/FedRAMP; MFA built-in; Conditional Access; risk-based auth; soporte Microsoft	Residencia de datos limitada a regiones Microsoft; pricing MAU puede escalar; algunos features avanzados requieren tenant Premium
Microsoft Entra ID P1/P2 (Workforce)	Operadores internos	Por usuario/mes: P1 ~$6/u/mes · P2 ~$9/u/mes	Para ~50 operadores internos: ~USD 300–450/mes	Integra nativo con AD, M365, Conditional Access	No aplica para retail (confundir ambos planos es el error #1 del dominio)
Keycl	Amb	Open-	Infra Aurora + EC2 +	Open-source sin	Responsabilidad

Opción	Plano	Modelo	Costo típico a 1M MAU retail	Pros	Contras
oak OSS (ambos planos, realms separados)	os	source self-hosted en EKS; alternativa a Red Hat SSO con soporte	storage ~USD 800–1.500/mes + **2 FTE SRE senior ~USD 7.000–10.000/mes** + Red Hat SSO support opcional ~USD 15–25k/año	lock-in; personalización total; residencia de datos controlada	total del equipo; HA real exige expertise; CVE patching propio
AWS Cognito	Retail (CIAM)	$0.0055/MAU	Para 1M MAU: ~USD 5.500/mes	Integrado stack AWS; barato	Lock-in AWS; featureset limitado en MFA avanzado y Conditional Access
Auth0 / Okta Customer Identity	Retail (CIAM)	Enterprise negociado	Para 1M MAU: ~USD 40.000–70.000/mes	Developer experience top; SDK maduros	Costo alto; residencia de datos EU/US

Decisión: proveer en la arquitectura **dos alternativas tercerizables intercambiables** para el plano CIAM (retail) y mantener el plano workforce separado:

- **Plano CIAM (clientes retail)**: Entra External ID **o** Keycloak (realm CIAM dedicado). BP selecciona según costo total, estrategia de residencia de datos y apetito operativo.
- **Plano Workforce (operadores internos)**: Entra ID P1/P2 integrado con AD corporativo de BP (o Keycloak realm separado si BP no usa M365).

La arquitectura las trata como **proveedores de identidad intercambiables** mediante estándares abiertos (OAuth 2.0 + OIDC + JWT + JWKS + back-channel logout RFC 8414). El sistema consume `issuer` + `jwks_uri` + `token endpoint` + `introspection_endpoint` + `end_session_endpoint` sin acoplamiento al proveedor específico.

5.6.1 Cobertura ampliada (hallazgos del debate adversarial)

(1) Token revocation en tiempo real (feature crítica banca) Los JWT por naturaleza no se revocan antes de su expiración. Para banca esto es inaceptable. Se adopta la siguiente estrategia:

- **Access tokens con TTL corto**: 5–10 minutos (no 60 min default).

- **Refresh Token Rotation con reuse detection**: cada uso del refresh emite uno nuevo e invalida el anterior; reuso detectado → sesión cerrada globalmente.
- **Introspection endpoint obligatorio para operaciones AAL3** (transferencias sobre umbral): antes de ejecutar, el microservicio consulta `introspection` al IdP para validar que el token no haya sido revocado.
- **Token blocklist en Redis** sincronizada desde eventos de logout/revocación del IdP: lookup O(1) por jti antes de validar el JWT en operaciones sensibles.

(2) Logout propagation (back-channel logout RFC 8414) - Los IdPs están configurados con `backchannel_logout_uri` del BFF. - Cuando el cliente ejerce logout, el IdP notifica a todos los Relying Parties (BFF SPA, BFF móvil, otros clientes SSO). - Cada RP termina su sesión local y invalida refresh tokens asociados. - Los eventos de logout también se publican al topic `audit-events` (ver ADR-11).

(3) Runbook de migración entre proveedores Migrar 1M usuarios no es "cambio de configuración". El runbook contempla: - Export de usuarios del proveedor origen (incluyendo hashes de passwords en formatos migrables: bcrypt/PBKDF2/Argon2). - Import al proveedor destino con hashes compatibles (ambos soportan import de bcrypt). - **MFA enrollments** no son portables: los usuarios deben re-enrolar al primer login post-migración; se comunica con 30 días de anticipación. - **Dispositivos registrados y consent grants** se pierden: se re-confirman al primer login. - Período de **doble emisión paralela** (3–4 semanas): el sistema acepta JWT firmados por el issuer antiguo y el nuevo, con flag de preferencia. - Downtime objetivo: **cero** para consultas; **ventana de mantenimiento de ~4h** para el switch final de clientes activos.

(4) Cumplimiento Superintendencia de Bancos — JB-2020-2398 La contratación de proveedores de servicios tecnológicos críticos en la nube requiere: - Notificación / autorización previa a la Superintendencia. - Due diligence del proveedor (certificaciones, plan de continuidad, ubicación de datos, cláusulas contractuales). - Plan de salida documentado (patrón Strategy del ADR facilita esto, pero no lo reemplaza). - Cláusulas de auditoría del proveedor por el regulador o un tercero.

Se incorpora en el plan del Capítulo 9 un workstream de **formalización regulatoria** con legal y cumplimiento, antes del go-live con el proveedor elegido.

(5) Residencia de datos biométricos Los templates faciales del onboarding (ADR-08) **no se almacenan en el IdP**: viven en S3 cifrados con KMS en región local (Ecuador vía outposts si aplica, o la más cercana con disponibilidad del servicio). El IdP solo almacena **referencia + credenciales** derivadas, nunca el template biométrico en claro. Esto reduce el scope del Transfer Impact Assessment a datos de identidad, no a biometría.

(6) Matriz de features OIDC equivalentes (chequear antes de elegir)

Feature	Entra External ID	Keycloak	Observación

Feature	Entra External ID	Keycloak	Observación
Authorization Code + PKCE S256	✅	✅	ADR-06
Refresh Token Rotation + reuse detection	✅	✅ (config por realm)	Activar explícitamente en Keycloak
`acr_values` para step-up AAL3	✅ vía Conditional Access	✅ nativo	En Entra puede requerir Premium
Introspection endpoint	✅	✅	
Back-channel logout RFC 8414	✅	✅	
Pushed Authorization Requests (PAR) RFC 9126	✅	✅ (v23+)	
DPoP RFC 9449	⚠️ limitado	✅	Opcional
MFA built-in (TOTP, FIDO2/WebAuthn, push)	✅	✅	

Justificaciones teóricas:

1. **Principio de inversión de dependencias (DIP, SOLID)**. Los microservicios dependen de la abstracción OIDC/JWT estándar, no de un producto concreto. Este desacoplamiento permite sustituir el proveedor sin tocar código de negocio.
2. **Patrón Strategy aplicado a la identidad (GoF)**. Las dos alternativas son intercambiables porque implementan la misma interfaz conceptual (OIDC + back-channel logout + introspection). El sistema selecciona la estrategia por configuración.
3. **Alineación con NIST SP 800-63B y SP 800-63C**. Los dos proveedores soportan IAL2/FAL2 que banca requiere, con posibilidad de step-up a AAL3 para operaciones críticas.
4. **Resiliencia estratégica y continuidad**. Si el proveedor seleccionado sufre un incidente mayor (p. ej. outage Entra ID de oct-2023 o mar-2024) o un cambio comercial inaceptable, BP puede activar el runbook de migración al alternativo. El diseño no elimina el costo de migrar; lo acota y lo hace ejecutable.

Consecuencias y mitigaciones:

- *Costo real a 1M MAU con Entra External ID*: USD 220.000–360.000/año — reflejado en el Cap 10.
- *Costo real de Keycloak autogestionado*: USD 100.000–150.000/año (infra + personal + soporte opcional) — reflejado en el Cap 10.
- *Separación de planos (CIAM vs workforce)*: dos contratos y dos integraciones, pero mapping claro de responsabilidades.

- *Dependencia del IdP externo para operaciones sensibles*: mitigado con cache local de JWKS, grace period controlado si el IdP responde lento, fallback a modo degradado (solo consulta, sin step-up) si el IdP está caído.
- *Introspection endpoint añade latencia a operaciones AAL3*: mitigado con cache local invalidado por eventos de revocación recibidos del IdP.
- *Formalización SB requiere tiempo*: workstream regulatorio incorporado desde el Sprint 1 del Capítulo 9 para no ser cuello de botella del go-live.

5.7 ADR-06 — Flujo OAuth 2.0: Authorization Code + PKCE (S256)

Contexto: tanto la SPA web como la aplicación móvil son clientes públicos (no pueden guardar un `client_secret` de forma segura). El estándar OAuth 2.0 define varios flujos; la selección del flujo determina la seguridad y la experiencia del usuario.

Opciones evaluadas:

Flujo	Pros	Contras
Authorization Code + PKCE (S256)	Estándar OAuth 2.1; público client-safe; soporta Refresh Token Rotation; soporta `acr_values` para step-up	Requiere redirect + endpoint de token
Implicit flow	Simple	**Deprecado en OAuth 2.1** por inseguro (token expuesto en URL)
Resource Owner Password Credentials (ROPC)	Un solo request	**Deprecado**; el cliente ve la password del usuario
Client Credentials	Server-to-server limpio	No aplica a usuarios finales
Device Code	Dispositivos sin browser	No aplica al caso

Decisión: **Authorization Code + PKCE con `code_challenge_method = S256`**, tanto para SPA web como para aplicación móvil.

Justificaciones teóricas:

1. **RFC 7636 (Proof Key for Code Exchange)**. PKCE mitiga el ataque de interceptación del código de autorización en clientes públicos; es el único flujo que el IETF OAuth Working Group recomienda para SPA y móvil en OAuth 2.1 (draft).
2. **OAuth 2.1 deprecates Implicit flow**. Alinear la arquitectura con OAuth 2.1 future-proof-ea el diseño: no se adopta un flujo que será oficialmente obsoleto.

3. **Soporte de Refresh Token Rotation con reuse detection**. Permite mantener sesiones largas (requisito UX bancaria) sin exponer un bearer de larga vida. Tanto Entra ID como Keycloak soportan este patrón.
4. **Compatibilidad con MFA step-up (`acr_values`)**. El flujo soporta pedir explícitamente un nivel de aseguramiento superior (AAL3) en operaciones de alto impacto (RF-04), sin salir del estándar.

Consecuencias y mitigaciones:

- *SPA debe almacenar tokens con cuidado* → política: access token solo en memoria; refresh token en `httpOnly` cookie emitida por un BFF (Backend-for-Frontend) ligero.
- *Móvil usa librerías probadas* → `flutter_appauth` implementa PKCE correctamente; se evita rodar código criptográfico propio.

5.8 ADR-07 — Autenticación escalonada y step-up: AAL2 base y AAL3 para operaciones de alto impacto

Contexto: no todas las operaciones del sistema tienen el mismo riesgo. Consultar saldo es bajo riesgo; una transferencia interbancaria por un monto alto es crítica. Imponer el mismo nivel de autenticación a todo es o inseguro (si el nivel es bajo para lo crítico) o friccional (si es alto para lo trivial).

Decisión: oferta escalonada de factores de autenticación con step-up dinámico según el riesgo de la operación.

Operación	Factores exigidos	AAL (NIST SP 800-63B)
Login inicial	Usuario + contraseña + OTP (TOTP)	**AAL2**
Login recurrente en dispositivo registrado	Biometría local (huella / FaceID) + device binding	AAL2
Consulta de saldo o movimientos	Sesión activa	AAL2 heredado
Transferencia entre cuentas propias	Sesión activa	AAL2 heredado
Transferencia interbancaria o sobre umbral	Step-up: OTP por canal independiente (SMS, email o push) + firma de la transacción	**AAL3**
Cambio de datos sensibles (teléfono, email, beneficiarios)	Step-up: OTP por canal independiente	AAL3
Re-verificación periódica semestral	Reconocimiento facial (RF-08)	AAL3

Justificaciones teóricas:

1. **NIST SP 800-63B — Digital Identity Guidelines**. El estándar define los niveles de aseguramiento (AAL1 / AAL2 / AAL3) según el riesgo; banca requiere AAL2 como mínimo; operaciones de alto impacto exigen AAL3 con factores criptográficos y resistencia a phishing.
2. **Risk-Based Authentication (OWASP ASVS V2.2)**. El principio de fricción proporcional al riesgo es una buena práctica reconocida: no imponer la misma carga autenticatoria a operaciones de distinto impacto. Reduce abandono sin comprometer seguridad.
3. **Transaction Signing**. En operaciones de alto impacto, el OTP step-up no es solo un segundo factor: también firma la transacción específica (monto, destinatario), proporcionando no-repudio (requisito regulatorio bancario).
4. **Separación de canales (channel separation)**. El step-up se entrega por un canal distinto al del login (SMS, email o push en dispositivo registrado), dificultando ataques en los que un atacante controla solo un canal.

Consecuencias y mitigaciones:

- *Costo de SMS puede escalar* → priorizar push + email; SMS como fallback.
- *UX puede verse fragmentada* → mitigado con diseño UX cuidadoso: mensajes claros sobre por qué se pide el segundo factor en ese momento.

5.9 ADR-08 — Onboarding con reconocimiento facial: AWS Rekognition + Liveness con Veridas como fallback certificado

Contexto: el onboarding móvil (RF-01) requiere verificar que la persona frente a la cámara es real (liveness) y que su rostro coincide con el de su documento de identidad. Esto satisface la Evaluación de Impacto a la Protección de Datos exigida por la LOPDP para tratamiento biométrico.

Opciones evaluadas:

Opción	Pros	Contras
AWS Rekognition + Face Liveness	Integrado al stack cloud; SDK disponible; costo por uso; respuesta rápida	Liveness relativamente nuevo; no certificación local banca explícita
Veridas	Certificado por entidades financieras en LATAM; cumple eIDAS; flujo completo (NFC chip, OCR de documento, face match + liveness)	Costo mayor; integración más pesada
Jumio	Líder global KYC; muy maduro	Más costoso; menor integración con AWS

Opción	Pros	Contras
Onfido	Fuerte en Europa; buen UX	Menor penetración LATAM
Construir in-house	Control total	**Descartado**: no es core de BP; riesgo técnico y legal alto

Decisión: **AWS Rekognition + Face Liveness como implementación principal**, con **Veridas como fallback certificado** para onboarding de alto riesgo (cuentas premium, umbrales transaccionales altos, casos de confianza ambigua) y como respaldo si la Superintendencia de Bancos exige evidencia de vendor certificado.

Justificaciones teóricas:

1. **Defense in Depth (NIST SP 800-53, control SC-3)**. No depender de un único proveedor biométrico reduce el riesgo de que un falso positivo o un cambio comercial en el vendor comprometa el onboarding. Un match ambiguo en Rekognition puede escalar automáticamente a Veridas.
2. **Cost-to-value gradient**. Rekognition cubre la mayoría de los casos a bajo costo; Veridas cubre la minoría de alto riesgo donde el costo adicional está justificado por el valor protegido.
3. **Patrón Strategy aplicado al proveedor (GoF)**. La capa de orquestación del onboarding abstrae qué proveedor se usa. Cambiar de Rekognition a Jumio u Onfido es una decisión operativa/comercial, no un cambio arquitectónico.
4. **Cumplimiento regulatorio demostrable**. Tener Veridas en el stack facilita responder a auditorías de la Superintendencia de Bancos con evidencia de un proveedor con certificaciones específicas banca.

Consecuencias y mitigaciones:

- *Dos contratos de vendor* → mayor complejidad de compras; mitigado centralizando la gestión de proveedores en el PMO.
- *Thresholds de confianza y escalamiento* → definidos como configuración, revisables trimestralmente con métricas de falsos positivos/negativos.

5.10 ADR-09 — Persistencia de clientes frecuentes: Cache-Aside sobre Redis con TTL diferencial

Contexto: los datos consultados con frecuencia (perfil del cliente, productos, últimos 10 movimientos) no deben golpear siempre al core bancario preexistente. La latencia del core es acotada pero no suficiente para cumplir el RNF-02 (p95 < 2 segundos) bajo picos de carga. Además, el core tiene un costo asociado a cada consulta; el cache permite mejorar costo y latencia sin modificar el core.

Opciones evaluadas:

Patrón	Pros	Contras
Cache-Aside (Lazy Loading)	La aplicación controla el cache; invalidación simple; ideal para patrones de lectura irregulares	Primera lectura siempre es miss
Read-Through	Transparente al servicio; cache maneja la carga desde el origen	Requiere soporte nativo del provider (ElastiCache lo tiene)
Write-Through	Datos siempre frescos	Latencia de escritura mayor; el cache debe estar siempre disponible
Write-Behind	Escrituras rápidas	Pérdida potencial si el cache cae antes del flush

Decisión: **Cache-Aside sobre Redis (Amazon ElastiCache)** con **TTL diferencial** por tipo de dato: - Datos muy frecuentes y volátiles (saldo, últimos movimientos): TTL 5 minutos. - Datos menos frecuentes (perfil, productos contratados): TTL 30 minutos. - Datos inmutables o casi (datos maestros del cliente): TTL 24 horas, invalidación por evento del core vía Kafka.

Justificaciones teóricas:

1. **Microsoft Cloud Design Patterns — Cache-Aside**. Patrón explícitamente recomendado para escenarios donde el dataset es grande pero el working-set (datos frecuentes) es pequeño. Encaja con la naturaleza de banca: muchos clientes, pero pocos datos realmente consultados por cada uno en una sesión.
2. **Observabilidad clara de hit/miss ratio**. El patrón expone métricas naturales (hit, miss, invalidate) que alimentan dashboards y permiten ajustar TTL empíricamente. Un read-through opaco al servicio dificulta esta observabilidad.
3. **Resiliencia ante caída del cache**. Si Redis cae, la aplicación degrada (más latencia, más carga al core) pero no falla en correctness. En un write-through o write-behind, la caída del cache impacta correctness.
4. **Invalidación por eventos**. Cuando el core bancario emite un evento de cambio (vía Kafka, patrón outbox), un consumer del servicio invalida la entrada del cache. Consistencia eventual acotada, sin sincronismo rígido (teorema CAP — Brewer; elegimos AP sobre CP para lecturas no críticas).

Consecuencias y mitigaciones:

- *Primera consulta es miss* → irrelevante funcionalmente; aceptable en UX.
- *Redis como SPOF potencial* → mitigado con ElastiCache cluster mode (3 shards con réplicas, multi-AZ automático) y reconciliación automática.

5.11 ADR-10 — Patrón de mensajería: RabbitMQ para comando asíncrono + Kafka para eventos de dominio

Contexto: el sistema requiere dos tipos distintos de comunicación asíncrona: (a) **Comandos asíncronos** entre microservicios con semántica de request/response diferido y ruteo flexible (por ejemplo, un servicio solicita a otro enviar una notificación y espera la confirmación eventual). (b) **Eventos de dominio** que reflejan hechos ocurridos (una transferencia se ejecutó, un cliente se registró) que múltiples consumidores pueden necesitar con replay histórico y retención prolongada.

Estos dos patrones tienen semánticas distintas y usarlos sobre un solo broker penaliza a uno u otro.

Opciones evaluadas:

Opción	Pros	Contras
RabbitMQ + Kafka (dos brokers con roles diferenciados)	Cada uno optimizado a su patrón; madurez probada en banca; roles claros	Dos sistemas a operar
Solo Kafka	Un único sistema; retención fuerte	Modelo pull/offset no ideal para comando asíncrono simple
Solo RabbitMQ	Un único sistema; semántica rich routing	Sin retención fuerte ni replay; no apto para event sourcing
Amazon SQS + SNS	Managed AWS	Lock-in; menos features avanzadas; SNS no es event streaming
NATS JetStream	Moderno; alta performance	Menos adopción banca; comunidad menor

Decisión: **RabbitMQ + Kafka con roles diferenciados**:

- **RabbitMQ** (self-hosted en K8s, operador RabbitMQ Cluster) para **mensajería transaccional** entre microservicios: comandos asíncronos (`send-notification`), solicitudes diferidas, patrones request/reply async.
- **Kafka** (Amazon MSK o self-hosted) para **eventos de dominio**: "transferencia ejecutada", "cliente registrado", "auditoría emitida". Retención larga, consumidores múltiples con replay.

Justificaciones teóricas:

1. **Semántica diferenciada (Enterprise Integration Patterns, Hohpe & Woolf)**. RabbitMQ implementa el patrón "Message Broker" con AMQP exchange + bindings

+ queues; es ideal para comando/respuesta y fan-out dirigido. Kafka implementa el patrón “Event Streaming Log” con topics, particiones y offsets; es ideal para eventos y replay. Forzar uno sobre el otro penaliza performance o semántica.

2. **Patrón Outbox para consistencia** (Chris Richardson, *Microservices Patterns*). Los eventos de dominio se persisten en la misma transacción que la escritura operativa (tabla outbox); un relay publica a Kafka. Este patrón exige el modelo de log de Kafka.
3. **Retención larga para auditoría y replay**. Kafka retiene eventos por días/semanas/meses configurables, lo que permite recuperación ante errores de consumidores downstream y análisis forense. RabbitMQ no está diseñado para retención larga.
4. **Operabilidad probada en banca LATAM**. Tanto RabbitMQ como Kafka tienen clusters bancarios en producción en la región; existen playbooks y talento disponible.

Consecuencias y mitigaciones:

- *Dos brokers a operar* → mitigado con operadores K8s (RabbitMQ Cluster Operator, Strimzi para Kafka) y runbooks compartidos.
- *Decisión de en qué broker ir* → documentada: si tiene respuesta eventual y ruteo rich → RabbitMQ; si es hecho histórico con replay → Kafka.

5.12 ADR-11 — Patrón de auditoría inmutable: Event Sourcing + Outbox + Aurora append-only con hash-chain + TSA + Anchor S3 Object Lock

Contexto: toda acción del cliente, de operadores internos y de accesos administrativos debe registrarse de forma **inmutable, no repudiable y criptográficamente verificable** (RF-10, RNF-06). Un auditor externo o la Superintendencia de Bancos deben poder validar que un registro no ha sido manipulado. Además, el diseño debe conciliarse con el derecho de supresión de la LOPDP (Art. 12).

> **Nota sobre QLDB**: en la primera iteración de este documento se contempló Amazon QLDB como ledger. **Amazon QLDB fue deprecado por AWS en julio de 2024 con end-of-life en julio de 2025**. Por esta razón se descartó esta opción y se diseñó una alternativa portable basada en componentes vigentes y soportados a largo plazo.

Opciones evaluadas:

Opción	Pros	Contras
~~Amazon QLDB~~	Ledger inmutable con verificación criptográfica Merkle	**Deprecado — AWS EOL jul/2025**
Aurora PostgreSQL	Portable (PostgreSQL estándar);	Más partes a

Opción	Pros	Contras
append-only + hash-chain HMAC + TSA RFC 3161 + anchor a S3 Object Lock	criptográficamente verificable; usa componentes maduros; sin lock-in; evidencia timestamped por autoridad externa confiable	orquestar; implementación custom del hash-chain
Immudb (self-hosted)	Ledger verificable OSS con API familiar; mantiene semantica “immutable by design”	Menor adopción enterprise; sin soporte vendor en LATAM
Append-only table en RDBMS sin hash-chain ni TSA	Simple	No garantiza inmutabilidad real; DBA puede alterar; sin no-repudio
Blockchain privada (Hyperledger Fabric)	Inmutabilidad máxima multi-parte	Overkill operativo y de costo para el caso

Decisión: **Event Sourcing con patrón Outbox sobre Kafka + consumer que persiste a Aurora PostgreSQL con hash-chain HMAC + sello de tiempo por TSA externa (RFC 3161) + anchor diario a Amazon S3 Object Lock, espejo a OpenSearch para consulta**.

5.12.1 Flujo conceptual

1. El microservicio emisor realiza una acción de negocio y, en la **misma transacción ACID**, persiste en su tabla operativa y en una tabla `outbox` (patrón Transactional Outbox de Chris Richardson).
2. Un relay CDC (Debezium) captura los eventos del outbox y los publica al topic Kafka `audit-events`.
3. El `audit-service` consume los eventos y los persiste en una **tabla `audit_ledger` en Aurora PostgreSQL** con las siguientes propiedades:
   - **Append-only enforced**: triggers `BEFORE UPDATE OR DELETE` que lanzan excepción; rol de BD con permisos únicamente `INSERT, SELECT`.
   - **Hash-chain HMAC**: cada fila contiene `prev_hash` + `current_hash = HMAC-SHA256(key, prev_hash || row_payload)`. La clave HMAC vive en HashiCorp Vault con rotación controlada y auditoría de uso.
   - **Partitioning por mes** para gestión de volumen sin comprometer verificabilidad.
4. **Anclaje externo por TSA (Timestamping Authority, RFC 3161)**: cada hora el `audit-service` toma el `current_hash` más reciente (root hash del periodo), lo envía a una TSA externa confiable (ej. DigiCert, FreeTSA) y recibe un sello de tiempo firmado por una autoridad reconocida. Este sello se persiste junto al root hash.

5. **Anchor diario a S3 Object Lock + Glacier Deep Archive**: snapshot diario del `audit_ledger` del día + los sellos TSA correspondientes, con Object Lock en modo *Compliance* (no eliminable ni por el root de la cuenta AWS) y lifecycle a Glacier Deep Archive tras 90 días.
6. **Espejo a Amazon OpenSearch** para consulta por el oficial de cumplimiento, dashboards y alertas; con reindexación on-demand desde Aurora como fuente de verdad.
7. **Verificación**: cualquier auditor puede: (a) validar el hash-chain recorriendo las filas secuencialmente; (b) validar los sellos TSA con la clave pública de la autoridad; (c) comparar los anchors en S3 con los datos en Aurora.

5.12.2 Cobertura ampliada (hallazgos del debate adversarial)

- **Eventos del IdP externo** (Keycloak / Microsoft Entra ID): un job programado hace *pull* periódico de los audit logs del IdP (Microsoft Graph API o Keycloak Events API) y los emite al topic `audit-events` con un source-tag específico, para garantizar trazabilidad end-to-end incluyendo autenticación.
- **Auditoría de lecturas sensibles**: toda consulta a información personal o financiera emite evento de auditoría independientemente de que la respuesta venga del cache (ADR-09) o del core. El evento se emite en el microservicio antes de retornar la respuesta.
- **Comandos RabbitMQ sensibles** (ADR-10): emisión de OTP, notificaciones críticas, etc., también emiten evento al `audit-events`.

5.12.3 Conciliación con LOPDP Art. 12 (derecho de supresión)

- **Base legal preferente**: LOPDP Art. 12 numeral 2 — **retención por obligación legal**. La Superintendencia de Bancos exige retención de evidencia de operaciones por al menos 10 años, lo que prevalece sobre el derecho de supresión ordinario para registros con impacto financiero o regulatorio.
- **Mecanismo técnico: crypto-shredding**. Los campos con datos personales (PII) dentro del evento de auditoría se cifran con una **clave por titular** almacenada en Vault. Cuando un cliente ejerce derecho de supresión fuera del alcance de la obligación regulatoria, se destruye la clave: el hash-chain permanece íntegro (el `row_payload` incluye el ciphertext, no el plaintext), pero el contenido PII se vuelve matemáticamente ilegible. Se preserva la evidencia regulatoria y se cumple el derecho LOPDP.
- **Tokenización complementaria**: identificadores de titular dentro del ledger se tokenizan; el mapping token-identidad vive en un store mutable que sí puede purgarse según LOPDP cuando aplique.

Justificaciones teóricas:

1. **Outbox Pattern (Chris Richardson, *Microservices Patterns*)**. Garantiza que toda acción genera un evento y ningún evento se pierde, resolviendo el problema del dual write (escribir en BD y publicar a Kafka en la misma transacción atómica).
2. **Verificabilidad criptográfica sin lock-in**. El hash-chain HMAC + TSA externa + anchor S3 proporcionan garantías equivalentes a un ledger propietario (no repudio, detección de tampering, timestamping por tercero confiable) usando componentes estándar y portables. Este diseño sobrevive a la deprecación de cualquier servicio managed específico.
3. **Separación de responsabilidades (Single Responsibility Principle)**. Kafka = canal de eventos; Aurora append-only = persistencia inmutable verificable; OpenSearch = consulta y dashboards; S3 Object Lock = archive regulatorio.
4. **Retención y almacenamiento de largo plazo**. Snapshot diario a S3 Object Lock en modo *Compliance* + lifecycle a Glacier Deep Archive: retención de 10+ años a costo mínimo, con garantía de no-eliminación por nadie (incluido el root de la cuenta AWS), cumpliendo exigencias de la Superintendencia de Bancos.

Consecuencias y mitigaciones:

- *Más piezas que operar (Kafka, Aurora ledger, TSA externa, OpenSearch, S3)* → mitigado con observabilidad fuerte (lag de consumer, edad del último anchor, verificación automatizada del hash-chain cada N horas) y pruebas de reconciliación mensuales.
- *Dependencia de TSA externa* → mitigado usando múltiples TSAs (FreeTSA + DigiCert) y almacenando los sellos de ambas por evento crítico.
- *Volumen y costo de Aurora ledger* → mitigado con particionado mensual, archivo a S3 trascurridos 90 días, y compresión de filas antiguas; costo total estimado USD 2k–4k/mes para 50-150M eventos/mes (ver Cap 10), significativamente inferior al descartado QLDB.
- *Throughput* → Aurora PostgreSQL soporta decenas de miles de inserts/segundo con la configuración apropiada; muy por encima del throughput observado en banca de 1M MAU.

5.13 ADR-12 — Object storage y gestión de secretos: MinIO + Amazon S3 y HashiCorp Vault + AWS Secrets Manager

Contexto: el sistema requiere almacenamiento de objetos para dos usos distintos (documentos operativos como comprobantes, archivos KYC del onboarding, imágenes del documento de identidad; y almacenamiento de archivo de largo plazo) y una gestión robusta de secretos (credenciales de BD, API keys, certificados).

5.13.1 Decisión sobre object storage

- **MinIO desplegado en Kubernetes** para almacenamiento operativo de corto y mediano plazo (acceso frecuente desde microservicios dentro del cluster; latencia baja; S3-compatible API).
- **Amazon S3** para archivo de largo plazo (comprobantes mayores a 90 días, journal de auditoría Aurora exportado, backups), con tiering a S3 Intelligent-Tiering y Glacier Deep Archive para datos fríos.

Justificaciones teóricas:

1. **Portabilidad y evitabilidad de egress fees**. MinIO expone API compatible con S3; el código que lo consume no sabe si está hablando con MinIO o con S3 real. Mantener datos operativos dentro del cluster evita el egress cost y la latencia de ida/vuelta a S3 para operaciones frecuentes.
2. **Costo diferenciado por patrón de acceso**. Datos calientes en MinIO (bajo costo operativo dentro del cluster); datos fríos en S3 Glacier Deep Archive ($0.00099/GB/mes) con reglas de lifecycle automáticas.

5.13.2 Decisión sobre gestión de secretos

- **HashiCorp Vault** desplegado en K8s como gestor central de secretos de aplicación (rotación dinámica, dynamic secrets para bases de datos, PKI interna, encryption-as-a-service).
- **AWS Secrets Manager** para secretos que son consumidos por servicios AWS nativos (RDS credentials, API keys de servicios AWS, IAM role credentials).
- Jerarquía: Vault es la fuente primaria; sincroniza o espeja a Secrets Manager cuando un servicio AWS lo exige.

Justificaciones teóricas:

1. **Principio del mínimo privilegio (POLP)**. Vault emite credenciales dinámicas con TTL corto en lugar de almacenar credenciales estáticas de larga duración. Compromiso de un secreto tiene impacto temporal acotado.
2. **Separación entre secretos de aplicación y secretos de nube**. Secretos de aplicación (contraseñas de BD, API keys de terceros) viven en Vault; secretos AWS-nativos viven en Secrets Manager. Cada herramienta donde hace mejor su trabajo.
3. **Encryption-as-a-service**. Vault Transit puede cifrar/descifrar datos sensibles bajo demanda sin que las claves salgan del cluster, permitiendo que los microservicios encripten a nivel de aplicación sin manejar material criptográfico localmente.

Consecuencias y mitigaciones:

- *Vault es un componente crítico* → desplegado en modo HA (Raft con 3-5 nodos), backups automáticos, DR drill mensual.

- *Dos stores de secretos* → mitigado con documentación clara del árbol de decisión (qué secreto va en dónde).

5.14 Síntesis del capítulo

El Capítulo 4 ha desarrollado doce decisiones arquitectónicas clave, agrupadas en cuatro familias (backend y comunicación, frontend, identidad y seguridad, datos y almacenamiento). Cada decisión se ha presentado con su contexto, las opciones evaluadas, la decisión tomada, al menos dos justificaciones teóricas con fundamento conceptual, y las consecuencias y mitigaciones asumidas.

En conjunto, las decisiones configuran un sistema que:

- Opera sobre Kubernetes administrado (EKS), con microservicios Spring Boot 3 sobre Java 21, aplicando DDD, Hexagonal Architecture y Clean Architecture dentro de cada servicio.
- Se comunica externamente a través de una capa perimetral (AWS API Gateway + WAF + Shield) y enruta internamente con Spring Cloud Gateway + Kubernetes-native service discovery.
- Presenta su interfaz al cliente final mediante una SPA Angular 17+ y una aplicación móvil Flutter, ambas autenticándose con OAuth 2.0 Authorization Code + PKCE contra un proveedor de identidad tercerizable (Microsoft Entra ID o Keycloak).
- Protege las operaciones críticas con autenticación escalonada AAL2 base y step-up AAL3 por token OTP de canal independiente.
- Realiza el onboarding digital con reconocimiento facial (Rekognition + Veridas como fallback certificado).
- Cachea datos frecuentes con patrón Cache-Aside sobre Redis con TTL diferencial.
- Utiliza RabbitMQ para mensajería transaccional y Kafka para eventos de dominio.
- Audita todas las acciones de forma inmutable mediante Event Sourcing + Outbox + Aurora append-only con hash-chain HMAC + TSA + anchor S3 Object Lock + espejo a OpenSearch.
- Almacena objetos operativos en MinIO y archivos de largo plazo en S3; gestiona secretos con Vault + AWS Secrets Manager.

Las vistas de contenedores y componentes de esta arquitectura se desarrollan en los dos capítulos siguientes con el modelo C4.

---

6 Diagramas C4 (de la alternativa seleccionada)

Este capítulo presenta la vista arquitectónica del sistema seleccionado en el Capítulo 3 (Alternativa B — Híbrida Kubernetes + Spring Cloud) en los tres niveles del modelo C4 de Simon Brown. El Nivel 1 (Contexto) para cada alternativa evaluada se presentó en el Capítulo 3; aquí se profundiza sobre la alternativa ganadora con los Niveles 2 (Contenedores) y 3 (Componentes).

6.1 C4 Nivel 1 — Contexto (síntesis del ganador)

Para la alternativa seleccionada, el diagrama de contexto es el presentado en la sección 3.4 del Capítulo 3 (Alternativa B). Muestra el sistema de banca por internet BP como caja negra, sus actores (cliente retail, onboarding, back office, cumplimiento, DPO, Superintendencia de Bancos) y sus sistemas externos (core bancario, CRM/ODS, red interbancaria, proveedores de identidad y de reconocimiento facial intercambiables, servicios de notificación).

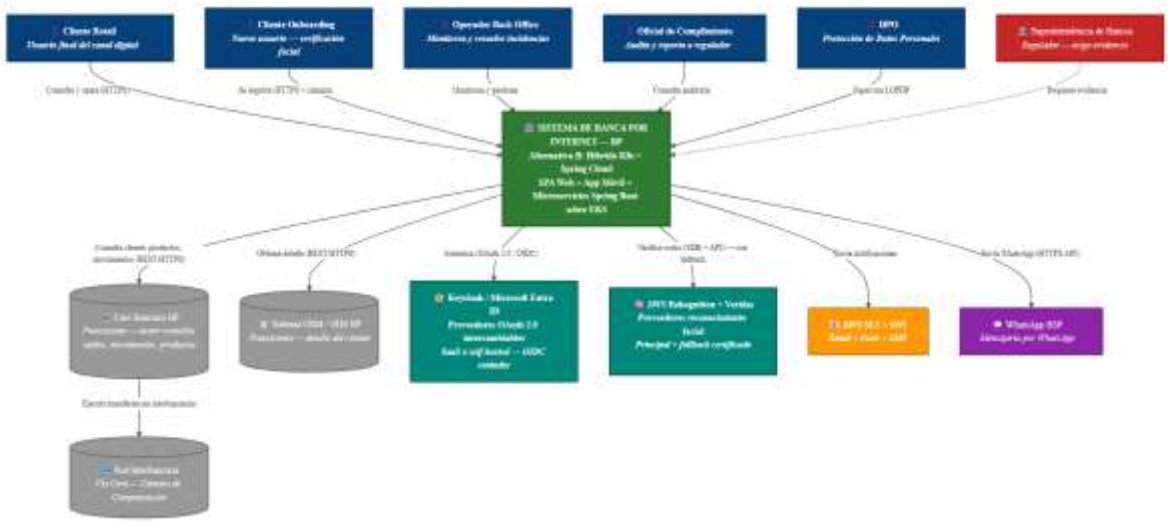


Diagrama C4 Nivel 1 — Contexto — Alternativa B seleccionada

6.2 C4 Nivel 2 — Contenedores (vista técnica)

El diagrama de contenedores desglosa el sistema en sus unidades desplegables: la SPA Angular, la app móvil Flutter, los microservicios Spring Boot sobre EKS, las bases de datos, los brokers de mensajería, los servicios cloud gestionados y las integraciones externas. Explicita los protocolos de comunicación principales (HTTPS/REST, OAuth 2.0/OIDC, mTLS entre microservicios, AMQP para RabbitMQ, protocolo Kafka para eventos, Cache-Aside sobre Redis).

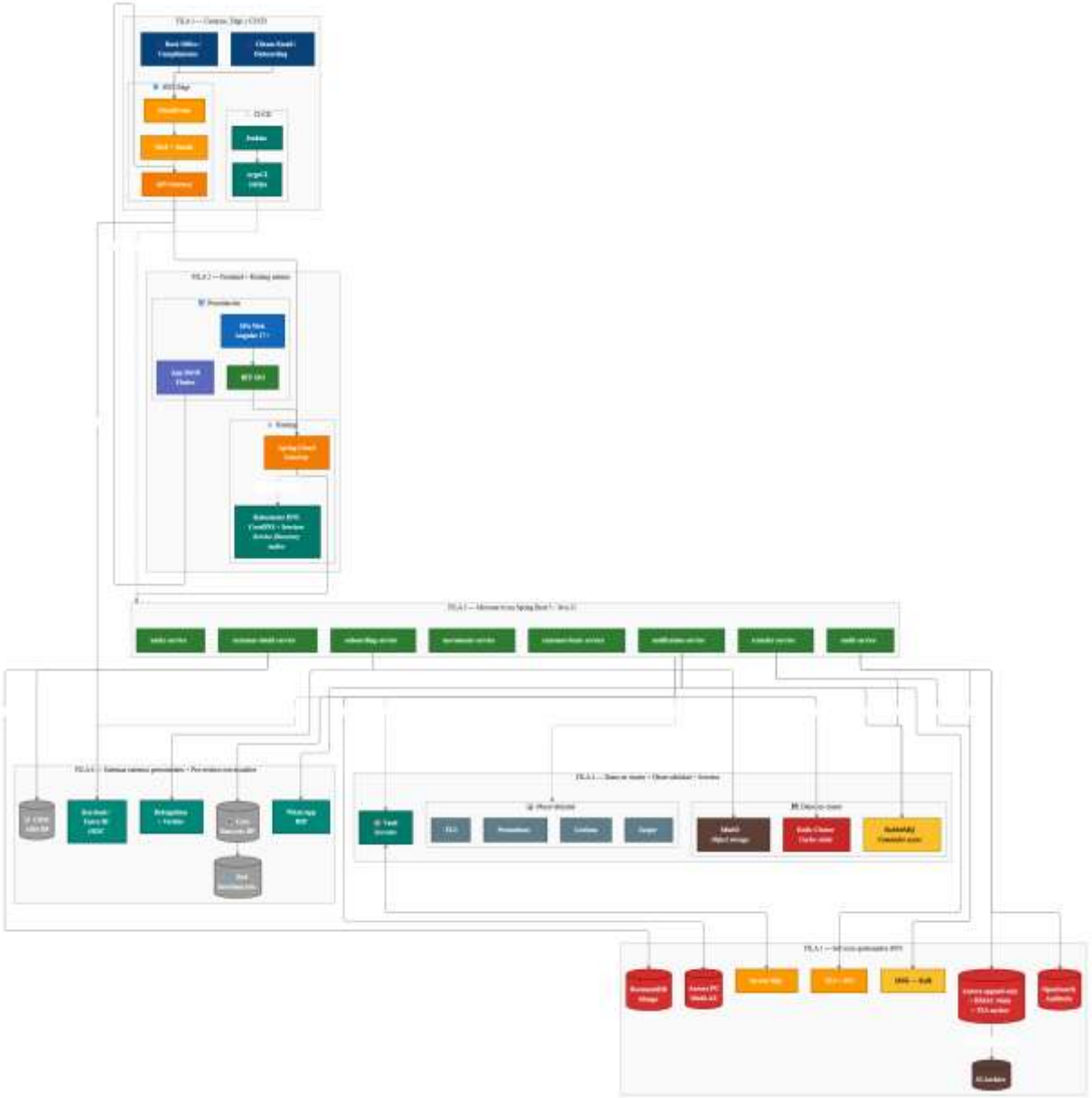


Diagrama C4 Nivel 2 — Contenedores — Alternativa B

Convenciones de color:

- Azul oscuro: actores (personas).
- Azul claro: aplicaciones de interfaz de usuario (SPA).
- Índigo: aplicación móvil.
- Verde: microservicios Spring Boot y elementos del cluster Kubernetes.
- Naranja: servicios AWS managed estratégicos reemplazables (Aurora, MSK, OpenSearch, SES, SNS, Secrets Manager, S3).
- Rojo: bases de datos (cache y persistencia).
- Amarillo: brokers de mensajería (RabbitMQ, Kafka).
- Marrón: object storage (MinIO + S3).
- Gris acero: observabilidad (Prometheus, Grafana, ELK, Jaeger).
- Gris: sistemas externos preexistentes de BP (core bancario, CRM/ODS, red interbancaria).
- Teal: proveedores tercerizables intercambiables (Keycloak/Entra ID, Rekognition/Veridas, WhatsApp BSP).

6.3 C4 Nivel 3 — Componentes (detalle del microservicio canónico)

Como ejemplo canónico del nivel de componentes se detalla el microservicio `transfer-service`, porque concentra la mayoría de patrones arquitectónicos del sistema: Hexagonal Architecture, DDD, Clean Architecture, patrón Outbox, idempotencia, step-up authentication, circuit breaker y resiliencia, observabilidad y gestión de secretos. El mismo esquema es aplicable a los demás microservicios con las adaptaciones propias de cada dominio.

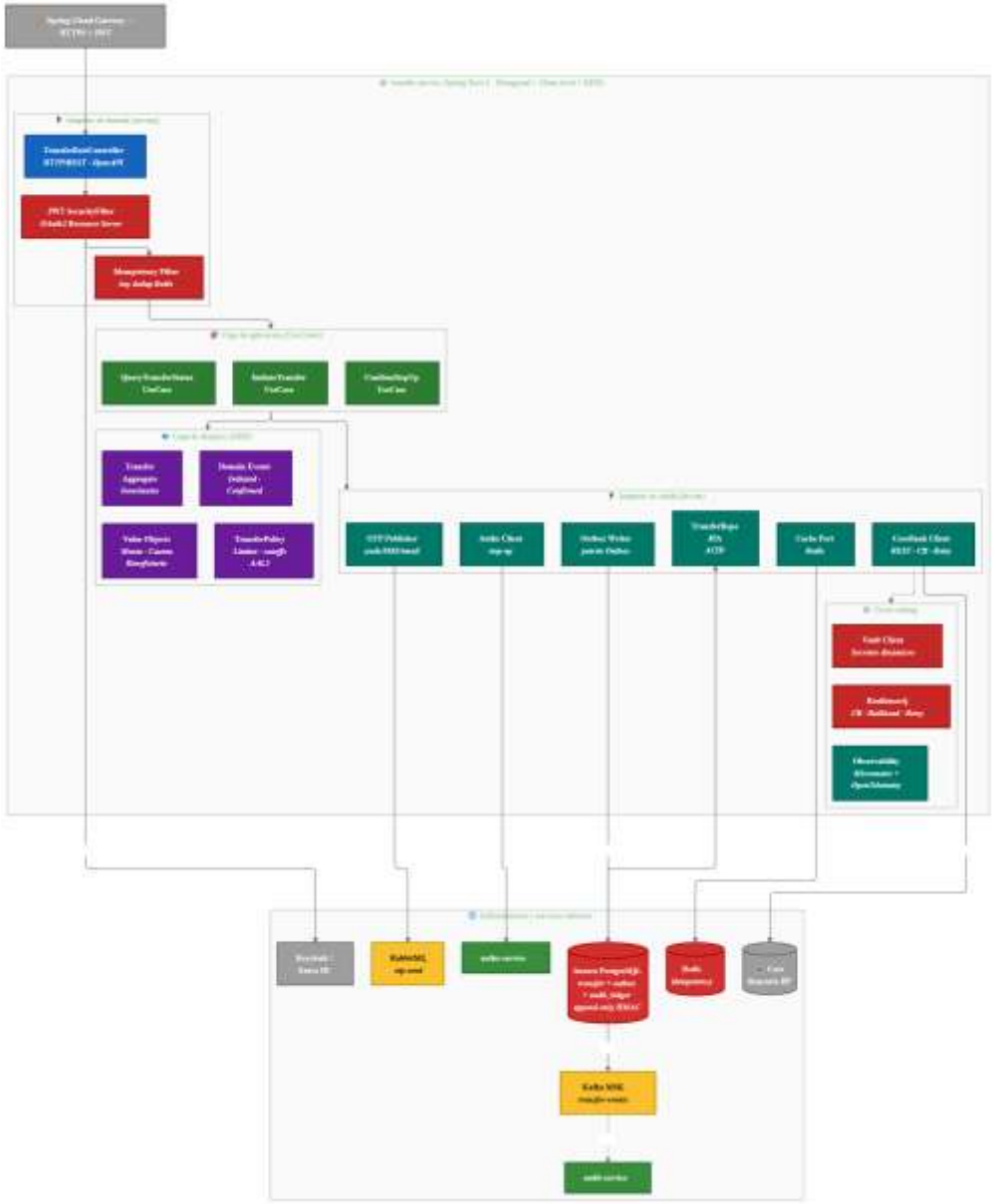


Diagrama C4 Nivel 3 — Componentes — transfer-service

Capas internas (Hexagonal + Clean):

- **Adapters de entrada (driving)**: controladores REST, filtros de seguridad (Spring Security + OAuth2 Resource Server), filtro de idempotencia sobre Redis.
- **Capa de aplicación (use cases)**: casos de uso que coordinan el flujo (`InitiateTransferUseCase`, `ConfirmStepUpUseCase`, `QueryTransferStatusUseCase`); son el punto de entrada al dominio.
- **Capa de dominio (DDD)**: agregado `Transfer` con invariantes, value objects (Monto, Cuenta, Beneficiario), eventos de dominio y políticas de negocio (límites, cutoffs, requerimientos AAL3).
- **Adapters de salida (driven)**: repositorio JPA (ACID), escritor del outbox (patrón Outbox para consistencia transaccional-eventos), cliente al core bancario con circuit breaker, cliente al `authz-service` para step-up, publicador de OTP, port al cache Redis.
- **Cross-cutting**: observabilidad (Micrometer + OpenTelemetry), resiliencia (Resilience4j: Circuit Breaker + Bulkhead + Retry), cliente Vault para secretos dinámicos.

---

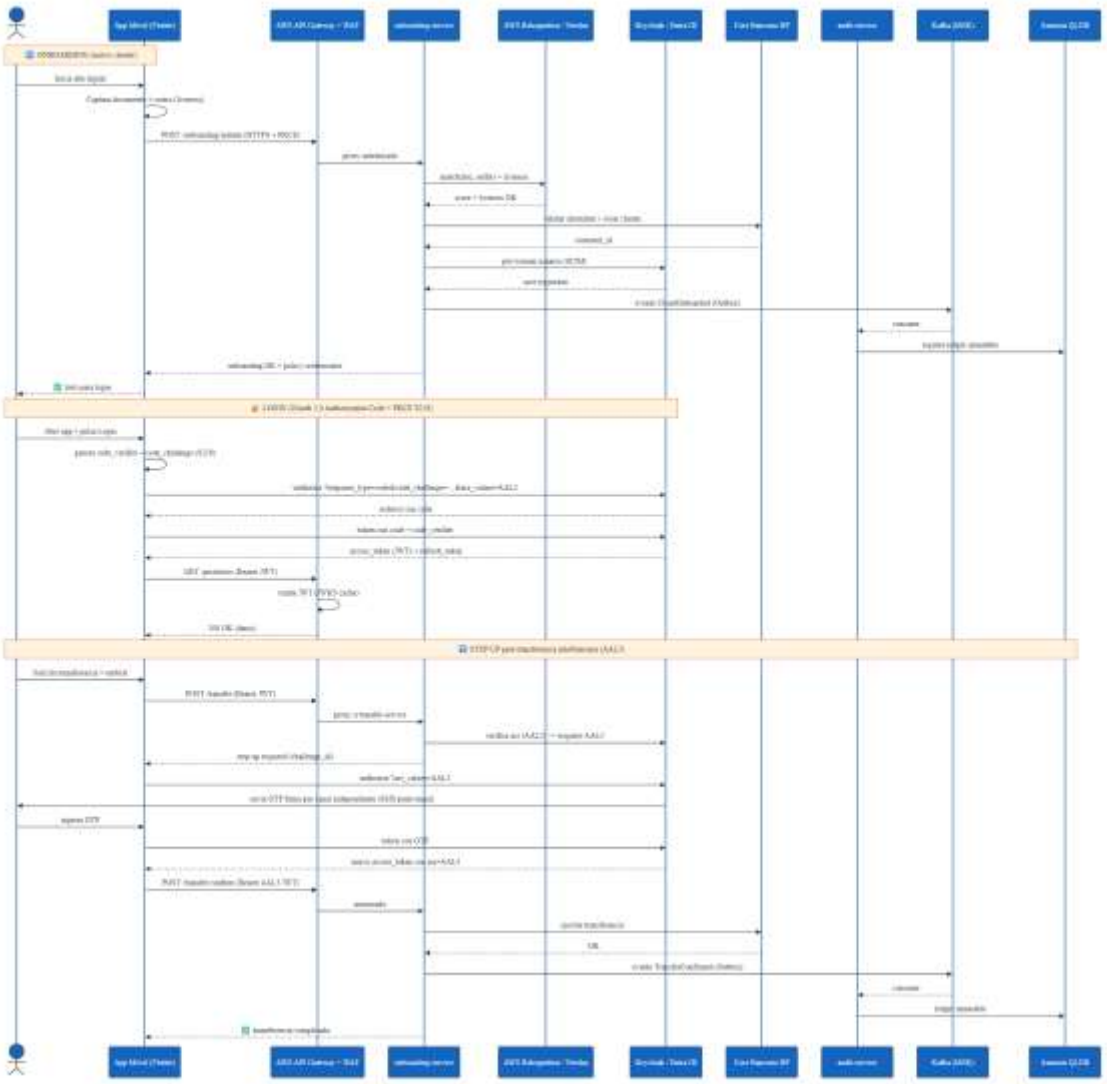
7 Diagramas complementarios

Los diagramas complementarios ilustran flujos transversales y vistas de infraestructura que complementan el modelo C4.

7.1 Flujo de autenticación OAuth 2.0 + onboarding con reconocimiento facial

Este diagrama de secuencia muestra tres sub-flujos encadenados que ejemplifican la mayoría de las decisiones de autenticación del Capítulo 4 en acción:

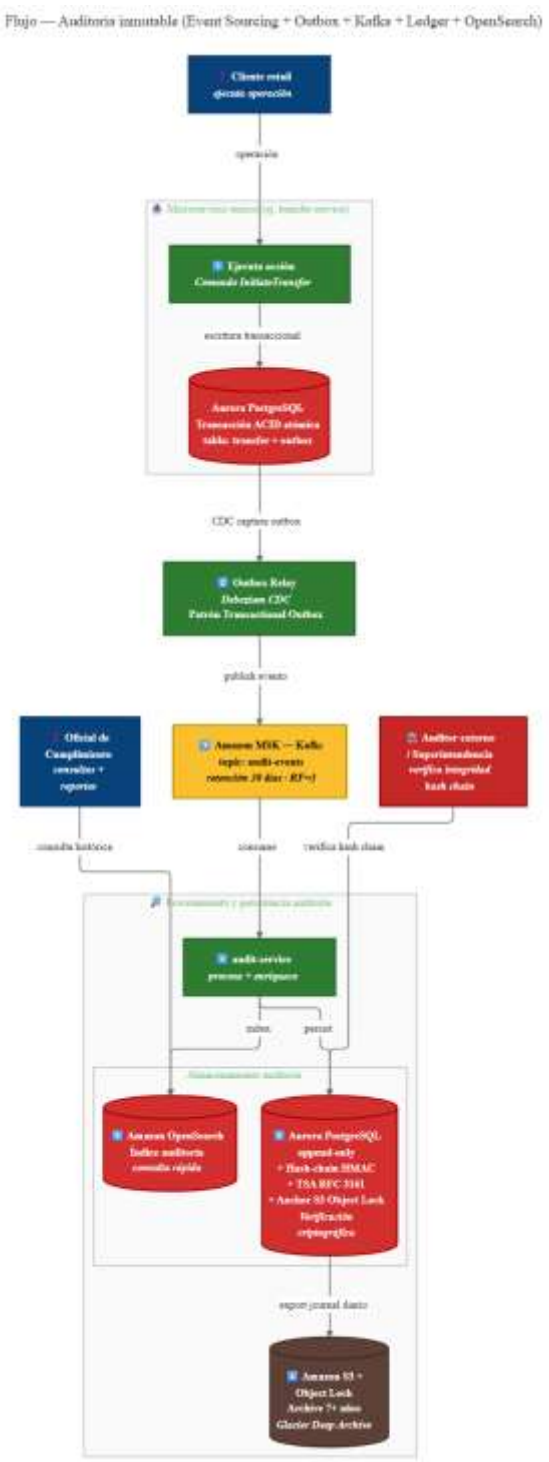
1. **Onboarding** de un cliente nuevo con captura de documento, verificación facial (liveness + match), provisión del usuario en el IdP y registro inmutable de auditoría.
2. **Login** con OAuth 2.0 Authorization Code + PKCE (S256) contra el IdP (Keycloak o Entra ID).
3. **Step-up a AAL3** mediante OTP firma por canal independiente, requerido para operaciones de alto impacto (transferencia interbancaria sobre umbral).



Flujo OAuth 2.0 + onboarding facial

7.2 Flujo de auditoría inmutable (Event Sourcing + Outbox + Kafka + Aurora append-only + TSA + OpenSearch)

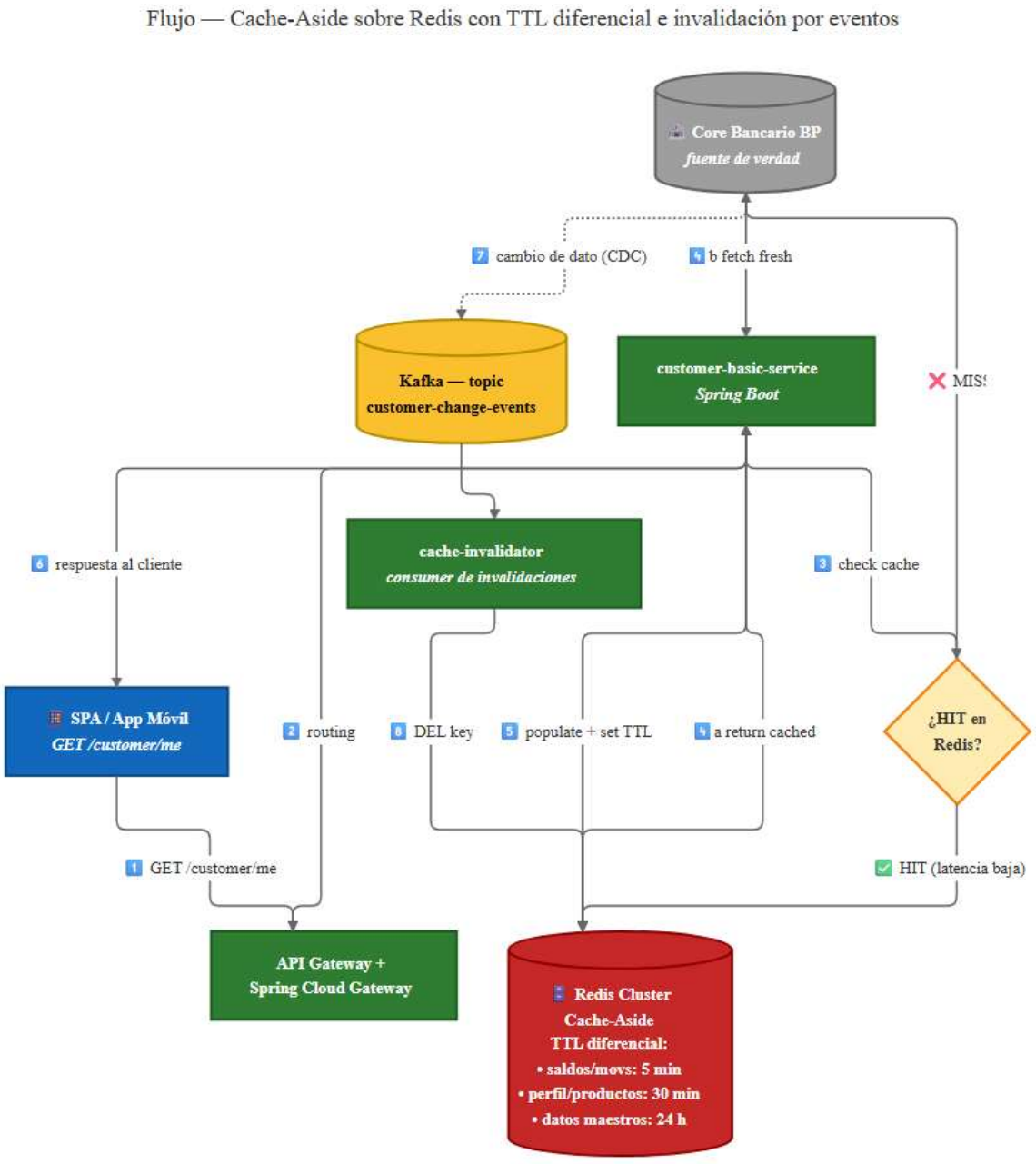
Este diagrama ilustra el patrón de auditoría propuesto en el ADR-11: una acción del usuario produce una escritura transaccional atómica (BD operativa + tabla outbox), que es capturada por CDC (Debezium) y publicada a Kafka; un consumidor dedicado persiste cada evento en Aurora PostgreSQL append-only con hash-chain HMAC (verificable criptográficamente) y lo indexa paralelamente en OpenSearch para consulta por el oficial de cumplimiento. El contenido del ledger se ancla diariamente a S3 con Object Lock + Glacier Deep Archive para retención regulatoria de 7+ años.



Flujo de auditoría inmutable

7.3 Flujo de cache (Cache-Aside sobre Redis con invalidación por eventos)

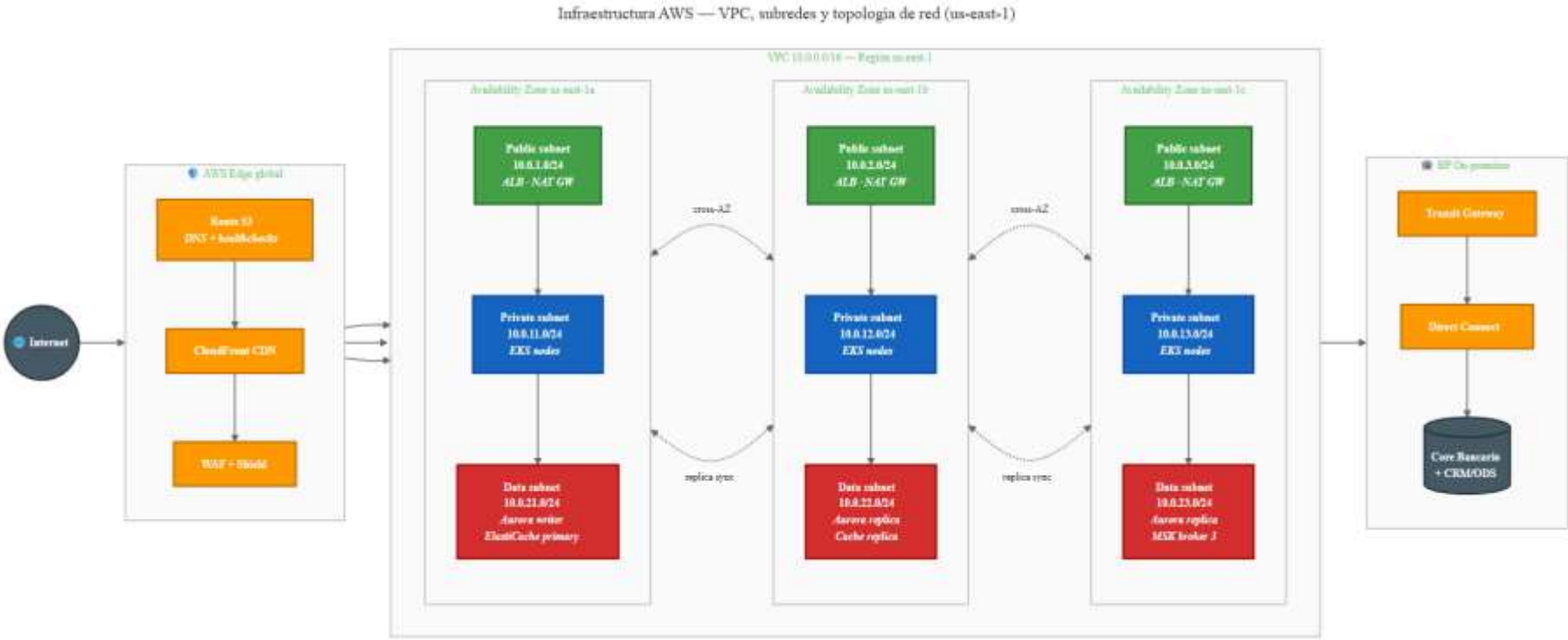
Este diagrama ilustra el patrón Cache-Aside propuesto en el ADR-09, con TTL diferencial (5 min / 30 min / 24 h según volatilidad del dato) e invalidación por eventos emitidos por el core bancario a través de Kafka cuando un dato cambia en la fuente de verdad.



Flujo de cache — Cache-Aside sobre Redis

7.4 Infraestructura AWS — VPC, subredes y topología de red

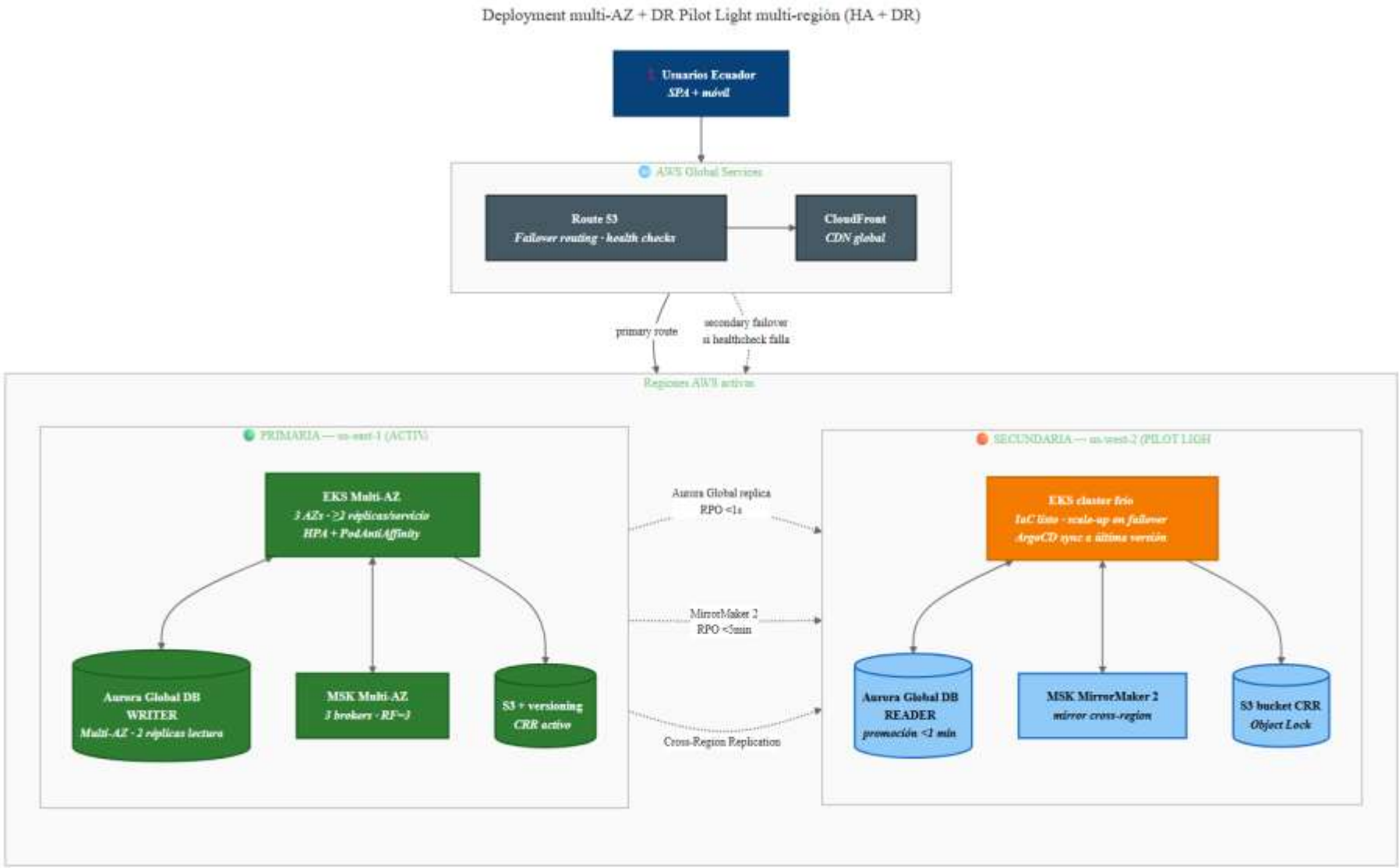
Este diagrama muestra la topología de red del sistema en la región primaria (us-east-1): tres zonas de disponibilidad (AZs), cada una con subredes pública, privada y de datos; NAT Gateway por AZ para egress controlado; integración con on-premises de BP vía Transit Gateway + Direct Connect para alcanzar el core bancario.



Infraestructura AWS — VPC y topología de red

7.5 Deployment multi-AZ + DR Pilot Light multi-región

Este diagrama muestra la estrategia de HA y DR: la región primaria (us-east-1) opera activa con EKS multi-AZ, Aurora Global Database como writer, MSK con factor de replicación 3 y S3 con versioning + Cross-Region Replication. La región secundaria (us-west-2) opera en modo **Pilot Light**: EKS “frío” con IaC listo para scale-up, Aurora Global Database como reader (promoción en menos de 1 minuto), MirrorMaker 2 espejando Kafka y S3 CRR. Route 53 con health checks ejecuta el failover automatizado cuando el health check de la región primaria falla. RTO objetivo ≤ 30 minutos, RPO ≤ 5 minutos.



Deployment multi-AZ + DR multi-región

8 HA, DR, Observabilidad y Auto-healing

8.1 Alta disponibilidad (HA)

El sistema se diseña para cumplir el SLA de 99.95% mensual (≈ 22 minutos de downtime permitido) mediante tres niveles de redundancia complementarios:

Nivel de red y perímetro (AWS edge): Route 53 con health checks activos sobre endpoints clave; CloudFront como CDN global; AWS WAF + Shield en modo Advanced (opcional) para protección perimetral L7 y DDoS; AWS API Gateway como capa de entrada regional con rate limiting y autenticación.

Nivel de cluster (EKS multi-AZ): el cluster EKS se despliega en tres zonas de disponibilidad de la región primaria; cada microservicio corre con al menos dos réplicas distribuidas con `PodAntiAffinity` para evitar que caigan por una sola falla de nodo o AZ; Horizontal Pod Autoscaler (HPA) escala según métricas custom (RPS, latencia p95); Pod Disruption Budgets protegen durante mantenimientos del cluster.

Nivel de datos: Aurora PostgreSQL Multi-AZ con writer en una AZ y replicas en las otras (failover automático en menos de 60 segundos); DocumentDB con réplicas cross-AZ; ElastiCache Redis en modo cluster con 3 shards y réplicas; Amazon MSK con factor de replicación 3 distribuido entre AZs; MinIO en modo distribuido con erasure coding.

8.2 Disaster Recovery (DR)

Estrategia seleccionada: Pilot Light multi-región. La región secundaria (us-west-2) mantiene recursos mínimos pero críticos pre-provistos y listos para escalar:

- Aurora Global Database con instancia de lectura en región secundaria (replicación a nivel de storage con RPO típicamente inferior a 1 segundo); promoción a writer en menos de 1 minuto.
- EKS cluster “frío” con infraestructura como código (Terraform) lista para `apply`; ArgoCD sincronizado a la última versión estable de los manifiestos.
- MirrorMaker 2 espejando los topics Kafka críticos cross-region.
- S3 Cross-Region Replication con Object Lock.
- Route 53 con configuración de failover preparada.

Objetivos acordados: RTO ≤ 30 minutos, RPO ≤ 5 minutos.

Pruebas: Game Day trimestral con observadores externos; tabletop exercise mensual para refinar runbooks; chaos engineering con LitmusChaos para validar mecanismos de recuperación.

8.3 Observabilidad — cuatro pilares

Métricas: Prometheus (operator en EKS) recolecta métricas de los microservicios (expuestas vía Micrometer / Spring Boot Actuator) y de la infraestructura; Grafana presenta dashboards por squad y un dashboard ejecutivo con SLIs/SLOs; Thanos opcional para long-term storage.

Logs: logs estructurados en formato JSON con `correlation-id`, `trace-id` y `user-id-hashed` (nunca datos personales en claro); Fluent Bit en cada nodo envía a OpenSearch (o ELK self-hosted); retención diferenciada (90 días caliente, 1 año en S3, 7 años en Glacier Deep Archive para logs de auditoría regulatoria).

Trazas: OpenTelemetry SDK en todos los microservicios; collector envía a Jaeger (o AWS X-Ray); sampling adaptativo (100% en errores, 10% en requests normales).

Logs de auditoría (cuarto pilar propio de banca): separados de los logs operativos; inmutables en Aurora append-only con hash-chain HMAC + TSA; consultables por el oficial de cumplimiento vía OpenSearch; firmados criptográficamente.

Dashboards clave: **Golden Signals** (Latency, Traffic, Errors, Saturation) por servicio; **USE** (Utilization, Saturation, Errors) por infraestructura; **RED** (Rate, Errors, Duration) por endpoint; métricas de negocio (login success rate, transferencias por hora, completitud de onboarding).

8.4 Auto-healing

Falla	Detección	Mecanismo de auto-healing
Pod cae	Kubernetes liveness probe	Reinicio automático
Pod degradado	Kubernetes readiness probe	Remoción del service hasta recuperación
Nodo cae	Node Problem Detector	Cordon + drain + reemplazo por Auto Scaling Group
Deployment incorrecto	Argo Rollouts analysis (error rate, latencia)	Rollback automático
Instancia Aurora cae	Aurora failover	Promoción de réplica en <60 s
AZ cae	Route 53 health check	Routing a AZ sana
Memory leak	HPA + VPA	Scale horizontal + alerta
Thread pool exhausted	Resilience4j + Prometheus	Circuit breaker abre + alerta
Quota de API externa agotada	Métrica custom	Rate limit más agresivo + alerta

8.5 Observabilidad de seguridad

AWS GuardDuty para detección de amenazas; Security Hub como agregador de hallazgos; CloudTrail (inmutable, con S3 Object Lock) para auditoría de API AWS; VPC Flow Logs; AWS Config para detección de drift; Falco para seguridad en runtime de pods; Wazuh (o SIEM equivalente) para correlación de eventos.

8.6 Excelencia operativa

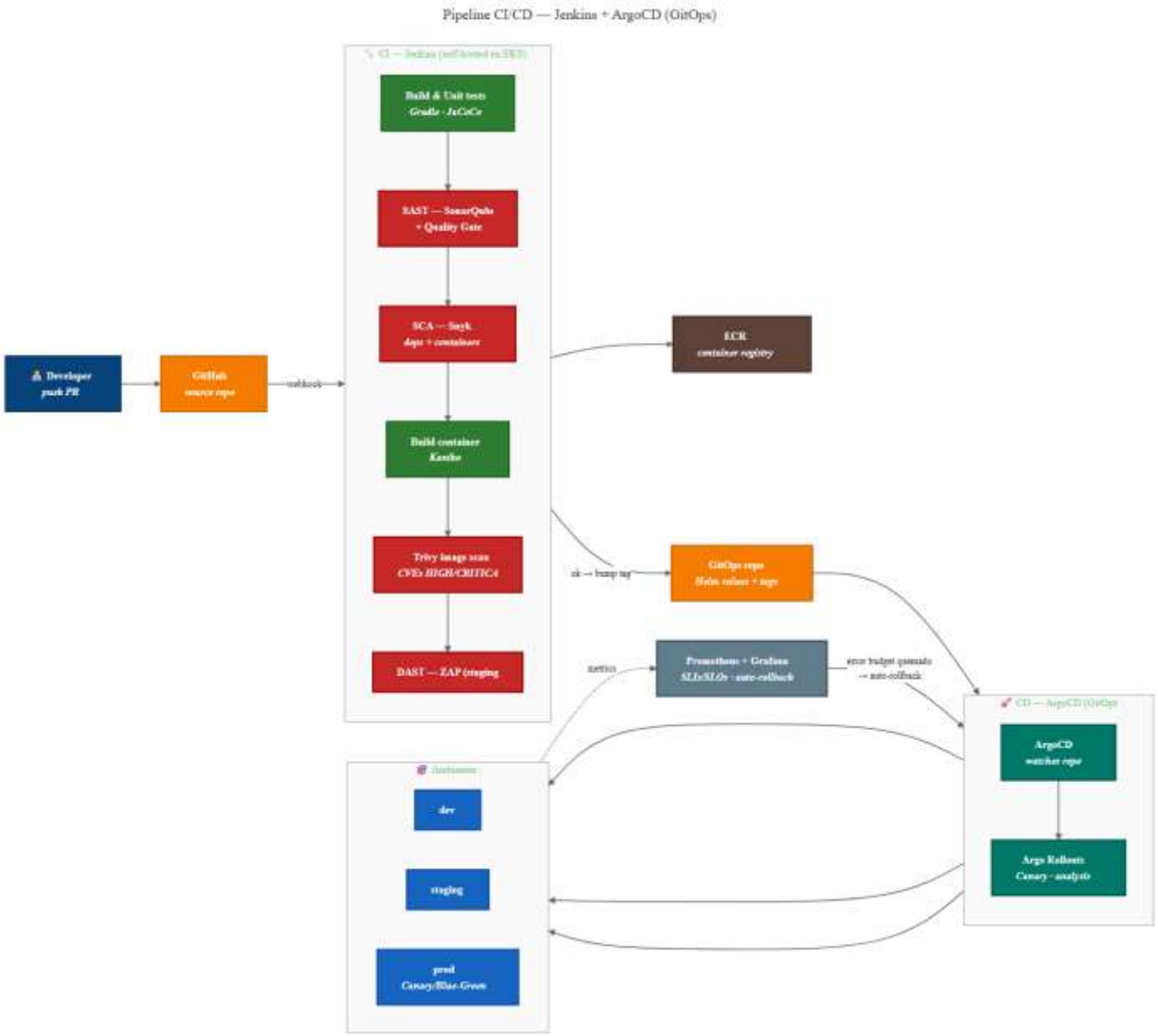
Runbooks versionados en Git por cada servicio (dependencias, SLIs, procedimiento de rollback, escalation path, last known good config). On-call con rotación semanal, 2 responders por semana (primary + secondary) y PagerDuty con escalation automática. Postmortems blame-free obligatorios para incidentes SEV2+.

---

9 CI/CD, GitOps y respaldos en cluster

9.1 Estrategia general

- **CI**: Jenkins declarative pipelines self-hosted en EKS.
- **CD**: ArgoCD (GitOps), con el estado deseado del cluster versionado en un repo Git separado del código fuente.
- **Branching**: Trunk-based development con feature flags.
- **Despliegue**: progressive delivery con **Canary** (Argo Rollouts) para servicios de bajo riesgo y **Blue/Green con approval manual** para servicios críticos (transferencias).
- **Respaldos**: Velero + snapshots EBS + backup lógico PostgreSQL + MinIO versionado.



Pipeline CI/CD — Jenkins + ArgoCD (GitOps)

9.2 Fases del pipeline Jenkins

1. **Checkout** del código.
2. **Build + unit tests** (Gradle, JaCoCo).
3. **SAST** — SonarQube + Quality Gate que aborta el pipeline si no se cumplen umbrales.
4. **SCA** — Snyk para dependencias y contenedores.
5. **Build container image** con Kaniko.
6. **Trivy image scan** (aborta si hay CVEs HIGH o CRITICAL).
7. **DAST** — OWASP ZAP contra staging.
8. **GitOps — bump tag** en el repo de manifiestos (PR automático o commit directo según política).

ArgoCD detecta el cambio en el repo GitOps y sincroniza al cluster objetivo según el ambiente (dev, staging, prod). Argo Rollouts gestiona canary/blue-green y ejecuta análisis automático con métricas de Prometheus — si el error rate supera el umbral o la latencia p95 degrada, ejecuta rollback automático.

9.3 Estrategias de despliegue por criticidad

- **Servicios de bajo riesgo (consultas read-only)**: Canary 10% → 25% → 50% → 100% con observabilidad en cada paso; rollback automático si error rate > 0.5% o latencia p95 > 2× baseline.
- **Servicios críticos (transferencias)**: Blue/Green con approval manual del tech lead; smoke tests automáticos en Green; switch atómico en el gateway; Blue permanece 24 h para rollback inmediato.
- **Infraestructura (Terraform)**: Plan en PR (comment automático con output); merge requiere 2 aprobaciones (arquitecto + DevOps lead); apply post-merge.

9.4 Respaldos en cluster

Velero para backup de Kubernetes (manifiestos + PVCs con snapshot EBS): diario full + horario incremental de recursos críticos; retención 30 días caliente, 90 días en S3 Glacier IA, 7 años en Glacier Deep Archive. Destino: bucket S3 dedicado con versioning + Object Lock. DR validado trimestralmente restaurando en región secundaria.

Bases de datos: Aurora PITR 35 días + snapshots semanales cross-region + export mensual a S3 en formato Parquet. DocumentDB PITR 7 días + snapshots cross-region. MinIO con versioning y replication a S3 en región secundaria.

Secretos: Vault snapshot automático cada hora a S3 cifrado con KMS; restore procedure documentado y probado mensualmente. Keycloak: export de realms en cada cambio (hook al pipeline) + backup de su PostgreSQL.

9.5 Métricas DORA

Objetivos al cierre del año 1: Deployment Frequency (varias veces por día — nivel *elite*); Lead Time for Changes (< 1 día); Change Failure Rate (< 5%); Mean Time to Recover (< 1 hora).

---

10 Planificación y simulación de tiempos

Este capítulo describe cómo se organiza el equipo, cómo se distribuye el trabajo en sprints, qué milestones marcan los puntos de control y cuánto tiempo estimamos que toma llegar a producción bajo tres escenarios (optimista, normal, pesimista) aplicando la técnica PERT. Se complementa con los capítulos 8 (CI/CD) y 10 (costos).

10.1 Marco metodológico

- **Scrum de equipos** + **SAFe-lite** (Scaled Agile Framework ligero) para coordinar múltiples squads cross-funcionales trabajando en paralelo. Alineación cada 2 semanas en Scrum of Scrums.
- **PMBOK 7** como capa de gobernanza del programa (steering committee, risk register, procurement, communication plan, stakeholder management), complementando el marco ágil de ejecución.
- **Sprints de 2 semanas**. **Incrementos de 3 meses** (6 sprints por incremento).
- **Event storming** con stakeholders de BP en Sprint 1 para validar bounded contexts y descartar el riesgo de "partición técnica disfrazada de DDD" (hallazgo del debate adversarial, ADR-01).
- **Rituales SAFe-lite**: PI Planning al inicio de cada incremento (1 día cross-squad), Scrum of Scrums 2× semana, review y retro por squad al final de cada sprint.

10.2 Organización del equipo

El proyecto se organiza en **6 squads cross-funcionales** + un equipo de plataforma transversal + un workstream regulatorio. La composición sigue las prácticas estándar de la industria para proyectos de banca digital en LATAM.

10.2.1 Diagrama organizacional

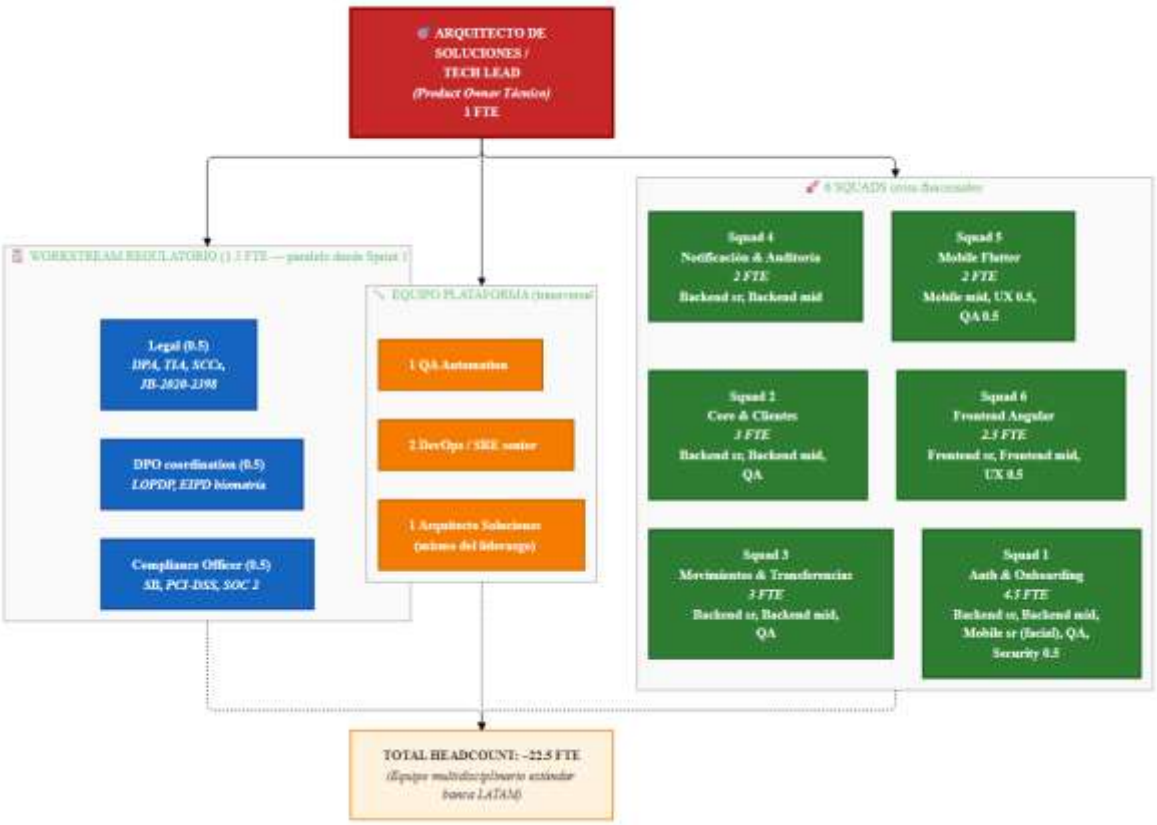


Diagrama organizacional del equipo del proyecto (~22.5 FTE)

10.2.2 Composición por squad

Squad	Roles	Headcount
Squad 1 — Auth & Onboarding	1 Backend senior, 1 Backend mid, 1 Mobile senior (para captura facial), 1 QA, 0.5 Security (part-time)	4.5
Squad 2 — Core & Clientes (customer-basic + customer-detail)	1 Backend senior, 1 Backend mid, 1 QA	3
Squad 3 — Movimientos & Transferencias	1 Backend senior, 1 Backend mid, 1 QA	3
Squad 4 — Notificación & Auditoría	1 Backend senior, 1 Backend mid	2
Squad 5 — Mobile Flutter	1 Mobile mid, 0.5 UX (compartido), 0.5 QA (compartido)	2

Squad	Roles	Headcount
Squad 6 — Frontend Angular	1 Frontend senior, 1 Frontend mid, 0.5 UX (compartido)	2.5
Platform (transversal)	2 DevOps/SRE, 1 QA Automation, 1 Arquitecto de Soluciones	4
Workstream Regulatorio	0.5 Legal, 0.5 Compliance Officer, 0.5 DPO (coordinación LOPDP)	1.5
Total headcount		**~22.5**

> **Nota de dimensionamiento**: la cifra de 22.5 es mayor al "16.5" del draft original porque incluye explícitamente el workstream regulatorio (requerido por el debate adversarial del ADR-05 — compliance JB-2020-2398) y refleja la realidad de banca regulada. El detalle de costos por rol se desarrolla en el Capítulo 10.

10.2.3 Workstream regulatorio

Trabaja en paralelo a los squads técnicos desde el Sprint 1. Responsabilidades:

- Formalización ante la **Superintendencia de Bancos (JB-2020-2398)** de proveedores cloud críticos (AWS como PaaS; IdP externo como servicio tecnológico).
- Preparación de **DPA (Data Processing Agreement)**, **Transfer Impact Assessment (TIA)** y SCCs con proveedores SaaS extranjeros (Microsoft Entra External ID si se elige, Veridas).
- **EIPD (Evaluación de Impacto a la Protección de Datos)** para el tratamiento biométrico del onboarding facial (requerido por LOPDP Art. 44).
- Coordinación de **pentest externo**, **auditoría SOC 2 Type I**, y preparación del ejercicio de certificación PCI-DSS si aplica.
- Comunicación con el regulador y preparación de documentación de respuesta a requerimientos.

10.3 Roadmap de alto nivel — 4 incrementos de 3 meses

10.3.1 Incremento 1 (Mes 1-3) — Fundación + validación

- **Objetivo**: landing zone AWS, CI/CD base, IdP corporativo configurado (Keycloak o Entra External ID), esqueletos de microservicios, SPA shell, app móvil shell. **Event storming con negocio validado**. **Workstream regulatorio arrancado**.
- **Milestone**: entorno de staging operativo con 1 microservicio "hello world" end-to-end; EIPD en borrador; notificación JB-2020-2398 en preparación.

10.3.2 Incremento 2 (Mes 4-6) — Core funcional

- **Objetivo**: flujo OAuth completo end-to-end (Authorization Code + PKCE S256), consulta datos cliente, consulta movimientos, notificaciones básicas, Cache-Aside sobre Redis, tracing distribuido.
- **Milestone**: flujo "login + ver mi saldo" funcional en staging, integrado con Core bancario simulado; **pentest #1** sobre el flujo de auth.

10.3.3 Incremento 3 (Mes 7-9) — Transferencias + onboarding + auditoría

- **Objetivo**: transferencias propias e interbancarias, onboarding facial completo con step-up AAL3, **auditoría inmutable sobre Aurora append-only + hash-chain HMAC + TSA RFC 3161 + anchor S3 Object Lock** (según ADR-11 revisado), crypto-shredding para LOPDP.
- **Milestone**: **pentest #2** (transacciones críticas); demo a negocio.

10.3.4 Incremento 4 (Mes 10-12) — Hardening + certificaciones + go-live

- **Objetivo**: performance testing (3× la carga esperada), DR drill multi-región, compliance audit (SOC 2, PCI-DSS si aplica), piloto con 1.000 usuarios reales.
- **Milestone**: **go-live con grupo piloto** → general availability (GA).

10.4 Plan de sprints — primeros 6 sprints detallados (Incremento 1 + Sprint 7 de Incr. 2)

10.4.1 Sprint 1 (semanas 1-2) — Setup + event storming

Squad / Workstream	Entregables
Platform	AWS Landing Zone, cuentas (dev/staging/prod), VPC multi-AZ, EKS clusters base (3 AZs)
Squad 1	Setup Keycloak en K8s + realms iniciales (CIAM retail + Workforce separados); alternativamente iniciar PoC con Entra External ID
Squad 2	Repos de microservicios base (Spring Boot 3 template + DDD skeleton)
Squad 3	Repos y templates; integración simulada con Core
Squad 4	Repos y templates; estructura tablas outbox y audit_ledger (append-only)
Squad 5	Setup Flutter, pipeline de build Android/iOS, design system móvil base
Squad 6	Setup Angular + Nx monorepo, design system base (tokens BP + Angular Material)

Squad / Workstream	Entregables
Arquitectura	**Event storming con negocio BP** (2 sesiones) para validar bounded contexts de los 8 microservicios propuestos
Workstream Regulatorio	Arranque notificación JB-2020-2398, draft DPA/TIA con proveedores, draft EIPD

10.4.2 Sprint 2 (semanas 3-4) — CI/CD y observabilidad

Squad / Workstream	Entregables
Platform	Jenkins declarativo + ArgoCD (GitOps), Prometheus+Grafana, ELK (Elasticsearch, Logstash, Kibana), Jaeger
Squad 1	Configuración OAuth 2.0 (Authorization Code + PKCE S256) en el IdP; endpoints de JWKS cache
Squad 2	Microservicio `customer-basic-service` (esqueleto + health check + Spring Actuator)
Squad 3	Microservicio `movements-service` (esqueleto)
Squad 4	Microservicio `notification-service` (esqueleto); setup de RabbitMQ en K8s
Squad 5	Primeras pantallas Flutter (splash, login mockup, navegación básica)
Squad 6	Primeras pantallas Angular (login mockup, dashboard mock, autenticación mockeada)
Workstream Regulatorio	Primera reunión con SB para presentar scope; coordinación con área legal interna

10.4.3 Sprint 3 (semanas 5-6) — Service discovery K8s + Gateway + MinIO

Squad / Workstream	Entregables
Platform	**Spring Cloud Gateway** desplegado; **Kubernetes-native service discovery** (CoreDNS + Services + Spring Cloud LoadBalancer) **—reemplazo del Eureka inicialmente planeado** (ver ADR-02 revisado); MinIO cluster desplegado
Squad 1	Flujo OAuth funcional end-to-end desde SPA (login real contra IdP); introspection endpoint integrado
Squad 2	Integración simulada con Core bancario (mocks WireMock + contratos OpenAPI documentados)
Squad 3	Modelo de datos movimientos, primeras queries, repositorios JPA

Squad / Workstream	Entregables
Squad 4	Integración RabbitMQ + SES (envío email básico); estructura outbox
Squad 5	Login real contra IdP desde Flutter (flutter_appauth con PKCE)
Squad 6	SPA consume `customer-basic-service` via Gateway; BFF ligero con session management

10.4.4 Sprint 4 (semanas 7-8) — Movimientos + cache + mTLS

Squad / Workstream	Entregables
Platform	Redis Cluster, Amazon MSK (Kafka) cluster, observabilidad de brokers; **mTLS intra-cluster con cert-manager** (ADR-01 fix)
Squad 1	MFA (TOTP) + biometría local en móvil (huella/FaceID); refresh token rotation configurado
Squad 2	**Cache-Aside sobre Redis** con TTL diferencial (5/30/1440 min); invalidación por eventos
Squad 3	Consulta de movimientos paginada, caching, idempotency keys
Squad 4	**Outbox pattern** con Debezium CDC → Kafka → consumer notification
Squad 5	Pantalla de movimientos funcional en móvil
Squad 6	Pantalla de movimientos funcional en SPA + skeleton loading

10.4.5 Sprint 5 (semanas 9-10) — Onboarding facial + auditoría inmutable

Squad / Workstream	Entregables
Platform	Vault para secretos (HA con Raft 3 nodos), WAF rules custom, Shield rules
Squad 1	**Onboarding facial completo**: liveness + match contra cédula (POC con AWS Rekognition + fallback Veridas para alta certificación)
Squad 2	Servicio `customer-detail-service` (consulta detallada), integrado
Squad 3	Validaciones de negocio en transferencias (saldo, límites, cutoffs horarios)
Squad 4	**Auditoría inmutable sobre Aurora append-only + hash-chain HMAC + TSA RFC 3161** (patrón ADR-11 revisado — reemplazo de QLDB deprecado); crypto-shredding para LOPDP
Squad 5	Flujo de onboarding en app móvil (3 pantallas + captura facial con feedback de liveness)
Squad 6	Panel de operaciones (consulta de auditoría)

Squad / Workstream	Entregables
Workstream Regulatorio	EIPD aprobada por DPO; validación ante SB del vendor biométrico

10.4.6 Sprint 6 (semanas 11-12) — Demo integración + hardening + anchor S3

Squad / Workstream	Entregables
Platform	**DR drill #1** (failover Aurora Multi-AZ), chaos engineering con LitmusChaos, **anchor diario a S3 Object Lock modo Compliance**
Squad 1	SSO entre SPA y mobile funcionando; **back-channel logout RFC 8414** implementado
Squad 2	Documentación OpenAPI completa de servicios; consumer-driven contracts con Pact
Squad 3	**Transferencia propia end-to-end** (débito + crédito + auditoría + notificación)
Squad 4	WhatsApp notifications (Twilio BSP) + SMS fallback (SNS)
Squad 5	Transferencia desde móvil con step-up AAL3 por OTP
Squad 6	Transferencia desde SPA con step-up AAL3

Demo al negocio al final del Sprint 6: flujo completo de usuario nuevo = onboarding facial → login → ver saldo → ver movimientos → transferir (con step-up OTP) → recibir notificación multicanal → auditoría inmutable registrada con hash-chain + TSA.

10.5 Simulación de tiempos de entrega — PERT con 3 escenarios

Modelo de estimación basado en **PERT (Program Evaluation and Review Technique)**:

Duración estimada = (Optimista + 4 × Normal + Pesimista) / 6

10.5.1 Variables que modelan los escenarios

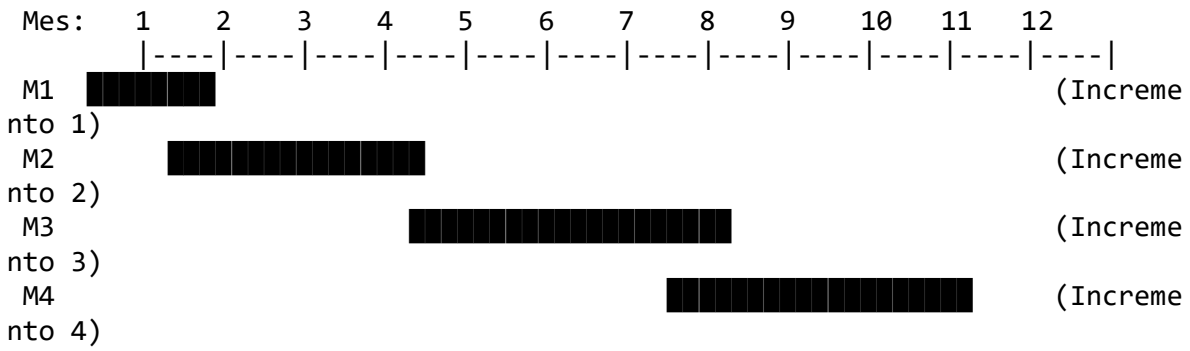
Variable	Optimista	Normal	Pesimista
Nivel del equipo (seniority)	70% senior, 30% mid	40% senior, 40% mid, 20% junior	20% senior, 40% mid, 40% junior
Rotación esperada durante el proyecto	5%	15%	30%
Bloqueos externos (core bancario, auth corporativo)	Bajos, respuesta en 2 días	Medios, respuesta en 5 días	Altos, respuesta en 10+ días

Variable	Optimista	Normal	Pesimista
Cambios de alcance (scope creep)	Ninguno	1-2 cambios menores	3+ cambios, al menos 1 mayor
Calidad de requerimientos del negocio	Claros, documentados	Moderadamente claros, iterativos	Ambiguos, reactivos
Experiencia previa del equipo con el stack	Alta (ya usó Spring Cloud + K8s)	Media (conoce Spring Boot, aprende K8s)	Baja (curva fuerte en 2+ tecnologías)
Disponibilidad de ambientes (dev/staging/prod)	Día 1	Semana 2	Semana 4+
Respuesta del regulador (SB) a notificaciones	Expedita (<1 mes)	Normal (2-3 meses)	Lenta (4-6 meses)

10.5.2 Resultados por milestone

Milestone	Optimista	Normal (PERT)	Pesimista
M1 — Fundación (landing zone + CI/CD + SSO + event storming)	6 sem	**10 sem**	16 sem
M2 — Core funcional (login + consulta end-to-end)	11 sem	**22 sem**	34 sem
M3 — Transferencias + Onboarding facial + Auditoría	18 sem	**34 sem**	50 sem
M4 — Go-live piloto (1.000 usuarios, hardening, compliance)	24 sem (~6 meses)	**44 sem (~11 meses)**	64 sem (~16 meses)
M5 — General Availability (rollout completo)	28 sem (~7 meses)	**52 sem (12 meses)**	76 sem (~19 meses)

10.5.3 Gantt resumido — escenario Normal



M5 ▓▓▓▓▓▓▓ (GA)

Workstream Regulatorio ▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓▓ (continuo)

10.5.4 Riesgos específicos del escenario Normal → Pesimista (y cómo evitarlos)

Riesgo	Impacto si ocurre	Mitigación temprana
Core bancario no documentado o inestable	+4 semanas por servicio	Spikes técnicos Sprint 1, SLA interno BP ≤48h respuesta
Nuevo control regulatorio SB durante proyecto (ej. tokenización obligatoria)	+6-8 semanas	Workstream regulatorio desde Sprint 1, relación proactiva con SB
Falla del equipo clave de seguridad / DevOps	+4 semanas de knowledge transfer	ADRs documentadas, pair programming, bus factor ≥2 por área
Vendor de reconocimiento facial no certificado localmente	+4 semanas re-trabajo	Dual vendor desde día 1 (Rekognition + Veridas)
Performance detectado tarde	+3-6 semanas refactor	Load testing con 3× el volumen esperado desde Sprint 4
Lentitud de la SB en la aprobación JB-2020-2398	Bloquea go-live	Workstream regulatorio desde Sprint 1, no en el último incremento

10.5.5 Mitigaciones para mantenernos en Normal

- **Spikes técnicos obligatorios** en Sprint 1 para los 4 componentes más riesgosos: reconocimiento facial, OAuth step-up, auditoría con hash-chain + TSA, integración con el Core bancario.
- **Buffer de 15%** en cada sprint (reservar 3 de 20 story points típicos).
- **Dual-track seguridad**: pentest en Mes 4 y Mes 7, no esperar al final (fail-early).
- **UX validada antes de build** (lo-fi → hi-fi → prototipo clickable con 5-8 usuarios reales).
- **Contrato interno con BP** para SLA de respuesta sobre consultas al Core bancario (máx 48h hábiles).
- **Workstream regulatorio arrancado el Sprint 1** — no al final.

10.6 Rituales

- **Daily stand-up**: 10 min por squad

- **Scrum of Scrums**: 2× semana (martes/jueves), 20 min — tech leads + arquitecto
- **PI Planning**: 1 día cross-squad al inicio de cada incremento (cada 3 meses)
- **Planning de sprint**: 2 h por squad al inicio del sprint
- **Review**: 1 h cross-squad al fin de sprint (demo)
- **Retro**: 1 h por squad al fin de sprint; 1 h cross-squad cada 2 sprints
- **Architecture sync**: 1 h semanal con arquitecto + tech leads
- **Security review**: cada 2 sprints — security officer + arquitecto + tech leads
- **Regulatory sync**: 1 h quincenal — workstream regulatorio + arquitecto + legal BP

10.7 Supuestos del modelo

- Semanas calendario con sprints de 2 semanas.
- Equipo full-time, feriados y vacaciones estándar en Ecuador (~22 días/año/persona).
- Trabajo concurrente de 6 squads + plataforma + workstream regulatorio (no serializado).
- Fecha de inicio real a confirmar con BP.

10.8 Nota sobre la validez de las estimaciones

Toda estimación de proyectos de software es inherentemente incierta. El valor de este modelo no es "acertar la fecha" sino **hacer visible el rango** y permitir decisiones informadas sobre:

- Qué recortar si el escenario se desvía a pesimista.
- Dónde invertir en mitigaciones tempranas.
- Cuándo comunicar al negocio que el deadline está en riesgo.

Referencias bibliográficas: Fred Brooks, *The Mythical Man-Month* (1975); Steve McConnell, *Software Estimation: Demystifying the Black Art* (2006); PMI, *Guía del PMBOK* 7ª ed. (2021); Dean Leffingwell, *SAFe 6.0 Reference Guide* (2023).

---

11 Costos — mensual, trimestral, anual y TCO

Este capítulo desglosa el costo total de propiedad (TCO) del sistema propuesto en los tres rubros principales (infraestructura cloud, licencias y servicios de terceros, personal del equipo) por **escenario de carga** y por **horizonte temporal**. Las cifras son estimaciones basadas en el pricing público de AWS (región `us-east-1`, fecha de corte 2026-11) y rangos salariales LATAM. Deben revalidarse con AWS Pricing Calculator y con BP durante el dimensionamiento real.

11.1 Metodología

- **Escenario base**: 500k–1M MAU, pico 500–2.000 TPS, SLA 99.95% (ver supuestos del Capítulo 1).
- **Pricing AWS**: on-demand como piso, ajustado con Reserved Instances 1-año (ahorro típico 30-40%) y Savings Plans donde aplica.
- **Personal**: salarios totales (brutos empleador + cargas sociales ≈ 1.4× bruto trabajador) a tarifas de mercado Ecuador/LATAM 2026.
- **Separación de planos de identidad** (según ADR-05 revisado): CIAM retail (alto volumen MAU) separado de Workforce (operadores internos, licencias por usuario/mes).
- **Alineación con Cap 4 revisado**: sin QLDB (reemplazado por Aurora append-only + HMAC + TSA), sin Eureka (reemplazado por K8s-native discovery).

11.2 1. Infraestructura AWS (mensual) — escenario objetivo 500k–1M MAU

Componente	Configuración	USD /mes
EKS cluster (control plane)	1 clúster producción + 1 staging	146
EC2 nodos EKS (compute app)	14 nodos m5.xlarge reserved 1-año (8 microservicios × 2-3 réplicas × 3 AZs + margen)	1.600
Aurora PostgreSQL	db.r6g.xlarge Multi-AZ writer + 2 read replicas (operacional + audit ledger append-only)	2.100
DocumentDB (Mongo-compatible)	db.r6g.large × 2	750
Amazon MSK (Kafka)	3 brokers kafka.m7g.large	850
ElastiCache Redis	cache.r6g.large cluster mode, 3 shards con réplicas	540
S3 (archive + static + anchor ledger)	3 TB, 15M requests, Glacier Deep Archive lifecycle	95
Amazon OpenSearch	cluster 3 masters t3.small + 3 data nodes r6g.large	1.100
API Gateway (AWS edge)	30M requests/mes	105
AWS WAF + Shield Standard	ruleset managed + custom rules	75
CloudFront (CDN para SPA)	1 TB transfer/mes	110
Route 53	zona + health checks + Global DNS failover	30
AWS Rekognition (Face	~15k verificaciones/mes onboarding	225

Componente	Configuración	USD /mes
Liveness)		
SES (email)	1M emails/mes transaccionales	100
SNS (push + SMS)	500k push + 100k SMS	780
CloudWatch Logs + Metrics	300 GB ingestion + retención 90 días caliente	230
Data transfer (egress + cross-AZ)	2.5 TB egress + chatty microservices cross-AZ	240
Secrets Manager	60 secretos	24
KMS	25 keys + operaciones	50
VPC endpoints + NAT Gateways	3 NAT GW (uno por AZ) + endpoints	330
Backup (RDS/EBS/EFS snapshots)	1.5 TB snapshots + cross-region	180
DR Pilot Light us-west-2	recursos mínimos pre-provistos (Aurora reader + EKS idle + buckets)	850
Subtotal AWS		**~10.510**

11.3 2. Licencias y servicios de terceros (mensual)

11.3.1 2.A — Opción A: IdP CIAM con Microsoft Entra External ID

Componente	USD/mes	Comentario
Entra External ID (CIAM retail)	**18.000 – 30.000**	Tier premium con MFA + Conditional Access, para 500k–1M MAU
Entra ID P1 (workforce 50 operadores internos)	300	Para SSO corporativo interno
Veridas (reconocimiento facial certificado — fallback)	1.500	Alternativa a Rekognition para casos de alto riesgo
WhatsApp Business API (Twilio BSP)	400	Notificaciones por WhatsApp a clientes
GitHub Enterprise Cloud	210	10 licencias × $21/mes (repos + CodeQL + Actions)
SonarCloud / SonarQube Enterprise	150	Calidad de código y SAST
Snyk (SCA + container scan)	300	Dependencias y contenedores

Componente	USD/mes	Comentario
HashiCorp Vault OSS	0	Self-hosted en K8s
PagerDuty / OpsGenie	300	On-call para equipo DevOps
DigiCert TSA (Timestamping Authority RFC 3161)	150	Para anchor del ledger de auditoría
Subtotal 2.A (Entra External ID)	**~21.110–32.610**	

11.3.2 2.B — Opción B: IdP CIAM con Keycloak (self-hosted)

Componente	USD/mes	Comentario
Keycloak OSS (self-hosted en K8s)	0	Open-source; infra ya contabilizada en Aurora + EKS
Red Hat SSO support (opcional)	1.500	Suscripción enterprise para SLA de parches
(Resto idéntico a opción 2.A excluyendo Entra)		
Veridas	1.500	
WhatsApp BSP	400	
GitHub Enterprise Cloud	210	
SonarCloud	150	
Snyk	300	
PagerDuty	300	
DigiCert TSA	150	
Subtotal 2.B (Keycloak)	**~4.510**	

La **diferencia principal entre 2.A y 2.B** es el proveedor de identidad CIAM. La elección depende de la estrategia de BP — ver ADR-05 revisado.

11.4 3. Personal mensual

Equipo de 22.5 FTE según Cap 9. Tarifas de mercado Ecuador/LATAM 2026 (totales incluyendo cargas sociales empleador ≈ 1.4× bruto trabajador).

Rol	Headcount	USD/mes por persona	Subtotal

Rol	Headcount	USD/mes por persona	Subtotal
Arquitecto de Soluciones / Tech Lead	1	5.500	5.500
Tech Leads backend	2	5.000	10.000
Backend senior (Spring Boot 3)	3	4.000	12.000
Backend mid	3	2.800	8.400
Frontend senior (Angular)	1	3.800	3.800
Frontend mid	1	2.500	2.500
Mobile senior (Flutter)	1	4.000	4.000
Mobile mid	1	2.700	2.700
DevOps / SRE senior	2	4.500	9.000
QA Automation senior	1	3.500	3.500
QA Manual	2	2.200	4.400
Security Officer (part-time)	0.5	5.000	2.500
UX / UI Designer	1	3.200	3.200
Product Owner / Scrum Master	1	3.800	3.800
Workstream Regulatorio: Legal part-time	0.5	4.500	2.250
Workstream Regulatorio: Compliance Officer	0.5	4.000	2.000
Workstream Regulatorio: DPO coordination	0.5	4.500	2.250
Total headcount	**22.5**		**~81.800**

11.5 4. Gran total mensual (dos escenarios de IdP)

Rubro	Opción A (Entra External ID)	Opción B (Keycloak)
Infraestructura AWS	10.510	10.510
Licencias y terceros	21.110–32.610	4.510
Personal	81.800	81.800
Imprevistos (10%)	11.342–12.492	9.682
TOTAL MENSUAL	**~124.762–137.412**	**~106.502**

11.6 5. Costos por escenario de carga (orden de magnitud)

El costo escala con el volumen de usuarios, principalmente por la licencia CIAM MAU-based y por la infraestructura cloud elástica. El personal tiene un piso irreducible (~15 personas mínimo) y no escala tan lineal.

Escenario	MAU	TPS pico	SLA	Costo mensual (Opción A Entra)	Costo mensual (Opción B Keycloak)
Piloto / MVP	1.000	10	99.0%	~45.000	~40.000
Pequeña escala	10.000	50	99.5%	~60.000	~55.000
Mediana escala	100.000	500	99.9%	~80.000	~75.000
Escenario objetivo	**500k–1M**	**500–2.000**	**99.95%**	**~125k–137k**	**~106k**
Escala media mercado EC	2M–3M	5.000	99.95%	~180k–230k	~140k
Escala masiva	5M+	15.000	99.99%	~320k–400k	~230k

> **Observación crítica**: la diferencia entre Opción A y Opción B se amplifica a mayor escala porque el pricing de Entra External ID es MAU-based. A 5M MAU el ahorro con Keycloak puede justificar fácilmente los 2 FTE adicionales de SRE dedicado.

11.7 6. Costos por horizonte temporal — escenario objetivo

Horizonte	Opción A (USD)	Opción B (USD)
Mensual (operación)	124.762–137.412	106.502
Trimestral	374.286–412.236	319.506
Anual (operación)	1.497.144–1.648.944	1.278.024
Costos únicos año 1 (ver sección 7)	230.000	220.000
TOTAL AÑO 1	**~1.727.000–1.879.000**	**~1.498.000**
TCO a 3 años	**~5.100.000–5.500.000**	**~4.000.000**

11.8 7. Costos únicos de construcción — año 1

Costos no recurrentes de arranque, auditorías externas y certificaciones.

Concepto	USD

Concepto	USD
Setup cuentas AWS + landing zone (Control Tower + Terraform base)	5.000
Certificación PCI-DSS (QSA assessment inicial)	30.000
Auditoría SOC 2 Type I	20.000
Pentests externos (3 durante el año: auth, transacciones, infra)	45.000
Capacitación del equipo (K8s, Spring Cloud, AWS, DDD, Mermaid)	20.000
Licencias de software iniciales (Jira, Confluence, Figma, Miro)	10.000
Setup Veridas + onboarding integración	12.000
Diseño UX/UI completo + sistema de diseño	30.000
Consultoría de seguridad y hardening	25.000
Workstream regulatorio año 1: DPA/TIA, EIPD, notificación JB-2020-2398, legal fees	25.000
Setup inicial Vault + HSM si aplica	8.000
TOTAL ÚNICOS AÑO 1	**~230.000**

En la Opción B (Keycloak) se restan ~10k del setup Entra inicial, dando ~220k.

11.9 8. Proyección a 3 años — ambas opciones

Año	Opción A (USD)	Opción B (USD)
Año 1 (incluye únicos)	1.727.000–1.879.000	1.498.000
Año 2 (operación + 5% inflación + reauditorías)	1.620.000–1.780.000	1.390.000
Año 3 (operación + 5% + maintenance)	1.700.000–1.870.000	1.460.000
TCO 3 años	**5.050.000–5.530.000**	**~4.350.000**

Diferencia 3 años: ~USD 700.000–1.180.000 a favor de Opción B (Keycloak). Suficiente para justificar el costo adicional de 2 FTE SRE dedicados (~USD 150-200k adicional). La decisión final debe considerar: estrategia de BP sobre proveedores, apetito operativo, continuidad en caso de rotación de SRE.

11.10 9. Comparativa con las alternativas descartadas en Cap 3

Alternativa	Costo mensual estimado (500k–1M MAU)	TCO 3 años	Comentario
Alt. A — Cloud-native AWS pura (descartada)	~95.000–115.000	~3.600.000	Menor costo por delegar operación a AWS; vendor lock-in alto
Alt. B — Híbrida K8s + Spring Cloud (elegida, opción Keycloak)	~106.000	~4.350.000	Diferencia ~750k en 3 años frente a Alt. A; justificada por portabilidad y evitar lock-in
Alt. B (opción Entra External ID)	~125.000–137.000	~5.100.000 – 5.500.000	Más caro por la licencia CIAM MAU-based; menor carga operativa
Alt. C — Serverless-first AWS (descartada)	~85.000–95.000	~3.100.000	Menor costo variable pero lock-in extremo y gaps funcionales para banca

11.11 10. Composición del gasto (escenario objetivo)

Rubro	% del total (Opción A)	% del total (Opción B)
Personal	~60%	~65%
Licencias y terceros (IdP + facial + resto)	~18%	~5%
Infraestructura cloud	~9%	~10%
Imprevistos	~10%	~10%

> **Lectura**: en ambas opciones el **personal es el componente mayoritario**. Optimizar infra tiene retorno acotado; optimizar productividad del equipo (herramientas, automatización, documentación) tiene retorno mucho mayor.

11.12 11. Palancas de optimización (reducción potencial de 20-35%)

1. **Reserved Instances + Savings Plans** sobre compute EC2 y RDS: ahorro de 30-50% comprometiendo 1-3 años.

2. **Spot Instances** para workloads no críticos (batch, CI/CD runners, dev/staging): ahorro hasta 70%.
3. **S3 Intelligent-Tiering** para logs y auditoría archive: ahorro 20-40% vs S3 Standard.
4. **Log sampling y compactación** antes de ingerir a CloudWatch: los logs son uno de los costos ocultos más grandes a escala.
5. **Autoescalado agresivo** fuera de horario laboral para ambientes no-prod (apagar dev/staging fines de semana y de noche).
6. **Cold storage para auditoría > 1 año** con S3 Glacier Deep Archive ($0.00099/GB/mes).
7. **Nearshoring / híbrido** para optimizar costo de personal manteniendo zona horaria compatible.
8. **FinOps como práctica**: Cost Explorer alerts, tagging obligatorio por equipo/producto, chargeback interno, revisión mensual.
9. **Evaluar Aurora Serverless v2** para ambientes no-prod y para servicios con carga muy variable.
10. **Negociación de descuento enterprise** con AWS (Enterprise Discount Program) a partir de USD 100k/mes de gasto comprometido.

11.13 12. Nota sobre validez de las estimaciones

Las cifras anteriores son **órdenes de magnitud** con precisión aproximada ±20%. El dimensionamiento final requiere:

- AWS Pricing Calculator con la configuración específica del diseño detallado por microservicio.
- Validación de salarios reales con el área de RRHH de BP o partner externo.
- Confirmación del modelo de contratación de proveedores de terceros (anual vs mensual, descuento por volumen).
- Decisión final de BP sobre Opción A (Entra External ID) vs Opción B (Keycloak) según su estrategia.

Referencias: AWS Pricing (aws.amazon.com/pricing), Entra External ID Pricing (azure.microsoft.com/pricing/details/active-directory-external-identities/), rangos salariales Glassdoor/Computrabajo Ecuador 2026.

---

12 Riesgos y mitigaciones

Este capítulo registra los riesgos identificados del proyecto y de la arquitectura, con su probabilidad, impacto, nivel de riesgo (P × I), mitigación propuesta y responsable

asignado. La matriz se mantiene viva durante toda la ejecución; se revisa quincenalmente en el Scrum of Scrums y mensualmente en el steering committee.

12.1 Metodología

- **Probabilidad (P)**: escala 1 (muy baja) – 5 (muy alta).
- **Impacto (I)**: escala 1 (muy bajo) – 5 (muy alto).
- **Nivel de Riesgo (R) = P × I**: 1-6 (bajo), 8-12 (medio), 15-25 (alto).
- **Mitigación**: acciones concretas preventivas (reducen probabilidad) o de contingencia (reducen impacto).
- **Responsable**: rol o squad accountable del seguimiento.

12.2 Matriz de riesgos — 28 riesgos identificados

ID	Riesgo	P	I	R	Mitigación	Responsable
R01	Core bancario con API no documentada o inestable	4	5	**20**	Spike técnico Sprint 1, contratos OpenAPI + mocks WireMock, SLA interno con BP ≤48h, modo degradado con cache	Arquitecto + PO Core BP
R02	Falla del reconocimiento facial con alto false-rejection rate	3	4	**12**	Dual vendor (Rekognition + Veridas), fallback a verificación manual en sucursal, telemetría de match confidence	Squad 1 + Seguridad
R03	Rotación de ingenieros clave (bus factor)	4	4	**16**	Pair programming, ADR culture obligatoria, documentación como entregable, bus factor ≥2 por área, retención salarial competitiva	HR + Tech Lead
R04	Ataque DDoS en lanzamiento	2	5	**10**	AWS Shield Advanced (opcional), WAF rate limiting, autoescalado agresivo,	Secur

ID	Riesgo	P	I	R	Mitigación	Responsable
					plan de respuesta documentado	ity + DevOps
R05	Breach de datos personales → sanción LOPDP	1	5	**5**	Cifrado at-rest + in-transit, acceso mínimo, pentests trimestrales, EIPD, DPO, plan de respuesta a incidentes (72h notificación)	DPO + Security
R06	Nueva normativa de la Superintendencia durante el proyecto	3	3	**9**	Buffer 15% en cada sprint, arquitectura flexible, relación proactiva con SB desde Sprint 1 via workstream regulatorio	Arquitecto + Legal
R07	Fraude masivo coordinado	2	5	**10**	Reglas antifraude, ML scoring, MFA step-up AAL3 para operaciones críticas, límites dinámicos, monitoreo 24/7	Antifraude + Security
R08	Caída prolongada de un servicio AWS (región o servicio managed)	2	4	**8**	Multi-AZ obligatorio, DR Pilot Light multi-región us-west-2, chaos engineering mensual, Game Day trimestral	DevOps/SRE
R09	Costo cloud se desvía > 30% del budget	3	3	**9**	FinOps: Cost Explorer alerts, tagging obligatorio por equipo/producto, revisión mensual, Savings Plans + Reserved Instances	Arquitecto + Finan

ID	Riesgo	P	I	R	Mitigación	Responsables
R10	Rendimiento no cumple en picos de nómina	3	4	**12**	Load testing con 3× volumen esperado antes de GA, plan de scale-out documentado, load shedding automático	DevOps + Squad 3
R11	IdP mal configurado → vulnerabilidad de auth	2	5	**10**	Hardening con checklist por vendor (Keycloak o Entra), pentest específico de auth, review por experto externo, back-channel logout RFC 8414	Squad 1 + Security
R12	Scope creep del negocio (nuevas features mid-project)	4	3	**12**	Change Control Board, backlog priorizado, trade-off explícito tiempo/alcance, PMBOK governance	PM + Stakeholders
R13	Infraestructura expuesta por mala configuración (S3 abierto, SG permisivo)	2	5	**10**	AWS Config rules, GuardDuty, Prowler scanner semanal, review obligatorio de PRs Terraform (2 aprobadores)	DevOps + Security
R14	Datos corruptos vienen del Core bancario	2	4	**8**	Schema validation a la entrada, Dead Letter Queue, alertas, reconciliación diaria con reportes del Core	Squad 2
R15	Ledger de auditoría corrompido o alterable	1	5	**5**	Aurora append-only (triggers que impiden UPDATE/DELETE) + hash-chain HMAC + TSA RFC 3161 + anchor S3 Object Lock modo Compliance + separación de duties (clave HMAC en	Arquitecto +

ID	Riesgo	P	I	R	Mitigación	Responsable
					Vault)	Compliance
R16	SPA o móvil con vulnerabilidad XSS / supply chain	3	4	**12**	CSP strict, SRI, SCA (Snyk) obligatorio en pipeline, Dependabot, review de deps nuevas, bug bounty opcional	Squads 5/6 + Security
R17	Pérdida de datos por bug en migration	2	5	**10**	Flyway/Liquibase versionado, dry-run en staging, backup pre-migration automático, rollback script probado	Todos los squads
R18	Lentitud / caída del IdP OAuth externo	2	4	**8**	Circuit breaker, cache local de JWKS, timeout agresivo, fallback a modo degradado (consulta sin step-up)	Squad 1
R19	Problemas de certificación de la app móvil (Apple/Google)	2	4	**8**	Feedback loop temprano con tiendas, rollout escalonado (TestFlight/Internal track), compliance review de permisos	Squad 5
R20	Vendor lock-in oculto pese a estrategia híbrida	2	4	**8**	Audit regular de servicios AWS usados vs. alternativos, portable-first en código, prueba de restore cross-cloud trimestral	Arquitecto
R21	**Deprecación de servicio cloud propietario crítico** (ej. QLDB	3	4	**12**	Preferir componentes open-source o estándares abiertos para el core; monitoreo activo de roadmap de vendors; fecha-check anual del stack; ADR de reemplazo pre-planeado	Arquitecto + De

ID	Riesgo	P	I	R	Mitigación	Responsable
	deprecado AWS 2024)					vOps
R22	**Costo CIAM MAU-based escala descontroladamente** (Entra External ID)	3	3	**9**	Monitoreo mensual del costo/MAU; alertas al superar umbrales; evaluación semestral vs Opción B (Keycloak); negociación enterprise con Microsoft a partir de 500k MAU	Arquitecto + Finanzas
R23	**Contradicción LOPDP Art. 12 (supresión) vs ledger inmutable**	2	5	**10**	Crypto-shredding (clave por titular en Vault; destruir clave = PII ilegible, chain intacto); tokenización de identificadores; base legal Art. 12 num. 2 (retención obligatoria SB) para evidencia regulatoria	DPO + Arquitecto + Legal
R24	**Lentitud regulatoria SB en aprobación de proveedores cloud (JB-2020-2398)**	4	4	**16**	Workstream regulatorio activo desde Sprint 1 (no al final); relación proactiva con SB; preparación anticipada de DPA, TIA, plan de salida	Compliance Officer + Legal
R25	**Latencia acumulativa por 8 microservicios chatty** (RNF-02 p95 <2s)	3	4	**12**	Budget de latencia explícito por servicio; topology-aware routing (misma AZ); BFF para agregación; Cache-Aside Redis; APM con tracing distribuido (OpenTelemetry + Jaeger)	Arquitecto + DevOps

ID	Riesgo	P	I	R	Mitigación	Responsable
R26	**Token JWT comprometido vive hasta expiración** (sin revocation real-time)	2	4	**8**	TTL corto 5-10 min; refresh token rotation con reuse detection; introspection endpoint obligatorio para AAL3; blocklist Redis sincronizada con eventos del IdP	Squad 1 + Security
R27	**Hash-chain del ledger roto por replay o duplicados**	2	5	**10**	Partition key = aggregate_id en Kafka; consumer idempotente; verificación automática del chain cada 6h; alerta inmediata si rompe; procedimiento documentado de reconciliación forense	Squad 4 + Arquitecto
R28	**Microservicios como sobre-ingeniería no justificada** (riesgo "resume-driven architecture")	2	3	**6**	Event storming con negocio Sprint 1 valida bounded contexts; sección explícita del ADR-01 "por qué no monolito modular" preparada para defensa; opción de fusionar servicios si event storming lo justifica	Arquitecto + PO

Totales: 28 riesgos identificados. 2 de nivel alto (R≥15), 13 de nivel medio (R=8-12), 13 de nivel bajo (R≤6).

12.3 Riesgos TOP 6 por prioridad (R ≥ 12)

12.3.1 R01 — Core bancario inestable (R=20)

Mayor riesgo del proyecto por dependencia dura. **Plan de contingencia**: si el Core no responde dentro del SLA, se activa modo degradado: lecturas servidas desde Cache-Aside Redis (datos pueden tener hasta 30 min de desactualización), eventos de escritura encolados en el outbox + RabbitMQ con reintento exponencial, comunicación clara al cliente ("estamos actualizando tus datos, en breve verás el resultado"). Game Day semestral simulando caída del Core.

12.3.2 R03 — Rotación de ingenieros clave (R=16)

Mitigación cultural obligatoria: - **ADR culture**: toda decisión significativa queda documentada; decisiones sin ADR no se mergean. - **Pair programming** mandatorio para onboarding (primeras 2 semanas de cada nuevo ingeniero). - **Bus factor ≥2** por área crítica (auth, audit, transfer): nunca un solo ingeniero domina un componente. - **Rotación planificada de ownership**: cada 6 meses los tech leads rotan secondary de alguien. - **Salarios competitivos de mercado** revisados anualmente. - **Oportunidades de crecimiento visibles** (certificaciones AWS/Azure pagadas, participación en conferencias).

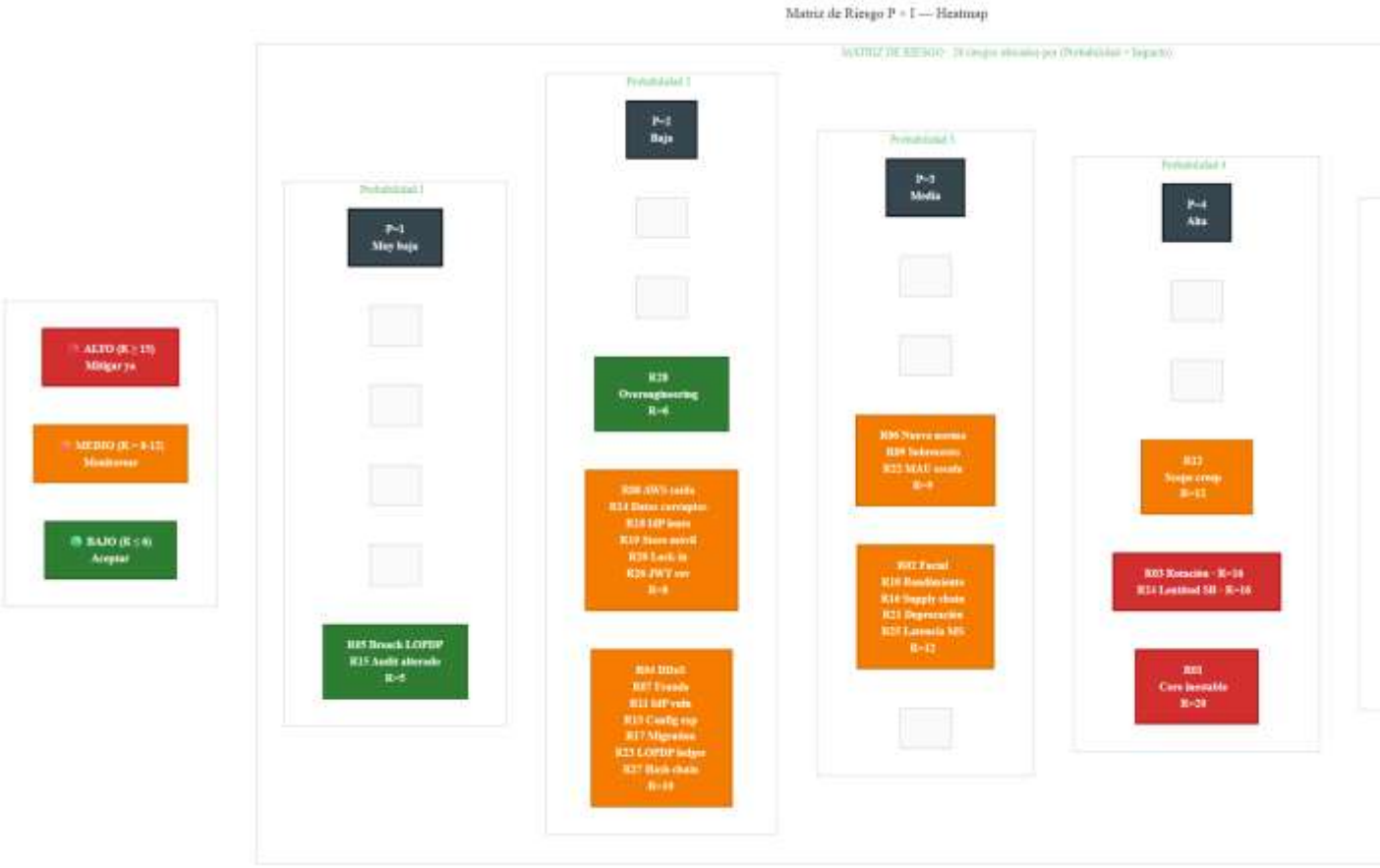
12.3.3 R24 — Lentitud regulatoria SB (R=16)

Hallazgo del debate adversarial (JB-2020-2398). La aprobación de proveedores cloud críticos puede demorar 2-6 meses. **Mitigación clave**: workstream regulatorio arrancado el Sprint 1, no al final del Incremento 4. Relación proactiva con la SB mediante reuniones mensuales. Preparación anticipada de DPA, TIA, plan de salida contractual del proveedor cloud. Eventual plan B: iniciar con Opción B (Keycloak self-hosted) mientras se tramita la aprobación de Opción A (Entra External ID).

12.3.4 R02, R10, R12, R16, R21, R23, R25 — Nivel medio (R=10-12)

- **R02 Facial**: dual vendor desde día 1 + umbral configurable + proceso manual de respaldo.
- **R10 Rendimiento**: load testing agresivo (3× esperado) antes de GA + plan de scale-out + load shedding automático.
- **R12 Scope creep**: Change Control Board + backlog priorizado + “no” cuando corresponde.
- **R16 Supply chain**: Snyk + SCA + Dependabot + policy de review + CSP + SRI.
- **R21 Deprecación vendor**: preferir estándares abiertos; monitoreo activo; ejemplo reciente: QLDB (ver ADR-11 revisado).
- **R23 LOPDP vs ledger**: crypto-shredding documentado; base legal Art. 12 num. 2.
- **R25 Latencia microservicios**: budget por servicio + tracing distribuido + BFF para agregación.

12.4 Matriz visual de riesgo (heatmap)



Matriz de Riesgo P × I — Heatmap con los 28 riesgos

12.5 Gestión continua de riesgos

- **Revisión quincenal** en Scrum of Scrums: estado de los top 10 riesgos, nuevos riesgos emergentes, cierre de riesgos resueltos.
- **Revisión mensual** en Steering Committee: matriz completa, decisiones de escalamiento, presupuesto de mitigación.
- **Registro vivo** del risk register en Confluence (o equivalente) con historial de cambios.
- **Cada pentest, Game Day y chaos experiment** actualiza la matriz con lecciones aprendidas.
- **Postmortems blame-free** de incidentes SEV2+ alimentan nuevos riesgos identificados.

12.6 Observación final

La matriz incluye los riesgos emergentes del debate adversarial aplicado al Capítulo 4 (ADR-01, ADR-05, ADR-11). La incorporación temprana de estos riesgos — en lugar

de descubrirlos tras un incidente — es evidencia del valor del proceso de revisión crítica previo al go-live. Se recomienda repetir el ejercicio adversarial al final del Incremento 2 y antes del Incremento 4, cuando el diseño detallado haya evolucionado.

---

13 Anexos

13.1 Anexo A — Glosario de términos

Término	Definición
AAL (Authentication Assurance Level)	Nivel de aseguramiento de autenticación definido por NIST SP 800-63B. AAL1 = autenticación de un solo factor; AAL2 = multifactor; AAL3 = multifactor con factor criptográfico resistente a phishing.
ACID	Propiedades de las transacciones de base de datos: Atomicidad, Consistencia, Aislamiento, Durabilidad.
ADR (Architecture Decision Record)	Documento que registra una decisión arquitectónica significativa con su contexto, opciones evaluadas, decisión tomada, justificación y consecuencias.
Agregado (DDD)	Grupo de objetos de dominio tratado como una unidad de cambio; tiene una raíz (aggregate root) que garantiza invariantes.
Anchor (auditoría)	Snapshot periódico del estado del ledger (hash raíz) persistido en almacenamiento inmutable externo para verificación posterior.
AOT (Ahead-of-Time compilation)	Compilación a código máquina nativo antes de la ejecución (Flutter, GraalVM). Contrasta con JIT.
AZ (Availability Zone)	Zona de disponibilidad de AWS: datacenter físicamente separado dentro de una región, con conectividad baja latencia.
BFF (Backend-for-Frontend)	Patrón donde cada aplicación cliente (SPA, móvil) tiene su propio backend ligero que agrega llamadas a microservicios y maneja sesión.
BIAN (Banking Industry Architecture Network)	Arquitectura de referencia estándar de la industria bancaria. Define dominios de servicio (Payment Order, Customer Reference Data, etc.).
Bounded Context (DDD)	Frontera explícita dentro de la cual un modelo de dominio tiene sentido. Cada microservicio idealmente representa un bounded context.

Término	Definición
BCP (Business Continuity Plan)	Plan de continuidad del negocio: procedimientos documentados para mantener operaciones críticas durante y después de un incidente.
Cache-Aside	Patrón de cache donde la aplicación consulta primero el cache; si hay miss, consulta la fuente de verdad y popula el cache.
CAP (teorema)	Brewer: un sistema distribuido solo puede garantizar 2 de 3: Consistencia, Disponibilidad, Tolerancia a Particiones.
CDC (Change Data Capture)	Técnica que captura cambios de una base de datos y los emite como eventos (ej. Debezium sobre WAL de PostgreSQL).
CDE (Cardholder Data Environment)	Entorno donde se procesan, almacenan o transmiten datos de tarjetas (scope de PCI-DSS).
CIAM (Customer Identity and Access Management)	Gestión de identidad para clientes finales (retail). Contrasta con Workforce Identity.
Circuit Breaker	Patrón de resiliencia que detiene llamadas a un servicio cuando detecta fallas repetidas, evitando cascada.
Clean Architecture	Arquitectura propuesta por Robert C. Martin donde las capas externas dependen de las internas (regla de dependencia).
CoreDNS	Servidor DNS por defecto en Kubernetes para service discovery interno.
Correlation-ID	Identificador único propagado a través de todos los componentes que atraviesa un request, para trazabilidad end-to-end.
CQRS (Command Query Responsibility Segregation)	Patrón que separa los modelos de escritura (comandos) y lectura (consultas).
Crypto-shredding	Técnica de supresión de datos donde se destruye la clave de cifrado en lugar del dato; vuelve el dato matemáticamente ilegible.
DDD (Domain-Driven Design)	Enfoque de diseño que modela el software según el dominio del negocio (Eric Evans, 2003).
DLQ (Dead Letter Queue)	Cola donde se envían mensajes que no pudieron procesarse tras N reintentos, para análisis manual.
DORA metrics	Cuatro métricas de performance de entrega de software según DevOps Research and Assessment: Deployment Frequency, Lead Time for Changes, Change Failure Rate, MTTR.

Término	Definición
DPA (Data Processing Agreement)	Contrato entre controlador y procesador de datos personales que establece las obligaciones del procesador.
DPO (Data Protection Officer)	Delegado de Protección de Datos, figura obligatoria en LOPDP para tratamientos de alto riesgo.
Debezium	Plataforma de CDC open-source que captura cambios de bases de datos y los emite a Kafka.
EIPD (Evaluación de Impacto a la Protección de Datos)	Análisis formal exigido por LOPDP Art. 44 para tratamientos de alto riesgo (ej. biometría).
EKS (Elastic Kubernetes Service)	Servicio managed de Kubernetes de AWS.
ELK	Stack de observabilidad: Elasticsearch + Logstash + Kibana.
ELK layout engine	Eclipse Layout Kernel, motor de layout para grafos complejos usado por Mermaid.
Event Sourcing	Patrón donde el estado del sistema se deriva de una secuencia de eventos inmutables, en lugar de mutar directamente el estado.
Event Storming	Taller colaborativo con stakeholders de negocio para descubrir eventos de dominio y bounded contexts.
FAL (Federation Assurance Level)	Nivel de aseguramiento de federación de identidad según NIST SP 800-63C.
FIDO2 / WebAuthn	Estándares de autenticación sin contraseña con factores criptográficos resistentes a phishing.
GitOps	Práctica donde el estado deseado de la infraestructura/aplicación vive en Git y un operador (ej. ArgoCD) lo sincroniza al cluster.
HA (High Availability)	Alta disponibilidad: capacidad del sistema de operar continuamente con mínimo downtime.
Hash-chain	Secuencia de registros donde cada uno incluye el hash del anterior, detectando cualquier manipulación.
Hexagonal Architecture (Ports & Adapters)	Arquitectura propuesta por Alistair Cockburn donde el dominio está aislado de la infraestructura mediante puertos y adaptadores.
HMAC	Hash-based Message Authentication Code: hash criptográfico con una clave secreta, usado para verificar integridad y autenticidad.

Término	Definición
HPA (Horizontal Pod Autoscaler)	Controlador de Kubernetes que escala el número de réplicas de un deployment según métricas.
HSM (Hardware Security Module)	Dispositivo físico dedicado a almacenar y operar con material criptográfico.
IaC (Infrastructure as Code)	Infraestructura definida en código versionado (Terraform, CDK, Pulumi).
IAL (Identity Assurance Level)	Nivel de aseguramiento de la identidad según NIST SP 800-63A.
IdP (Identity Provider)	Proveedor de identidad; emite y verifica credenciales.
JWKS (JSON Web Key Set)	Conjunto de claves públicas publicadas por un IdP para verificar firmas de JWT.
JWT (JSON Web Token)	Token firmado digitalmente que transporta claims (datos) sobre el usuario autenticado.
KMS (Key Management Service)	Servicio de gestión de claves criptográficas.
LOPDP	Ley Orgánica de Protección de Datos Personales (Ecuador, 2021).
MAU (Monthly Active Users)	Usuarios activos mensuales.
mTLS (mutual TLS)	TLS con autenticación bidireccional: cliente y servidor presentan certificados.
MSK (Managed Streaming for Kafka)	Servicio managed de Apache Kafka de AWS.
NOC (Network Operations Center)	Centro de operaciones de red.
OIDC (OpenID Connect)	Capa de identidad sobre OAuth 2.0 que añade claims estándar sobre el usuario.
OTP (One-Time Password)	Contraseña de un solo uso, típicamente de corta vigencia.
Outbox Pattern	Patrón donde eventos se persisten atómicamente con los cambios de dominio en una tabla outbox, y un relay los publica después.
PCI-DSS	Payment Card Industry Data Security Standard: estándar de seguridad para datos de tarjetas.
PERT	Program Evaluation and Review Technique: método de

Término	Definición
	estimación con 3 escenarios (optimista/normal/pesimista).
PKCE	Proof Key for Code Exchange (RFC 7636): extensión de OAuth 2.0 que previene interceptación del authorization code.
PLAFT	Prevención de Lavado de Activos y Financiamiento del Terrorismo.
RF (Requisito Funcional)	Qué debe hacer el sistema.
RNF (Requisito No Funcional)	Cómo debe comportarse el sistema (performance, seguridad, disponibilidad, etc.).
RPO (Recovery Point Objective)	Máxima cantidad de datos (en tiempo) que se tolera perder en un incidente.
RTO (Recovery Time Objective)	Máximo tiempo tolerable para recuperar operación tras un incidente.
SAFe (Scaled Agile Framework)	Marco de ágil escalado para múltiples equipos/squads coordinados.
SAST	Static Application Security Testing: análisis estático del código buscando vulnerabilidades.
SCA	Software Composition Analysis: análisis de dependencias de terceros buscando vulnerabilidades.
SCCs (Standard Contractual Clauses)	Cláusulas contractuales tipo aprobadas para transferencia internacional de datos personales.
SIEM	Security Information and Event Management: agregación y correlación de eventos de seguridad.
SLA (Service Level Agreement)	Compromiso formal de nivel de servicio (ej. 99.95% disponibilidad).
SLI (Service Level Indicator)	Métrica concreta usada para evaluar el nivel de servicio (ej. error rate, latencia p95).
SLO (Service Level Objective)	Objetivo interno de nivel de servicio (más estricto que el SLA externo).
SOC (Security Operations Center)	Centro de operaciones de seguridad.
SPA (Single Page Application)	Aplicación web que corre en una sola página HTML, con ruteo cliente-side.
SPOF (Single Point of Failure)	Componente cuya falla deja todo el sistema inoperable.
SRE (Site Reliability Engineering)	Disciplina de Google que aplica ingeniería al problema de operar sistemas confiables a escala.

Término	Definición
Step-up authentication	Elevación dinámica del nivel de autenticación requerido (AAL2 → AAL3) ante operaciones de alto riesgo.
TIA (Transfer Impact Assessment)	Evaluación de impacto de transferencias internacionales de datos personales.
TPS (Transactions Per Second)	Transacciones por segundo.
TSA (Timestamping Authority)	Autoridad confiable que emite sellos de tiempo firmados digitalmente según RFC 3161.
TTL (Time To Live)	Tiempo de vida de un registro antes de ser expirado automáticamente.
VPC (Virtual Private Cloud)	Red virtual privada dentro de un proveedor cloud.
WAF (Web Application Firewall)	Firewall de capa 7 que protege aplicaciones web de amenazas (OWASP Top 10).
WCAG (Web Content Accessibility Guidelines)	Pautas de accesibilidad web del W3C.

13.2 Anexo B — Lista de siglas

Sigla	Expansión
ADR	Architecture Decision Record
API	Application Programming Interface
ASVS	Application Security Verification Standard (OWASP)
AWS	Amazon Web Services
BIAN	Banking Industry Architecture Network
CDC	Change Data Capture
CIS	Center for Internet Security
CRM	Customer Relationship Management
CSF	Cybersecurity Framework (NIST)
DDD	Domain-Driven Design
DR	Disaster Recovery
EIPD	Evaluación de Impacto a la Protección de Datos
ELK	Elasticsearch + Logstash + Kibana
EMU	English Metric Unit (unidad de OOXML)

Sigla	Expansión
GDPR	General Data Protection Regulation (UE)
HA	High Availability
HSM	Hardware Security Module
IAM	Identity and Access Management
ISO	International Organization for Standardization
JB	Junta Bancaria (Ecuador)
KMS	Key Management Service
LOPDP	Ley Orgánica de Protección de Datos Personales (Ecuador)
MAU	Monthly Active Users
MFA	Multi-Factor Authentication
MSK	Managed Streaming for Kafka
NIST	National Institute of Standards and Technology (USA)
OIDC	OpenID Connect
ODS	Operational Data Store
OWASP	Open Web Application Security Project
PCI-DSS	Payment Card Industry Data Security Standard
PKCE	Proof Key for Code Exchange
PLAFT	Prevención de Lavado de Activos y Financiamiento del Terrorismo
PMBOK	Project Management Body of Knowledge
QLDB	Quantum Ledger Database (AWS — deprecado)
RBAC	Role-Based Access Control
RTO / RPO	Recovery Time Objective / Recovery Point Objective
SAFe	Scaled Agile Framework
SB	Superintendencia de Bancos (Ecuador)
SIEM	Security Information and Event Management
SLA / SLO / SLI	Service Level Agreement / Objective / Indicator
SOC	Security Operations Center / Service Organization Control
SPA	Single Page Application
SRE	Site Reliability Engineering
SSO	Single Sign-On
TOTP	Time-based One-Time Password
TSA	Timestamping Authority
TSC	Trust Services Criteria (SOC 2)

Sigla	Expansión
VPC	Virtual Private Cloud
WAF	Web Application Firewall
WCAG	Web Content Accessibility Guidelines

13.3 Anexo C — Referencias bibliográficas y normativas

13.3.1 Libros y papers fundacionales de arquitectura

- **Brown, Simon.** *The C4 Model for Software Architecture*. (c4model.com)
- **Brooks, Fred.** *The Mythical Man-Month: Essays on Software Engineering*. Addison-Wesley, 1975.
- **Cockburn, Alistair.** *Hexagonal Architecture (Ports and Adapters)*. 2005.
- **Evans, Eric.** *Domain-Driven Design: Tackling Complexity in the Heart of Software*. Addison-Wesley, 2003.
- **Fowler, Martin.** *Patterns of Enterprise Application Architecture*. Addison-Wesley, 2002.
- **Gamma, Erich; Helm, Richard; Johnson, Ralph; Vlissides, John.** *Design Patterns: Elements of Reusable Object-Oriented Software*. Addison-Wesley, 1994. (Gang of Four)
- **Hohpe, Gregor; Woolf, Bobby.** *Enterprise Integration Patterns*. Addison-Wesley, 2003.
- **Kleppmann, Martin.** *Designing Data-Intensive Applications*. O'Reilly, 2017.
- **Martin, Robert C.** *Clean Architecture: A Craftsman's Guide to Software Structure and Design*. Prentice Hall, 2017.
- **McConnell, Steve.** *Software Estimation: Demystifying the Black Art*. Microsoft Press, 2006.
- **Nygard, Michael T.** *Release It! Design and Deploy Production-Ready Software*. Pragmatic Bookshelf, 2018 (2ª ed.).
- **Richardson, Chris.** *Microservices Patterns*. Manning, 2018.
- **Vernon, Vaughn.** *Implementing Domain-Driven Design*. Addison-Wesley, 2013.

13.3.2 Estándares y marcos normativos aplicados

- **ISO/IEC 25010:2011** — Systems and software Quality Requirements and Evaluation (SQuaRE) — System and software quality models.
- **ISO/IEC 27001:2022** — Information security, cybersecurity and privacy protection — Information security management systems — Requirements.
- **ISO/IEC 27701:2019** — Privacy Information Management System.
- **ISO 22301:2019** — Societal security — Business continuity management systems.
- **ISO/IEC 42010:2022** — Architecture description.

- **ISO 9241-11:2018** — Ergonomics of human-system interaction — Usability.
- **ISO 9241-210:2019** — Human-centred design for interactive systems.
- **NIST Cybersecurity Framework v2.0** (2024).
- **NIST SP 800-53 Rev. 5** — Security and Privacy Controls for Information Systems and Organizations.
- **NIST SP 800-63B** — Digital Identity Guidelines: Authentication and Lifecycle Management.
- **NIST SP 800-63C** — Digital Identity Guidelines: Federation and Assertions.
- **PCI-DSS v4.0** (2022).
- **AWS Well-Architected Framework** — 6 pilares (2023).
- **OWASP Top 10 (2021)**.
- **OWASP ASVS v4.0**.
- **CIS Controls v8**.
- **CIS Kubernetes Benchmark v1.9**.
- **RFC 6749** — The OAuth 2.0 Authorization Framework.
- **RFC 7636** — Proof Key for Code Exchange by OAuth Public Clients (PKCE).
- **RFC 8414** — OAuth 2.0 Authorization Server Metadata (incluye back-channel logout).
- **RFC 3161** — Internet X.509 Public Key Infrastructure Time-Stamp Protocol (TSP).
- **RFC 9126** — OAuth 2.0 Pushed Authorization Requests (PAR).
- **RFC 9449** — OAuth 2.0 Demonstrating Proof of Possession (DPoP).

13.3.3 Normativa Ecuador aplicable

- **Ley Orgánica de Protección de Datos Personales (LOPDP)** — Registro Oficial Suplemento Nº 459, 26 mayo 2021.
- **Código Orgánico Monetario y Financiero (COMF)**.
- **Resoluciones de la Superintendencia de Bancos del Ecuador** vigentes en materia de seguridad de la información y servicios financieros digitales (incluyendo JB-2020-2398 sobre servicios tecnológicos en la nube).
- **Ley Orgánica de Telecomunicaciones + regulación ARCOTEL**.

13.3.4 Marcos sectoriales y buenas prácticas

- **BIAN (Banking Industry Architecture Network)** — Reference Architecture.
- **Basilea III** — Marco internacional para la regulación bancaria.
- **PSD2 / Open Banking** — Directiva 2015/2366/UE (referencia).
- **SAFe 6.0 Reference Guide** — Scaled Agile, 2023.
- **PMBOK Guide — Seventh Edition** — PMI, 2021.

- **DORA — Accelerate: The Science of Lean Software and DevOps** — Forsgren, Humble, Kim. 2018.

13.3.5 Fuentes de datos de mercado (Capítulo 1)

- **Asobanca** — *La era de la banca digital en Ecuador: Reporte de transacciones*. Disponible en asobanca.org.ec.
- **Banco Mundial** — *Global Findex Database 2024*.
- **Forbes Ecuador** — *Ranking de bancos por activos y patrimonio 2024/2025*.
- **Primicias.ec**, **El Comercio**, **Ecuador221** — reportes sobre banca digital en Ecuador 2025-2026.
- **Banred** — cifras públicas de transferencias interbancarias.

13.4 Anexo D — Fichas técnicas de componentes clave

13.4.1 Componentes de la plataforma

Componente	Versión	Rol	Alternativas evaluadas
Amazon EKS	Kubernetes 1.29+	Orquestación de contenedores	GKE, AKS (portabilidad asegurada)
Spring Boot	3.x	Framework de microservicios	Quarkus (futuro); Node.js, Go, .NET (descartados — ver ADR-01)
Java	21 LTS	Lenguaje de backend	17 LTS (adopción mayoritaria actual); Kotlin (interop)
Angular	17+ con Nx	SPA web	React, Vue (evaluados en ADR-03)
Flutter	3.x	App móvil multiplataforma	React Native, KMM (evaluados en ADR-04)
Aurora PostgreSQL	15+	BD operacional + audit ledger append-only	MySQL, DynamoDB (para casos específicos)
DocumentDB (Mongo-compatible)	5.0	Detalle de cliente (datos poco estructurados)	MongoDB Atlas, DynamoDB
Amazon MSK (Kafka)	3.6	Event streaming + outbox relay	Self-hosted Kafka, Confluent
RabbitMQ	3.12	Mensajería transaccional (comandos async)	ActiveMQ, Amazon SQS (menos features)

Componente	Versión	Rol	Alternativas evaluadas
ElastiCache Redis	7.x	Cache-Aside, idempotency, blocklist	Memcached (menos features)
MinIO	reciente	Object storage interno S3-compatible	S3 directo (menos control)
Amazon S3	—	Archive long-term + anchor del ledger	—
HashiCorp Vault	1.15+	Gestión de secretos, PKI, Transit encryption	AWS Secrets Manager (complementario)
Keycloak	23+	IdP OSS (Opción B del ADR-05)	Microsoft Entra External ID (Opción A)
Spring Cloud Gateway	4.x	API Gateway interno	AWS API Gateway (edge), Kong
Jenkins	reciente	CI (declarative pipelines)	GitHub Actions, GitLab CI
ArgoCD	reciente	CD (GitOps)	FluxCD
Prometheus + Grafana	reciente	Métricas + dashboards	CloudWatch (complementario)
ELK (Elasticsearch, Logstash, Kibana)	8.x	Logs centralizados	AWS OpenSearch (fork gestionado)
Jaeger	reciente	Distributed tracing	AWS X-Ray

13.4.2 Proveedores de identidad y biometría (según ADR-05 y ADR-08)

Componente	Rol	Opciones
IdP CIAM	Autenticación clientes retail	Microsoft Entra External ID (Opción A) · Keycloak OSS (Opción B)
IdP Workforce	Autenticación operadores internos	Microsoft Entra ID P1/P2 · Keycloak realm separado
Reconocimiento facial principal	Liveness + match	AWS Rekognition + Face Liveness
Reconocimiento facial fallback	Casos de alto riesgo o certificación banca	Veridas
WhatsApp	Notificaciones por	Twilio BSP

Componente	Rol	Opciones
Business API	WhatsApp	
Timestamping Authority (TSA)	RFC 3161 para anchor del ledger	DigiCert TSA (primario) · FreeTSA (secundario)

13.5 Anexo E — Decisiones futuras (ADRs pendientes)

Decisiones identificadas pero diferidas a la etapa de implementación o a incrementos futuros, para evitar sobre-diseño prematuro:

ADR futuro	Momento sugerido	Alcance
ADR-13 Estrategia de testing (unit, integration, contract, e2e, chaos)	Sprint 2	Definir pirámide de testing por squad + criterios de cobertura + herramientas
ADR-14 Feature flags (framework + gobernanza)	Sprint 3	Unleash, LaunchDarkly, o solución propia; convenciones de uso
ADR-15 Service mesh completo (si la complejidad lo justifica)	Incremento 3	Istio vs linkerd vs cert-manager + Spring Cloud actual
ADR-16 Estrategia Open Banking (APIs reguladas)	Año 2	Si la Superintendencia de Bancos adopta normativa tipo PSD2
ADR-17 Data lake / warehouse analítico	Año 2	Si se requiere analítica avanzada; Redshift vs Snowflake vs data lakehouse
ADR-18 ML/AI para scoring antifraude	Año 2	SageMaker vs equipo propio; modelos de risk scoring
ADR-19 Estrategia de internacionalización / multi-país	Año 2-3	Si BP expande a otros países; multi-región, multi-moneda, multi-regulación

Cada ADR futuro deberá seguir la misma metodología del Capítulo 4: contexto, opciones evaluadas, decisión, justificaciones teóricas (mínimo dos), consecuencias y mitigaciones.